BÁO CÁO KIỂM THỬ BẢO MẬT ỨNG DỤNG WEB SHOPLAB

TỔNG HỢP PHẦN 1 ĐẾN PHẦN 8 VÀ KIỂM THỬ BỔ SUNG CAPTCHA

Đợt kiểm thử SL-PT-20260925 • Phiên bản báo cáo 1.1 • Cập nhật ngày 06/10/2026

Người nhận: Chủ dự án ShopLab. Hình thức đánh giá: kiểm thử gray-box trong môi trường thử nghiệm nội bộ của ứng dụng.

Báo cáo trình bày kết quả kiểm thử ứng dụng ShopLab trong môi trường local, gồm khảo sát bề mặt, xác thực và phiên, phân quyền, logic nghiệp vụ, xử lý đầu vào, tệp và cấu hình triển khai. Đợt gốc diễn ra ngày 25–26/09/2026; hồ sơ được đối chiếu ngày 30/09/2026. Kiểm thử bổ sung CAPTCHA đăng nhập được thực hiện ngày 06/10/2026 trên mã nguồn hiện tại.

Kết luận chính

Đợt gốc xác nhận bốn phát hiện mức Low: phân biệt email khi đăng ký, checkout vượt giới hạn tiền, ID ngoài Int32 gây lỗi máy chủ và phạm vi phục vụ tệp của Vite. Cả bốn còn Open, chưa được kiểm tra lại sau sửa. Phần bổ sung CAPTCHA có 2 bài kiểm thử tích hợp và 15 tình huống đạt tiêu chí; không ghi nhận bỏ qua mã xác minh trong các trường hợp đã thử. Một quan sát Informational về việc đổi mã theo email được bổ sung. Docker/Nginx/TLS và image runtime chưa được kiểm thử thực tế.

Ưu tiên đầu tiên là thu hẹp vùng file Vite có thể phục vụ trước khi chia sẻ môi trường dev. Tiếp theo chuẩn hóa giới hạn ID và tổng tiền, rồi chốt chính sách bảo vệ sự tồn tại email. Các yêu cầu chuyển sang production được theo dõi riêng, không gộp với lỗ hổng đã tái hiện.

ID	Kết quả xác nhận	Mức / trạng thái
F-P2-001	Phân biệt email đã đăng ký qua phản hồi đăng ký	Low / Open
F-P4-001	Checkout tổng rất lớn trả 500; rollback đúng	Low / Open
F-P5-001	ID ngoài Int32 trả 500	Low / Open
F-P7-001	Vite phục vụ JSON trong .local qua /@fs/	Low / Open

MỤC LỤC

PHẠM VI VÀ CÁCH ĐỌC BÁO CÁO 3
PHẦN 1 Môi trường và thu thập thông tin 4
PHẦN 2 Xác thực và quản lý phiên 11
PHẦN 3 Phân quyền và IDOR 21
PHẦN 4 Logic nghiệp vụ 32
PHẦN 5 Input output XSS và CSRF 42
PHẦN 6 Upload download và SSRF 52
PHẦN 7 Cấu hình dependency và mã nguồn 62
BỔ SUNG KIỂM THỬ CAPTCHA ĐĂNG NHẬP 72
PHẦN 8 Kết luận toàn đợt và kế hoạch khắc phục 76

Mỗi phép thử có mã tình huống và mã bằng chứng để tra cứu trong hồ sơ kỹ thuật. Đường dẫn tương đối trong báo cáo được tính từ thư mục dự án tại thời điểm kiểm thử.

PHẠM VI VÀ CÁCH ĐỌC BÁO CÁO

Target đã kiểm thử chủ yếu là http://localhost:5173 qua Vite và API local. Phiên bản ứng dụng báo 0.1.0; chưa có baseline Git HEAD tại Phần 1. SHA-256 các file được dùng làm dấu vết đối chiếu, không thay thế việc đóng băng image/commit và restart mọi tiến trình.

Ngoài phạm vi: khai thác hệ điều hành, Docker escape, gây từ chối dịch vụ, dịch vụ bên thứ ba, dữ liệu/mật khẩu thật, mục tiêu Internet và cloud metadata. Những thao tác ghi dùng fixture riêng, có cleanup và kiểm tra theo từng phần. SMTP inbox là công cụ hỗ trợ local, không phải đối tượng khai thác.

PASS là đáp ứng tiêu chí của phép thử; REVIEW là kết quả cần đối chiếu hoặc xác minh thêm; PARTIAL là phép thử chưa thực hiện đầy đủ. Open là phát hiện chưa được khắc phục và kiểm tra lại. Số phát hiện được thống kê theo nguyên nhân, không theo số request hay số ảnh.

Kết quả từng chương phản ánh trạng thái ứng dụng tại ngày kiểm thử tương ứng. Danh sách phát hiện và trạng thái hiện hành được trình bày ở phần mở đầu và chương kết luận.

Phần	Khối lượng đã ghi	Lưu ý cách đếm
1	46 paths, 59 operations; 6 ảnh	73 response API browser + 4 GET + 3 logout; không coi 59 là số request
2	21 nhóm; 127 HTTP record; 4 ảnh	87 live và 40 instance cô lập
3	20 nhóm; 212 HTTP record; 4 ảnh	7 đối chiếu DB
4	19 nhóm; 152 HTTP client; 3 ảnh	Một checkout browser riêng; 24 đối chiếu DB
5	19 nhóm chính + 4 đối chứng; 8 ảnh	92 HTTP client; 24 browser record phân loại; 7 đối chiếu DB
6	20 nhóm; 79 HTTP client; 3 ảnh	7 component check; 11 đối chiếu DB/file
7	18 nhóm hỗn hợp; 2 ảnh	22 attempt: 21 response và 1 refused; 4 config check
8	Đối chiếu và tổng hợp ngày 30/09	Không phát sinh request kiểm thử hoặc retest
CAPTCHA	06/10/2026: 2 bài kiểm thử tích hợp; 15 tình huống; 58 HTTP record	Instance và DB kiểm thử riêng; O-CAP-001 Informational

Khối lượng kiểm thử được thống kê riêng theo phương pháp thu thập của từng chương. Các bộ log HTTP client và traffic nền của trình duyệt không có cùng cách đếm nên không cộng thành tổng số request. Hồ sơ gốc gồm 30 ảnh bằng chứng.

PHẦN 1 Môi trường và thu thập thông tin

Môi trường local hoạt động và đã được lập danh mục bề mặt kiểm thử. Giai đoạn khảo sát chưa ghi nhận phát hiện bảo mật; các phép thử chuyên sâu được trình bày ở những chương tiếp theo.

Thông tin	Giá trị
Đợt và phiên bản báo cáo	SL-PT-20260925 • 1.0 • Internal
Thời gian capture	25/09/2026 16:25:21 – 16:25:46 UTC+07
Target chính	http://localhost:5173 và /api
Phương pháp	Kiểm thử gray-box trong môi trường nội bộ ShopLab
Runtime	Node v24.19.0; Playwright 1.63.0; Chrome 153.0.8010.53
Baseline	Ứng dụng trả version 0.1.0; Git chưa có HEAD commit
Hoạt động	27 lượt điều hướng/19 URL route-query khác nhau; 4 browser context
Evidence HTTP	73 response API browser + 4 GET baseline + 3 POST logout riêng
Inventory	46 paths, 59 operations; 16 quan sát luồng bình thường, 43 chưa gọi
Ảnh	6 ảnh viewport trình duyệt kiểm thử

Ý nghĩa và giới hạn

16/59 là mức quan sát method/path, không phải tỷ lệ đạt bảo mật. Các tài khoản user1, user2 và admin chỉ được dùng đăng nhập hợp lệ, đọc trang và đăng xuất. Chưa thử IDOR, brute force, sửa token, injection hoặc race.

Không có thay đổi code ứng dụng trong lượt capture: hash của 81 tệp trong manifest trước/sau trùng nhau. Manifest định danh tệp trên đĩa; không chứng minh toàn bộ tiến trình đã được restart từ bản đó. Các dịch vụ và dữ liệu đang có không được khởi tạo lại trong giai đoạn khảo sát.

1 Phạm vi và cách thực hiện

Đã thực hiện	Phương pháp và bằng chứng
P1-01 Môi trường	GET / và /api/health qua 5173; health qua 127.0.0.1 và backend 4000. Cả 4 trả 200. E-P1-HTTP-01…04.

Đã thực hiện	Phương pháp và bằng chứng
P1-02 Baseline	Kiểm tra Git và tạo SHA-256 manifest 81 tệp; so sánh trước/sau. Không đọc hoặc đưa secret .local vào evidence.
P1-03 Anonymous mapping	8 lượt trang: home, catalogue, product, search/category, login, register, forgot-password. Không gửi đăng ký/reset.
P1-04 Customer mapping	Mỗi user1/user2: profile, cart, orders, support; tổng 8 lượt. Không sửa dữ liệu.
P1-05 Admin mapping	11 lượt gồm 4 trang customer và 7 trang admin: overview, products, users, orders, coupons, tickets, images.
P1-06 Inventory	Tách API được quan sát khỏi operation mới biết qua OpenAPI; đọc route/middleware để bổ sung ngữ cảnh.
P1-07 Evidence	Chụp 6 ảnh, lưu metadata HTTP đã bỏ token/cookie; giữ body chỉ ở trang chủ/health công khai.
P1-08 Cleanup	Gửi logout cho 3 phiên tạo trong đợt, đều nhận 200; đóng browser. Chưa hậu kiểm revocation.

Các request được gửi trực tiếp đến localhost bằng HTTP client và trình duyệt kiểm thử. Bộ điều hướng giới hạn origin ở http://localhost:5173; không ghi nhận request ngoài origin trong lượt khảo sát.

Tác động có chủ đích: tạo phiên đăng nhập, refresh rotation và audit login/logout theo hoạt động bình thường. Không tạo/xóa đơn, coupon, ticket, tệp hay tài khoản. Không sao lưu DB trong phần read-only này; cần snapshot trước các phần có thao tác ghi.

2 Bề mặt và ranh giới cần kiểm thử

Nhóm	Input và tài nguyên	Phần tiếp theo
Auth/session	email/password, reset token, Bearer, refresh cookie, Origin	2
Quyền user/admin	role, userId, orderId, ticketId, messageId, attachmentId	3
Thương mại	productId, quantity, coupon code, shippingAddress, Idempotency-Key	4
Input và browser	q/category/page/limit, review content, profile, ticket message	5

Nhóm	Input và tài nguyên	Phần tiếp theo
Tệp và outbound	multipart file, asset/attachment ID, productId + URL import	6
Deployment	Vite frontend, Express headers, proxy, DB, dependency và source	7

Phân biệt nguồn bằng chứng

Runtime xác nhận giao diện, các GET và luồng login/refresh/logout bình thường. Các input ghi, upload/import và thao tác admin thay đổi dữ liệu chủ yếu được lập bản đồ từ form/OpenAPI/route; chưa được gửi thử trong Phần 1.

Trust boundary dự kiến: browser → Vite /api proxy → Express → PostgreSQL/storage. Một nhánh outbound từ admin image import tới fixture cần kiểm tra riêng. Đây là mô hình dựa trên source; biên mạng Docker không được chứng minh trong phiên này.

Không thuộc kết luận phần này

Không kiểm tra host OS, LAN, Internet, cloud metadata hoặc dịch vụ ngoài ShopLab. Chưa xác minh cổng 8025/1025/4101/4102/55432 bằng network probe; vai trò của chúng chỉ được ghi nhận từ runner. Nginx 8080, HTTPS/TLS và cô lập mạng chưa được đánh giá.

Health route thực hiện SELECT 1 theo source; phản hồi 200 hỗ trợ kết luận DB đáp ứng ở thời điểm đó. Nó không thay cho đánh giá quyền DB, an toàn truy vấn hay backup.

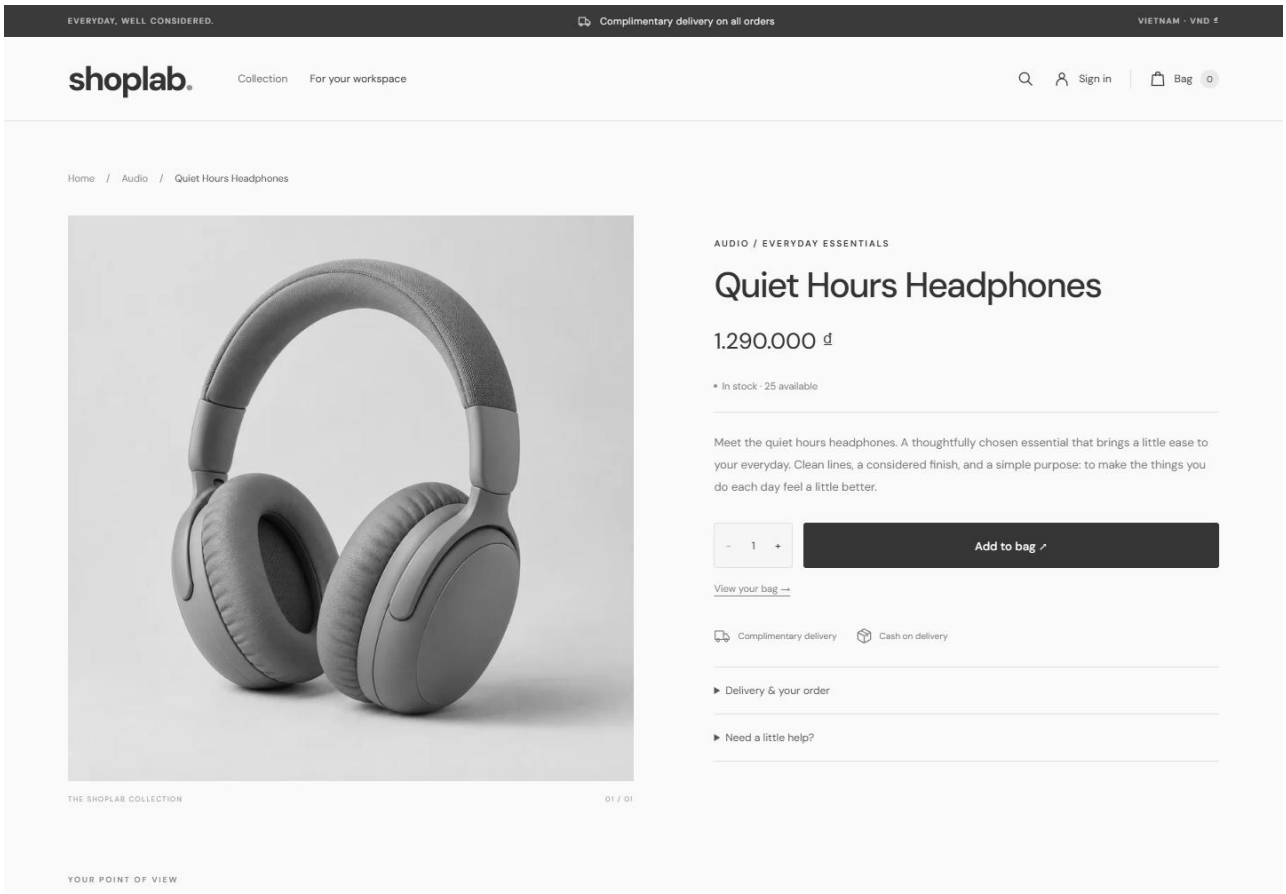
3 Quan sát và kết luận phần một

Mã	Quan sát	Diễn giải
OBS-P1-01	/api/health công khai trả version 0.1.0 và status ok	Thông tin baseline; chưa có tác động để xếp thành vulnerability.
OBS-P1-02	HTML có dấu hiệu Vite dev; API và HTML có bộ header khác nhau	Đây là dev environment. Chưa suy rộng kết quả sang Nginx/production.
OBS-P1-03	Cookie refresh có HttpOnly, SameSite=Strict, Path=/api/auth; không có Secure trong HTTP local	Quan sát header đã che giá trị. Không kết luận lỗi production từ môi trường HTTP này.
OBS-P1-04	11 response refresh 401 và 19 refresh 200 trong hoạt động điều hướng	401 xuất hiện trong các context chưa có phiên; chưa là finding. Kiểm tra expiry/reuse/race thuộc Phần 2.

Mã	Quan sát	Diễn giải
OBS-P1-05	Admin có form upload ảnh và import URL; public product/review và private order/ticket là các ranh giới khác nhau	Cần kiểm tra quyền server và quan hệ owner ở các phần sau.
OBS-P1-06	Git chưa có commit; dữ liệu hiện có không phải DB test sạch	Dùng manifest; tách fixture riêng trước thao tác ghi hoặc đối chứng A/B.

Không phát hiện pageerror JavaScript trong 27 lượt điều hướng. Điều này chỉ mô tả lượt recon, không bảo đảm mọi chức năng hoạt động hoặc không có lỗi bảo mật. Chưa phát hành finding F-xxx và chưa chấm CVSS.

4 Minh chứng giao diện công khai

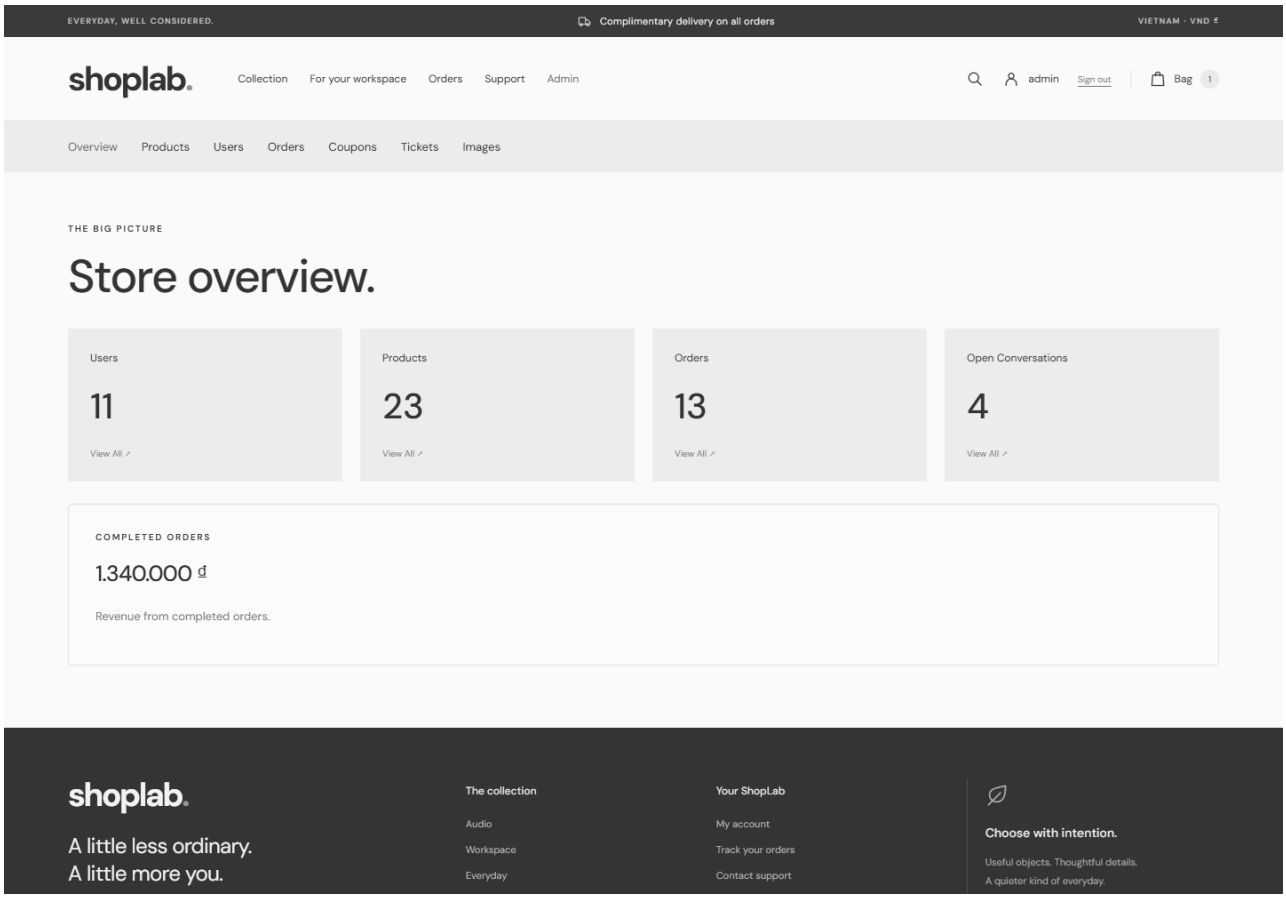


E-P1-03 • Anonymous tại /products/1. Có product ID, giá, tồn kho, thao tác thêm giỏ và review. Ảnh chứng minh bề mặt, không chứng minh lỗi.

Tái lập quan sát: mở /products → chọn sản phẩm đầu tiên. Metadata bắt được GET /api/products/1 và GET /api/products/1/reviews, đều trả 200. Request chi tiết nằm trong recon-results.json / traffic; không chứa Authorization hoặc Cookie nguyên bản.

Các ảnh E-P1-01 home và E-P1-02 catalogue được lưu trong thư mục screenshots. Trang đăng nhập E-P1-04 được chụp trước khi điền thông tin đăng nhập.

5 Minh chứng luồng quản trị hợp lệ

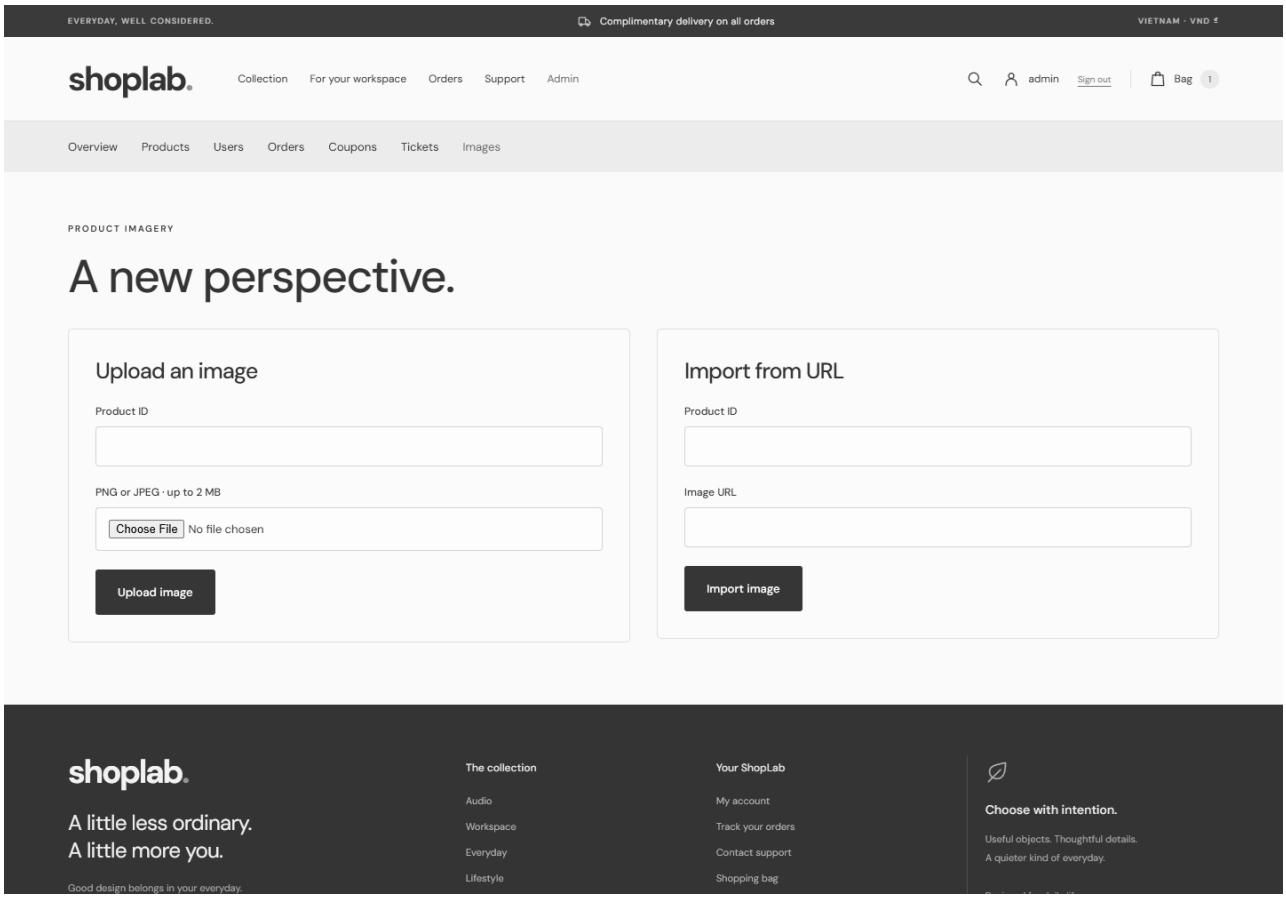


E-P1-05 • /admin sau đăng nhập bằng admin được cấp. Số liệu hiển thị là snapshot của DB đang có; không phải dữ liệu do đợt recon tạo ra.

Ảnh cho thấy điều hướng quản lý sản phẩm, tài khoản, đơn, coupon, ticket và ảnh. GET /api/admin/dashboard trả 200 trong context admin. Chưa gửi token user tới route này, vì phép thử vượt quyền thuộc Phần 3.

Ba phiên được tạo trong lượt khảo sát đều nhận phản hồi logout 200. Quyền quản trị được giữ nguyên.

6 Minh chứng đầu vào ảnh và URL



E-P1-06 • /admin/images. Hai form nhận Product ID cùng file PNG/JPEG hoặc Image URL. Không submit trong Phần 1.

Từ OpenAPI và source: POST /api/admin/products/{id}/image và POST /api/admin/products/{id}/image-import là hai operation cần kiểm tra ở Phần 6. Việc có trường URL không chứng minh SSRF; cần canary/fixture và biên mạng được kiểm chứng trước phép thử.

7 Hồ sơ bằng chứng và khả năng tái lập

Tệp trong part1	Nội dung
recon-results.json	Thời gian UTC, 27 quan sát trang, form/link, 73 metadata phản hồi API, trạng thái logout, lỗi browser.
E-P1-HTTP-01…04.json	GET baseline thực tế, response headers/body public, timestamp và request ID nếu có.
API_INVENTORY.md	59 operation; 16 quan sát luồng bình thường bao gồm logout, 43 chưa gọi.
operation-inventory-reconciled.json	Inventory máy đọc được kèm parameters/requestBody từ OpenAPI; nguồn logout được ghi riêng.

Tệp trong part1	Nội dung
source-manifest-before/after.json	SHA-256 của 81 tệp; không bao gồm secret, node_modules, DB, upload hoặc file cá nhân.
screenshots/E-P1-01…06.png	6 screenshot viewport nguyên gốc từ browser kiểm thử.
evidence-manifest.json	Danh sách tệp evidence, kích thước và SHA-256 để đối chiếu.

SHA-256 của source-manifest-before.json: 61e475776f52500f97ef70a2b2ff842c4b2503b11787b37a0b9f953093bb3758

Mã tái lập: pentest/run-part1.cjs. Không chạy lại trong cùng thư mục evidence nếu cần giữ nguyên lượt này; sao lưu hoặc đổi run ID trước. Các requestBody chỉ lưu tên trường; cookie chỉ lưu thuộc tính với giá trị [REDACTED]. Không lưu mật khẩu, access token, reset token hoặc body dữ liệu riêng.

Nguồn định hướng: pentest/scope.md, ASSESSMENT_SEQUENCE.md, docs/openapi.yaml, docs/authorization-matrix.md và route/middleware hiện tại. Phương pháp báo cáo tham khảo OWASP WSTG v4.2 Reporting: https://wstg.owasp.org/v4.2/5-Reporting/.

PHẦN 2 Xác thực và quản lý phiên

Phần 2 hoàn tất trong phạm vi đã thực hiện. Xác nhận một phát hiện mức Low: phản hồi đăng ký phân biệt email đã tồn tại. Các kiểm tra thu hồi phiên, reset và đổi mật khẩu đạt tiêu chí của những trường hợp đã thử; chưa có bằng chứng chiếm tài khoản trong đợt này.

Thông tin	Giá trị
Đợt và phiên bản	SL-PT-20260925 • Phần 2 • 1.0 • Internal
Người nhận / phương pháp	Chủ dự án ShopLab / kiểm thử gray-box
Thời gian thực thi	25/09/2026 16:42:11 – 25/09/2026 16:44:44 UTC+07
Target live	http://localhost:5173; auth API và PUT /api/users/me/password
Khối lượng	21 nhóm kiểm tra; 127 HTTP record: 87 live, 40 instance cô lập
Kết quả	19 nhóm đạt tiêu chí; 2 nhóm cùng minh chứng một finding F-P2-001
Ảnh	4 ảnh giao diện từ trình duyệt kiểm thử
Công cụ	Node v24.19.0; Playwright 1.63.0; Chrome 153.0.8010.53
Dữ liệu	3 tài khoản synthetic đã dọn; tài khoản có sẵn không thay đổi
Mã ứng dụng	Không sửa source; manifest trước/sau lượt chính trùng nhau

Cách đọc kết quả

PASS áp dụng cho tiêu chí ghi trong từng nhóm. Hai nhóm REVIEW, P2-03 và P2-15, cùng cung cấp bằng chứng cho F-P2-001. Phát hiện này còn Open và chưa được kiểm tra lại sau sửa.

Tác động vận hành tạm thời

Trong lượt kiểm thử ngày 25/09/2026, các thao tác xác thực đã sử dụng hết bucket 30 request/15 phút của IP local. Response cuối ghi RateLimit r=0; t=748 lúc 16:44:44, tương ứng thời điểm khôi phục khoảng 16:57:12. Limiter được giữ nguyên; chuỗi kiểm tra ngưỡng 31 request chạy trên instance cô lập.

Phạm vi môi trường và bảo toàn dữ liệu

Phạm vi gồm đăng ký, đăng nhập, JWT, refresh, logout, forgot/reset và đổi mật khẩu. Origin chuẩn là http://localhost:5173. Request được gửi bằng HTTP client và trình duyệt kiểm thử riêng.

Nguồn bằng chứng	Cách dùng và giới hạn
Live HTTP	P2-01 đến P2-16 và P2-19 đến P2-21. Gửi trực tiếp tới Vite proxy đang chạy; không qua Burp.
Fixture DB có kiểm soát	P2-10 và P2-12 chỉnh thời điểm/trạng thái riêng A/B rồi phục hồi. P2-19–21 tạo riêng C, session và reset pending trong DB.
Instance cô lập cùng source	P2-17/18 dùng loopback port tạm, cùng DB nhưng chỉ đọc fixture B; JWT secret mới độc lập và limiter mới trong process. Instance đã đóng.
Source review	Đọc auth.routes.js, auth.service.js, middleware/auth.js, users.routes.js, app.js và client auth. Không coi đọc source là exploit thành công.

Snapshot và cleanup

Trước thao tác ghi, snapshot nhất quán User, Session, RefreshToken, PasswordResetToken và Cart được lưu riêng trong .local/pentest-backups/SL-PT-20260925. Đây là backup nhạy cảm, đã nằm trong thư mục Git ignore; không đưa nội dung vào bộ báo cáo. Không phải full database backup và chưa thử restore.

Hai fixture A/B được đăng ký qua API; C được tạo qua DB cho phép thử bổ sung. Sau mỗi lượt, xóa đúng các record user/session/refresh/reset/cart/audit thuộc fixture; không xóa tài khoản demo hay dữ liệu mua hàng có sẵn. Đối chiếu toàn bộ record User có sẵn trước/sau không thay đổi. Đối chiếu trong bước này giới hạn ở các bản ghi User có sẵn; những bảng khác và hoạt động đồng thời ngoài lượt kiểm thử chưa được so sánh đầy đủ.

Hai email reset synthetic có thể còn trong inbox in-memory. Token đã vô hiệu vì fixture đã xóa; không xóa thư khác. ID sequence PostgreSQL có thể đã tăng do insert và duplicate thất bại; không cố hoàn tác sequence.

Phạm vi chưa thực hiện

Chưa kiểm thử IDOR, quyền admin, logic thương mại, file/SSRF, XSS/injection, toàn bộ CSRF, TLS/Nginx/production, nhiều replica hay distributed rate limit. Không thực hiện password spraying hoặc tấn công dịch vụ ngoài ShopLab.

F P2 001 Email enumeration qua đăng ký

Mức độ Low • Trạng thái Confirmed và Open • Endpoint POST /api/auth/register • CWE-204 • OWASP WSTG-IDNT-04. Phát hiện dựa trên response thực tế, không chỉ dựa trên source.

Tiền điều kiện và tác động

Không cần đăng nhập. Kẻ thử biết một email ứng viên, chọn username mới và password thỏa validation. Response khác nhau tiết lộ email đã có tài khoản. Thông tin này hỗ trợ chọn mục tiêu phishing hoặc thử credential stuffing; chưa chứng minh lộ password hoặc account

takeover. Rủi ro Low là đánh giá trong bối cảnh ShopLab local; chưa chấm CVSS cho production.

Các bước tái hiện đã thực hiện

1. E-P2-005/006: tạo hai email synthetic mới qua POST register, mỗi email/username độc lập; nhận 200 và role USER. Đây là positive control cho request hợp lệ.

2. E-P2-007: gửi email fixture A đã tồn tại, nhưng username mới p2unique. Body có email, username và password hợp lệ. Nhận 409, error.code=ALREADY_EXISTS, message=A record with these details already exists.

3. E-P2-008: giữ username A đã có và dùng email mới; cũng nhận 409. Biến thể này chứng minh tín hiệu trùng username; không nâng riêng thành finding vì username có thể đã công khai.

4. B-P2-004 và ảnh E-P2-02: dùng browser với email A và một username mới khác; cùng lỗi 409 xuất hiện trên UI. Fixture đã xóa sau thử nghiệm, nên tái lập cần tạo mới cặp control rồi lặp lại bước 2.

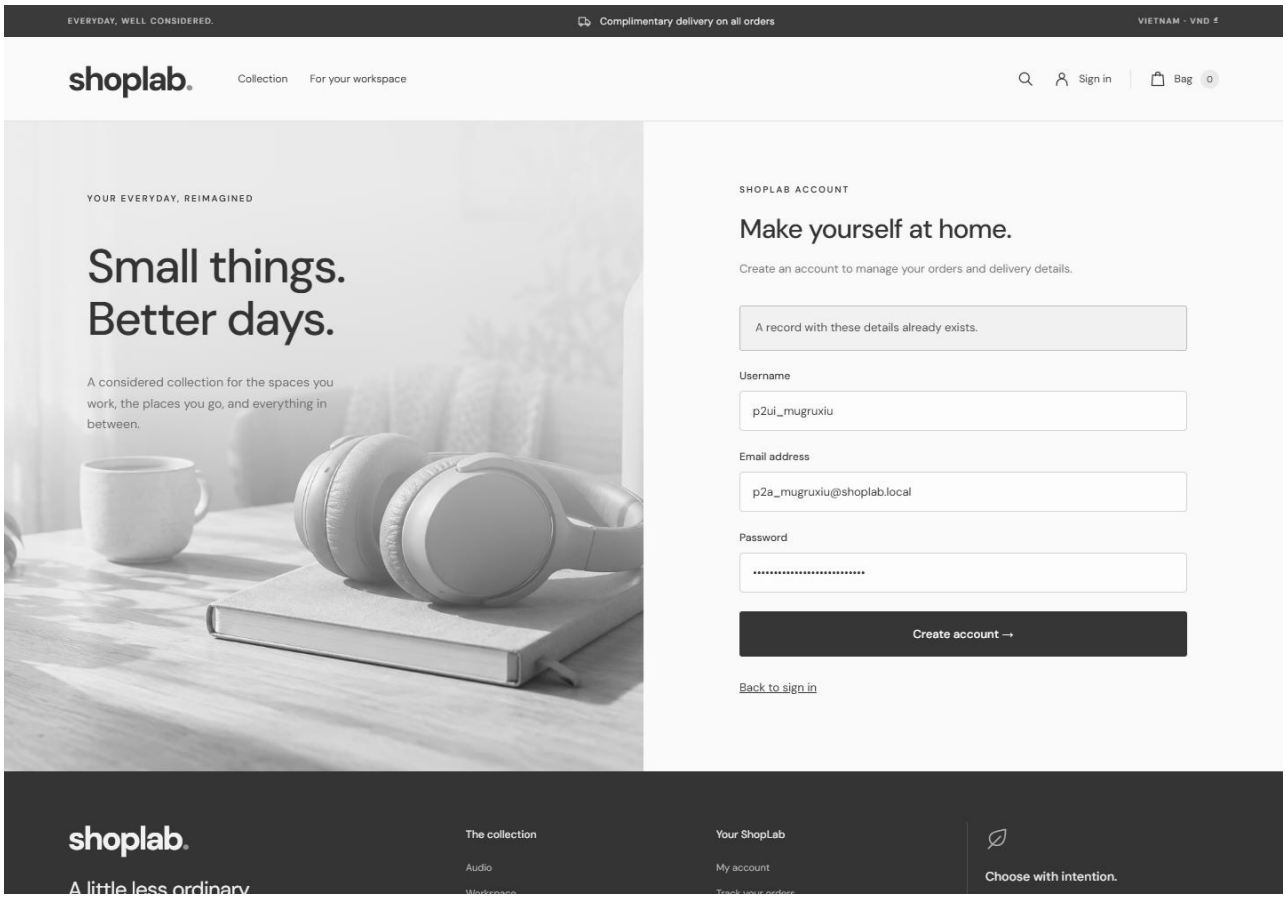
Nguyên nhân và khắc phục

auth.routes.js dòng 16–19 tạo user rồi cấp session ngay. app.js dòng 43 ánh xạ lỗi unique Prisma P2002 sang 409 ALREADY_EXISTS. Khác biệt status/body và việc cấp session khiến chỉ đổi chuỗi thông báo không đủ loại bỏ tín hiệu.

Nếu sản phẩm cần bảo vệ sự tồn tại email, chuyển sang quy trình xác minh email: trả response công khai thống nhất, không cấp session trước xác minh, xử lý thông tin tiếp theo qua email và giữ rate limit/giám sát abuse. Nếu cố ý giữ thông báo trùng để phục vụ UX, ghi nhận chấp nhận rủi ro Low thay vì tuyên bố đã khắc phục.

Tiêu chí retest: đối chiếu email có/không có với username mới; kiểm tra status, response schema, cấp session và timing. Cả hai không được tạo khác biệt công khai cho biết email tồn tại theo thiết kế đã thống nhất. Chưa áp dụng sửa đổi hoặc retest trong đợt này.

Ảnh minh chứng phản hồi đăng ký



E-P2-02 • Email synthetic đã có, username mới. UI hiển thị lỗi trùng sau HTTP 409. Ảnh viewport nguyên gốc, password được trình duyệt che.

Đối chiếu request ID trong http.json, record B-P2-004; control đăng ký mới E-P2-005/006 và biến thể email trùng E-P2-007. Ảnh riêng không chứng minh toàn bộ finding; kết luận dùng cả control và response HTTP.

Kết quả chi tiết P2 01 đến P2 03

P2 01 Baseline và validation đăng ký

Thực hiện: GET health làm đối chứng; POST register với mật khẩu 9 ký tự, 37 ký tự á (74 UTF-8 bytes), rồi field role=ADMIN.

Kết quả: Health 200. Cả ba payload đăng ký bị 400 VALIDATION_ERROR. Đây chỉ là các biên đã thử, chưa phải kiểm tra toàn bộ chính sách mật khẩu.

Bằng chứng: E-P2-001, E-P2-002, E-P2-003, E-P2-004.

P2 02 Đăng ký hợp lệ và thuộc tính cookie

Thực hiện: POST register cho A và B bằng tên/email độc lập, mật khẩu ngẫu nhiên; đọc role, response body, Set-Cookie và metadata JWT.

Kết quả: Hai request 200, role USER, không có passwordHash. Refresh cookie có HttpOnly, SameSite=Strict, Path=/api/auth, Max-Age=604800. JWT HS256, issuer shoplab, audience shoplab-web, exp−iat=1800 giây. Secure vắng mặt trong HTTP local; không suy ra cấu hình HTTPS production.

Bằng chứng: E-P2-005, E-P2-006.

P2 03 Account enumeration tại đăng ký

Kết luận: F-P2-001 được xác nhận.

Thực hiện: Đối chứng E-P2-005/006 tạo tài khoản mới. Gửi lại email A với username mới; tiếp đó username A với email mới.

Kết quả: Cả hai trả 409 ALREADY_EXISTS so với 200 khi mới. Xác nhận F-P2-001; username là tín hiệu phụ, email là tác động riêng tư chính. Không suy ra khả năng chiếm tài khoản.

Bằng chứng: E-P2-007, E-P2-008.

Kết quả chi tiết P2 04 đến P2 06

P2 04 Login lỗi chung và chuẩn hóa email

Thực hiện: Hai cặp login bằng password sai, luân phiên email đã có và email không có; sau đó login đúng với email viết hoa và thêm khoảng trắng.

Kết quả: Bốn request sai đều 401 LOGIN_FAILED cùng thông báo. Login email chuẩn hóa trả 200. Chỉ kiểm tra status/body; không kết luận chống enumeration qua timing với cỡ mẫu nhỏ này.

Bằng chứng: E-P2-009, E-P2-010, E-P2-011, E-P2-012, E-P2-013.

P2 05 Bearer token không hợp lệ

Thực hiện: GET auth/me với access gốc; lặp lại không bearer, chuỗi không phải JWT, JWT sửa chữ ký, JWT alg none.

Kết quả: Control 200; bốn biến thể sai đều 401. Payload ký đúng nhưng sai issuer/audience/exp được kiểm tra riêng tại P2-17, trên instance cô lập.

Bằng chứng: E-P2-014, E-P2-015, E-P2-016, E-P2-017, E-P2-018.

P2 06 Origin của refresh và logout

Thực hiện: POST refresh và logout mang cookie hợp lệ, lần lượt bỏ Origin, dùng http://untrusted.invalid và http://127.0.0.1:5173. GET me lại bằng access gốc.

Kết quả: Sáu thao tác bị 403; access gốc vẫn 200. Đây là phép thử kiểm tra header phía server, chưa mô phỏng toàn bộ hành vi CSRF/SameSite của trình duyệt đa origin. Host 127.0.0.1 khác cấu hình localhost nên bị chặn.

Bằng chứng: E-P2-019, E-P2-020, E-P2-021, E-P2-022, E-P2-023, E-P2-024, E-P2-025.

Kết quả chi tiết P2 07 đến P2 09

P2 07 Refresh thiếu hoặc ngẫu nhiên

Thực hiện: POST refresh không cookie rồi với một chuỗi ngẫu nhiên 32 byte mã hóa base64url.

Kết quả: Cả hai 401. Không dò không gian token, không thực hiện brute force.

Bằng chứng: E-P2-026, E-P2-027.

P2 08 Rotation và phát hiện reuse

Thực hiện: Refresh token T0 của A thành T1; xác nhận access mới; replay T0; dùng lại access/T1; kiểm tra phiên login độc lập của A.

Kết quả: Rotation 200 và giá trị token thay đổi. Replay T0 401, access/T1 của family đó 401. Phiên A độc lập vẫn 200. Bằng chứng kiểm tra cả access và refresh, không chỉ cookie phía client.

Bằng chứng: E-P2-028, E-P2-029, E-P2-030, E-P2-031, E-P2-032, E-P2-033.

P2 09 Logout thu hồi token phía server

Thực hiện: Logout phiên A độc lập; GET me và POST refresh lại bằng token đã lưu trước logout.

Kết quả: Logout 200 và clear-cookie hết hạn về 01/01/1970; access/refresh cũ đều 401. Chỉ thực hiện trên phiên do đợt này tạo.

Bằng chứng: E-P2-034, E-P2-035, E-P2-036.

Kết quả chi tiết P2 10 đến P2 12

P2 10 Hạn phiên và trạng thái tài khoản

Thực hiện: Dùng DB đặt expiresAt của phiên B về quá khứ, gọi me/refresh; phục hồi expiresAt. Đặt riêng account B inactive, gọi lại rồi phục hồi active.

Kết quả: Bốn request ở trạng thái bị cấm đều 401; control sau phục hồi 200. Đây là thử trạng thái được dựng bằng DB, không phải chờ tự hết hạn 7 ngày và không chứng minh idle timeout.

Bằng chứng: E-P2-037, E-P2-038, E-P2-039, E-P2-040, E-P2-041.

P2 11 Forgot password và token sai

Thực hiện: Xin link reset cho A và email không có; chỉ đọc thư A tại inbox local. Gửi token ngẫu nhiên và token hợp lệ với password mới quá ngắn.

Kết quả: Hai forgot response cùng 200 và cùng body. Reset ngẫu nhiên 400, password ngắn 400. Known/unknown mất 49/10 ms trong một cặp đo; chưa đủ mẫu xác nhận hoặc bác bỏ timing enumeration.

Bằng chứng: E-P2-042, E-P2-043, E-P2-044, E-P2-045.

P2 12 Reset token thay thế và hết hạn

Thực hiện: Xin link thứ hai T2 rồi dùng T1. Với T2, đặt expiresAt quá khứ trong DB riêng fixture, thử reset, sau đó phục hồi để dùng tiếp.

Kết quả: T2 khác T1; link bị thay thế và link có expiresAt quá khứ đều 400. Expiry được kiểm tra bằng fixture, chưa chờ 30 phút thời gian thực.

Bằng chứng: E-P2-046, E-P2-047, E-P2-048.

Kết quả chi tiết P2 13 đến P2 15

P2 13 Reset thực tế và thu hồi toàn bộ phiên

Thực hiện: Tạo hai phiên A; mở link T2 trong browser, cập nhật password. Replay link; dùng access/refresh cả hai phiên cũ; login password cũ/mới; kiểm tra B.

Kết quả: UI reset 200; replay 400. Bốn request từ hai phiên A cũ 401. Password cũ 401, password mới 200. B vẫn 200. SMTP chỉ dùng làm inbox thử nghiệm, không đánh giá inbox như mục tiêu tấn công.

Bằng chứng: E-P2-049, E-P2-050, B-P2-001, B-P2-002, E-P2-053, E-P2-054, E-P2-055, E-P2-056, E-P2-057, E-P2-058, E-P2-059, E-P2-060.

P2 14 Refresh đồng thời tối thiểu

Thực hiện: Gửi đúng hai POST refresh đồng thời với cùng cookie A; kiểm tra access của request thành công.

Kết quả: Kết quả [200,401]; access của nhánh thắng sau đó 401 do cơ chế phát hiện reuse thu hồi family. Chỉ một cặp đồng thời; chưa kiểm tra tải hay mọi lịch xen kẽ. Hành vi này có thể ảnh hưởng UX nhiều tab, chưa được xếp là lỗ hổng.

Bằng chứng: E-P2-061, E-P2-062, E-P2-063.

P2 15 Minh chứng enumeration qua trình duyệt

Kết luận: F-P2-001 được xác nhận.

Thực hiện: Mở register trong browser, dùng email A và username mới p2ui; submit hợp lệ.

Kết quả: UI hiện A record with these details already exists.; HTTP 409. Ảnh E-P2-02 tái hiện F-P2-001, không tính là phát hiện thứ hai.

Bằng chứng: B-P2-003, B-P2-004.

Kết quả chi tiết P2 16 đến P2 18

P2 16 Lưu token browser và logout UI

Thực hiện: Login A bằng password mới; đọc tên key localStorage/sessionStorage và khả năng thấy refresh cookie từ JavaScript. Logout bằng nút UI rồi mở profile.

Kết quả: Hai storage rỗng, JavaScript không thấy refresh cookie. Sau logout, profile chuyển về login. Đây là quan sát một browser context; không phải đánh giá đầy đủ XSS, cache hay browser history.

Bằng chứng: B-P2-005, B-P2-006, B-P2-007, B-P2-008, B-P2-009, B-P2-010.

P2 17 JWT expiry issuer audience và subject binding

Thực hiện: Khởi chạy app từ cùng source trên loopback port tạm, dùng JWT secret ngẫu nhiên riêng. Ký token control cho fixture B, rồi biến đổi từng exp/iss/aud/sub/sid và gọi auth/me.

Kết quả: Control có chữ ký đúng trả 200; expired, sai issuer, audience, subject-session binding và sid không tồn tại đều 401. Không dùng hoặc tiết lộ JWT secret thật. Đây là kiểm

thử bổ trợ cùng source, không phải bằng chứng những token tự ký này được gửi tới live instance.

Bằng chứng: E-P2-072, E-P2-073, E-P2-074, E-P2-075, E-P2-076, E-P2-077.

P2 18 Rate limit và X Forwarded For

Thực hiện: Trên instance cô lập có limiter mới: gửi 31 POST login body rỗng, rồi spoof X-Forwarded-For và gọi register/forgot. Không thử danh sách mật khẩu.

Kết quả: 30 request đầu 400, request 31 và ba request sau 429. XFF không vượt được bucket; các endpoint chia sẻ bucket. Chưa kiểm tra reset window theo thời gian, nhiều replica hoặc cấu hình Nginx. Không gửi chuỗi 31 request này tới web live.

Bằng chứng: E-P2-078 đến E-P2-111 (34 records; danh sách đầy đủ trong CASE_LOG.md).

Kết quả chi tiết P2 19 đến P2 21

P2 19 Đổi mật khẩu cần xác thực và mật khẩu hiện tại

Thực hiện: Tạo fixture C qua DB cùng hai phiên và reset token pending; lấy access bằng refresh live. PUT users/me/password thiếu bearer, sai currentPassword, password mới ngắn và thêm role.

Kết quả: Thiếu bearer 401, ba payload sai 400. Hash mật khẩu của C vẫn khớp password cũ. Phiên/reset được dựng bằng DB là tiền điều kiện có kiểm soát, không phải phát hiện khả năng tạo token từ bên ngoài.

Bằng chứng: S-P2-001, S-P2-002, S-P2-003, S-P2-004, S-P2-005, S-P2-006.

P2 20 Session fixation qua cookie trước login

Thực hiện: Login fixture C bằng mật khẩu đúng, đồng thời gửi một refresh cookie đã tồn tại trong request.

Kết quả: Login 200, refresh token và sid mới khác phiên gửi trước. Chưa thực hiện mọi biến thể fixation như cookie injection từ subdomain.

Bằng chứng: S-P2-007.

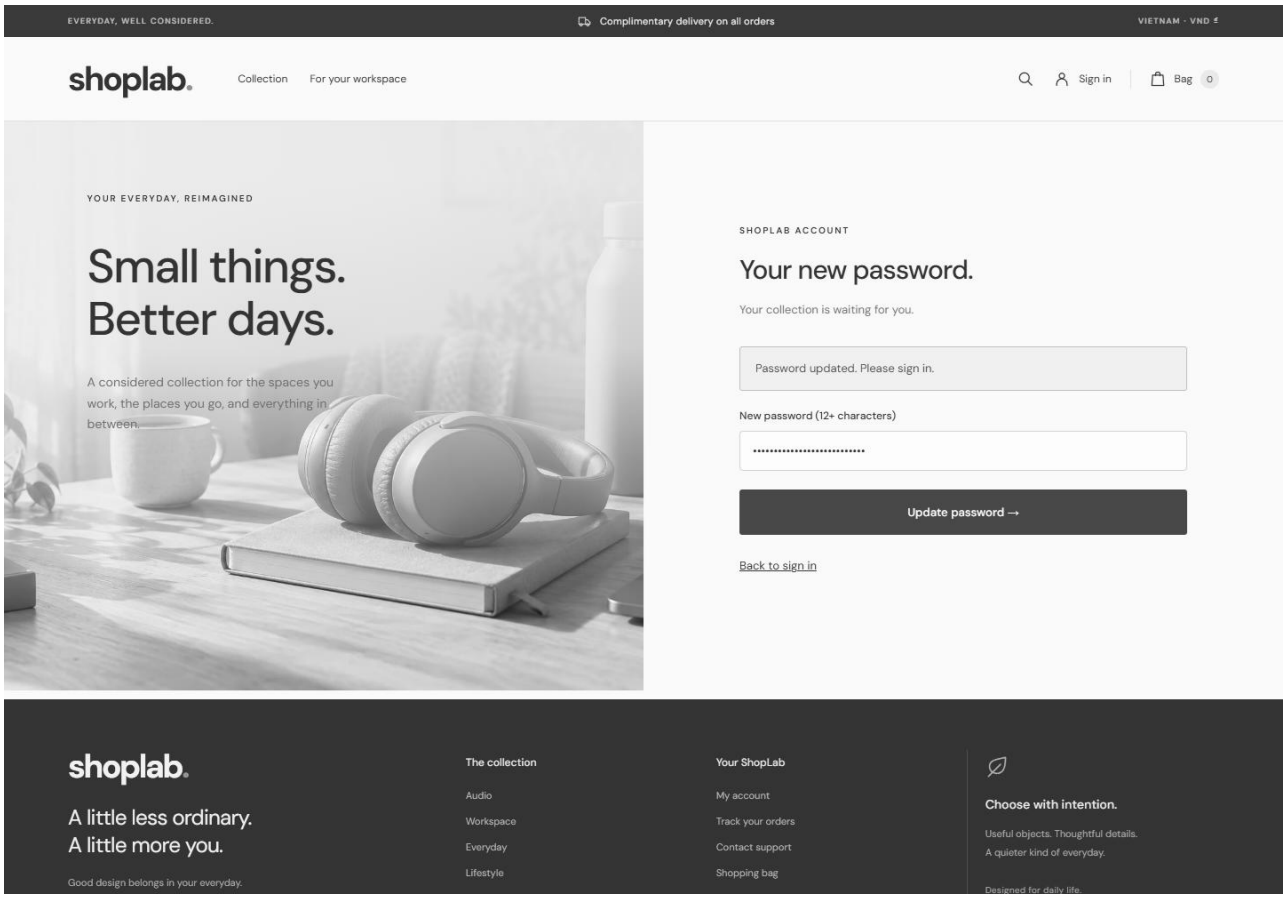
P2 21 Đổi mật khẩu thu hồi phiên và link reset

Thực hiện: PUT đổi mật khẩu C với currentPassword đúng. Gửi lại access/refresh của ba phiên trước đó; kiểm tra reset token pending trong DB; login bằng password cũ và mới.

Kết quả: Đổi mật khẩu 200; sáu request từ ba phiên cũ đều 401. Reset token pending có usedAt; bước này xác nhận trạng thái DB, không replay link qua HTTP. Password cũ 401, password mới 200.

Bằng chứng: S-P2-008, S-P2-009, S-P2-010, S-P2-011, S-P2-012, S-P2-013, S-P2-014, S-P2-015, S-P2-016.

Ảnh minh chứng reset mật khẩu



E-P2-01 • Reset password thành công trong browser riêng. Link reset lấy từ inbox synthetic; token không hiển thị trong ảnh.

B-P2-002 xác nhận reset 200. E-P2-053 là replay link bị 400; E-P2-054 đến 057 là access/refresh hai phiên cũ bị 401. Vì vậy kết luận thu hồi phiên dựa vào request kiểm chứng sau reset, không chỉ vào thông báo UI.

Hai ảnh còn lại trong thư mục screenshots: E-P2-03-authenticated-fixture.png ghi nhận profile A sau login; E-P2-04-after-logout.png ghi nhận quay về login. Token/password nguyên văn không nằm trong báo cáo hoặc evidence công khai.

Giới hạn khuyến nghị và hồ sơ bằng chứng

Những điểm chưa thể kết luận

Timing enumeration của forgot-password: một cặp 49/10 ms không đủ cơ sở thống kê. Cần lượt đo có đối chứng riêng nếu muốn kết luận; source có nhánh trả sớm khi email không tồn tại và gửi SMTP ở nhánh tồn tại.

Chưa đợi expiry tự nhiên của access token 30 phút, reset 30 phút hoặc refresh 7 ngày; expiry JWT được kiểm tra ở instance cô lập, expiry DB ở fixture live. Chưa thử session idle timeout, concurrency nhiều lần, password blocklist, MFA hoặc mọi dạng fixation. Endpoint đổi mật khẩu chưa có limiter riêng trong source; khả năng abuse cần đánh giá riêng, chưa gán thêm finding từ nhận xét này.

Hạn chế rate-limit đã được xác nhận trên cùng source với MemoryStore độc lập; không chứng minh cấu hình nhiều process hoặc production. Hành vi frontend HTTPS/cookie

Secure cũng chưa được đánh giá. Không đọc secret thực tế để tạo JWT tấn công; các JWT ký có kiểm soát dùng key riêng của instance cô lập.

Bộ evidence và cách tái lập

results.json và http.json lưu lượt chính; password-change-results.json lưu lượt bổ sung. CASE_LOG.md ghép 21 nhóm với từng bước, expected/actual, request ID và verdict. findings.json chứa một finding xác nhận. source-before.json/source-after.json định danh source; evidence-manifest.json giữ SHA-256 của từng file evidence.

Mã chạy kiểm thử là pentest/run-part2.cjs và pentest/run-part2-password-change.cjs. Cả hai từ chối ghi đè khi bằng chứng đã tồn tại. Mỗi lượt kiểm tra lại cần thư mục mới, dữ liệu thử nghiệm mới và kế hoạch kiểm soát quota xác thực. Backup nhạy cảm được lưu riêng trong .local, không đính kèm báo cáo.

Tài liệu đối chiếu

OWASP WSTG v4.2 Account Enumeration: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/03-Identity_Management_Testing/04-Testing_for_Account_Enumeration_and_Guessable_User_Account/

OWASP WSTG v4.2 Logout: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/06-Session_Management_Testing/06-Testing_for_Logout_Functionality/

OWASP Forgot Password Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html

MITRE CWE 204: https://cwe.mitre.org/data/definitions/204.html

Tài liệu WSTG được đối chiếu ngày 25/09/2026 và dùng để xây dựng tiêu chí kiểm thử.

PHẦN 3 Phân quyền và IDOR

Phần 3 hoàn tất trong phạm vi đã thực hiện. Chưa xác nhận lỗi vượt quyền mới: truy cập chéo tài khoản, quyền admin và quan hệ ticket–message–attachment được chặn theo ma trận trong các trường hợp đã thử.

Thông tin	Giá trị
Đợt và phiên bản	SL-PT-20260925 • Phần 3 • 1.0 • Internal
Người nhận / phương pháp	Chủ dự án ShopLab / kiểm thử gray-box
Thời gian thực thi	25/09/2026 17:26:59 – 25/09/2026 17:27:11 UTC+07
Target	http://localhost:5173 qua Vite proxy tới API đang chạy
Khối lượng	20 nhóm; 212 HTTP record từ client; 7 đối chiếu DB; 4 ảnh browser
Diễn giải browser	3 status API có request ID liên kết ảnh; không log toàn bộ traffic browser nền
Kết quả	20 nhóm đạt các tiêu chí đã thử; 0 finding mới được xác nhận
Actor	Anonymous, A USER, B USER, C ADMIN synthetic; B đổi role có kiểm soát
Công cụ	Node v24.19.0; Playwright 1.63.0; Chrome 153.0.8010.53
Cleanup	3 tài khoản và 5 tệp synthetic đã xóa; 18 bảng khớp bản ghi trước đợt

Điểm chính

A/B bị 403 ở 23 operation admin mỗi người. Owner đọc được order/ticket/file của mình; foreign request bị 404. Các phép thử ghi chéo có control DB cho những tài nguyên chọn lọc. Admin thay đổi role/active của B làm mất hiệu lực access token cũ.

Mã nguồn ứng dụng được giữ nguyên trong Phần 3. F-P2-001 vẫn Open và chưa được kiểm tra lại sau sửa.

Phạm vi tiền điều kiện và cách thực hiện

Dùng ma trận docs/authorization-matrix.md làm kỳ vọng. Mỗi đối chiếu IDOR dùng resource fixture tồn tại và control owner thành công; tránh kết luận từ một 404 đơn lẻ. Test gọi trực tiếp API bằng bearer đúng actor, không phụ thuộc việc frontend có hiện nút hay không.

Actor	ID và role ban đầu	Resource fixture chính
A	18 USER	Order 14; ticket 9; message 12; cart item 37
B	19 USER	Order 15; ticket 10; message 13; cart item 38
C	20 ADMIN	Admin thử nghiệm; có message riêng trong ticket A
Ẩn danh	Không bearer	Đối chứng 401 cho riêng tư và public image/review theo thiết kế

Tài khoản, quyền C và dữ liệu kinh doanh ban đầu được provision trực tiếp qua DB. Sau đó login và phép thử quyền đều chạy trên HTTP live. Provision không được coi là chứng minh lỗi tạo admin hoặc lỗi tạo order/ticket từ ngoài. Fixture order không phát sinh từ checkout: chỉ dùng kiểm tra quyền read/cancel/status.

Trước ghi dữ liệu, lưu snapshot nhất quán 18 model Prisma trong .local/pentest-backups/SL-PT-20260925. Backup có dữ liệu nhạy cảm, nằm trong thư mục Git ignore và không đưa vào báo cáo chia sẻ. Chưa kiểm tra restore; snapshot không bao gồm toàn bộ cấu hình cluster hoặc nội dung file upload có sẵn.

Ảnh upload là PNG 32×32 được tạo riêng cho kiểm thử. Sản phẩm thử nghiệm xuất hiện tạm trong catalogue và đã được dọn sau lượt chạy. Ảnh giao diện và bằng chứng HTTP được thu bằng trình duyệt và client kiểm thử riêng; tệp cá nhân được giữ nguyên.

Các ranh giới quan trọng

Admin được moderation delete review nhưng không edit review người khác. Admin được đọc ticket/download file của khách, nhưng upload chỉ vào message do admin viết. Chủ ticket được tải attachment của message admin trong ticket mình. Avatar/product image là public; TICKET asset phải dùng đường download được bảo vệ.

Ma trận kết quả quyền đã quan sát

Resource	Ẩn danh	User	Admin
Admin 23 operation	401 × 23	403 × 46 cho A/B	200/201 trên control chọn lọc
Profile và ownership field	401 read/update	Own 200; field cấm 400	Không dùng route admin để sửa profile
Order read và list	401	Own 200; foreign 404	User route 404; admin route 200
Order cancel và status	401 cancel	Own cancel 200; foreign 404	Admin status 200

Resource	Ẩn danh	User	Admin
Cart item PATCH DELETE	401	Own 200; foreign 404	Chưa thử cart của C
Review	Public GET 200; write 401	Own write 200; foreign 404	Foreign edit 404; moderation delete 200
Ticket read reply close	401 trên route đã thử	Own 200/201; foreign 404	Admin route được phép
Attachment upload	401	Sai owner/parent/author 404; own 201	Own message 201; message user 404
Attachment download	401	Owner ticket 200; foreign 404	200 cùng bytes với owner
Private TICKET qua assets	404	404	404
Public avatar/product image	200 GET fixture	Owner avatar giữ uploadedBy	Admin product upload 200
Role active changes	401 admin endpoint	403 admin endpoint	C được đổi B; stale token B 401

Mỗi ô chỉ tóm tắt tổ hợp đã thử; ô không được thử không được hiểu là PASS. AUTHORIZATION_MATRIX.md kèm mã nhóm, CASE_LOG.md kèm từng request/actor/status và request ID.

Ví dụ rõ nhất: order B tồn tại và B đọc 200, trong khi A đọc cùng ID nhận 404. Đây là control cần thiết để phân biệt quyền bị chặn với resource đơn giản không tồn tại.

Kết quả P3 01 đến P3 03

P3 01 Chuẩn bị actor và đối chứng phiên

Kỳ vọng: A/B là USER, C là ADMIN được cấp trước qua DB; login hợp lệ và me khớp actor.

Thực hiện: Tạo trước A/B USER và C ADMIN qua DB riêng fixture; login thật trên localhost; GET auth/me cho từng actor.

Kết quả: Health 200; login/me đều 200 và id/role đúng. Quyền ADMIN của C là quyền được cấp làm tiền điều kiện kiểm thử, không phải bằng chứng privilege escalation.

Bằng chứng: E-P3-001, E-P3-002, E-P3-003, E-P3-004, E-P3-005, E-P3-006, E-P3-007.

P3 02 Không đăng nhập trên API riêng tư

Kỳ vọng: Các route cá nhân và 23 operation admin từ chối 401 trước thao tác.

Thực hiện: Gửi không bearer vào 15 operation cá nhân và 23 operation admin, dùng JSON/multipart theo schema hợp lệ khi cần.

Kết quả: 38 request trả 401. Bao gồm profile, cart item, order read/cancel, ticket read/reply/close/upload, review edit/delete và các route admin. Các method ngoài danh sách kiểm thử chưa được đánh giá trong nhóm này.

Bằng chứng: E-P3-008 đến E-P3-045 (38 records).

P3 03 User gọi trực tiếp các operation admin

Kỳ vọng: A và B nhận 403 ở 23 operation admin, kể cả JSON và multipart hợp lệ; dữ liệu fixture không bị sửa.

Thực hiện: Lặp 23 operation admin với bearer A, rồi bearer B. Body chứa dữ liệu hợp lệ cho create/update; ảnh là PNG fixture 32×32.

Kết quả: 46 request đều 403. D-P3-001 đối chiếu product, coupon, order, ticket, user B, số message và FileAsset trước/sau trùng nhau. Không chỉ dựa vào UI ẩn menu admin. Image-import ở đây chỉ thử quyền, chưa thử fetch URL thành công.

Bằng chứng: E-P3-046 đến E-P3-091 (46 records); DB D-P3-001.

Kết quả P3 04 đến P3 06

P3 04 Đối chứng admin đọc hợp lệ

Kỳ vọng: C được đọc dashboard, danh sách và tài nguyên trên route admin; dữ liệu tài khoản có sẵn được lược bỏ khỏi evidence.

Thực hiện: Dùng C đọc dashboard, users/products/orders/coupons/tickets và detail user B/order A/ticket A qua admin API.

Kết quả: Chín request 200 làm control cho quyền admin. Các list response trong evidence giữ fixture và số item đã lược bỏ; nội dung account/order/ticket có sẵn không được đưa vào các list evidence.

Bằng chứng: E-P3-092, E-P3-093, E-P3-094, E-P3-095, E-P3-096, E-P3-097, E-P3-098, E-P3-099, E-P3-100.

P3 05 Profile theo identity server và mass assignment

Kỳ vọng: Query userId không đổi người dùng; body id/userId/role/active/passwordHash bị 400; cập nhật field cho phép chỉ tác động A.

Thực hiện: GET users/me với query userId trỏ sang tài khoản kia. PATCH lần lượt id, userId, role, active, passwordHash; sau đó PATCH firstName hợp lệ cho A.

Kết quả: Hai GET vẫn trả đúng người cầm bearer. Năm body chứa field không cho phép trả 400. A đổi firstName thành Pentest A, B không thay đổi (D-P3-002). Không phát hiện mass assignment trên các field đã thử.

Bằng chứng: E-P3-101, E-P3-102, E-P3-103, E-P3-104, E-P3-105, E-P3-106, E-P3-107, E-P3-108; DB D-P3-002.

P3 06 Order read và danh sách chéo A B

Kỳ vọng: Owner 200, tài khoản khác 404; admin phải dùng admin route. Query userId không mở rộng danh sách.

Thực hiện: A/B gọi list với userId người kia rồi detail đơn mình/đơn kia. C thử đọc đơn A trên cả user và admin route.

Kết quả: A đọc order 14, B đọc order 15 được 200; đọc chéo đều 404. Danh sách vẫn giới hạn userId theo bearer. C qua /orders/14 bị 404 nhưng /admin/orders/14 được 200, đúng ma trận quyền.

Bằng chứng: E-P3-109, E-P3-110, E-P3-111, E-P3-112, E-P3-113, E-P3-114, E-P3-115, E-P3-116.

Kết quả P3 07 đến P3 09

P3 07 Order cancel và update trạng thái có phân quyền

Kỳ vọng: B/C không hủy đơn A qua user route; A hủy đơn mình; C chuyển trạng thái riêng fixture khác qua admin route.

Thực hiện: B và C gọi cancel order A qua user route. Đọc DB kiểm tra trạng thái; A hủy chính đơn này. C chuyển một order fixture A khác qua admin status route.

Kết quả: Hai cancel trái owner trả 404, DB vẫn PENDING. Owner cancel 200 và DB thành CANCELLED. Admin status update trên fixture khác 200. Đây là kiểm thử quyền thao tác; không kết luận về toàn bộ logic chuyển trạng thái, hoàn tồn kho hoặc race của Phần 4.

Bằng chứng: E-P3-117, E-P3-118, E-P3-119, E-P3-120; DB D-P3-003.

P3 08 Cart item ownership

Kỳ vọng: A không PATCH/DELETE item B; B không PATCH item A; các owner thao tác thành công và cart list chỉ thuộc actor.

Thực hiện: Mỗi A/B gọi cart kèm userId người kia, rồi PATCH và DELETE item của bên kia; sau đó owner PATCH item riêng và B DELETE item mình.

Kết quả: Cart trả đúng userId từ bearer; bốn thao tác chéo 404. Item B vẫn quantity=1 trước positive control (D-P3-004). Ba thao tác owner trả 200. Chưa kiểm thử coupon abuse hay checkout ở nhóm này.

Bằng chứng: E-P3-121, E-P3-122, E-P3-123, E-P3-124, E-P3-125, E-P3-126, E-P3-127, E-P3-128, E-P3-129; DB D-P3-004.

P3 09 Review edit delete và moderation

Kỳ vọng: Review public được đọc; chỉ owner edit; admin không edit của người khác nhưng được delete để moderation.

Thực hiện: Đọc public reviews không đăng nhập. A edit/delete review B; C edit review B; B edit chính review; C delete để moderation; A edit/delete chính review.

Kết quả: Public read 200. Ba thao tác sửa/xóa sai quyền trả 404. Owner edit/delete và admin moderation delete trả 200. Việc review public hoặc admin được delete là hành vi được cho phép, không phải IDOR.

Bằng chứng: E-P3-130, E-P3-131, E-P3-132, E-P3-133, E-P3-134, E-P3-135, E-P3-136, E-P3-137.

Kết quả P3 10 đến P3 12

P3 10 Ticket list và read theo parent owner

Kỳ vọng: A/B chỉ thấy ticket mình; foreign 404; C qua user route không đọc A nhưng admin route được đọc.

Thực hiện: GET ticket list với userId đối phương; đọc detail own/foreign. C đọc ticket A ở user route rồi admin route.

Kết quả: A/B list chỉ có ticket mình; own detail 200 và foreign 404. C user route 404, admin route 200. Parent ticket owner được kiểm tra ở server; không chỉ kiểm tra link trên frontend.

Bằng chứng: E-P3-138, E-P3-139, E-P3-140, E-P3-141, E-P3-142, E-P3-143, E-P3-144, E-P3-145.

P3 11 Reply và close ticket chéo

Kỳ vọng: Foreign reply/close bị 404 không thêm message/đóng ticket; owner và admin reply qua đúng route được 201.

Thực hiện: A reply và close ticket B. So sánh toàn bộ ticket B kèm messages trước/sau. A reply ticket mình; C reply ticket A qua route admin.

Kết quả: Hai request chéo 404 và ticket/messages B không thay đổi (D-P3-005). Hai reply hợp lệ 201, authorId được gán lần lượt A và C theo bearer. Giữ ticket mở để kiểm tra attachment tiếp theo.

Bằng chứng: E-P3-146, E-P3-147, E-P3-148, E-P3-149; DB D-P3-005.

P3 12 Mass assignment ownership trong create

Kỳ vọng: Không nhận userId/authorId/ticketId/cartId thêm vào body cho ticket, message, review, cart và checkout.

Thực hiện: Thêm userId vào create ticket/review/order, authorId và ticketId vào reply, cartId vào add cart item. Checkout request mang Idempotency-Key UUID hợp lệ.

Kết quả: Năm payload đều bị 400 validation. Kết quả xác nhận các field ownership được thử không được chấp nhận; không thay thế kiểm thử logic checkout hoặc idempotency.

Bằng chứng: E-P3-150, E-P3-151, E-P3-152, E-P3-153, E-P3-154.

Kết quả P3 13 đến P3 15

P3 13 Attachment parent child và message author

Kỳ vọng: Không thể trộn ticket/message, ghi vào message người khác; A và admin C chỉ upload vào message chính mình qua route phù hợp.

Thực hiện: Trộn ticket A với message B và ngược lại; B upload vào A; A upload vào message admin trong ticket mình; C upload vào message A qua admin route. Sau đó A/B/C upload PNG vào message do mình viết qua đúng route.

Kết quả: Năm request sai parent/author trả 404; số FileAsset không tăng (D-P3-006). Ba positive upload trả 201. Đặc biệt C không được gắn file vào message A nhưng được gắn vào message C trong ticket A. Không kiểm thử parser, malware hoặc loại file khác trong phần này.

Bằng chứng: E-P3-155, E-P3-156, E-P3-157, E-P3-158, E-P3-159, E-P3-160, E-P3-161, E-P3-162; DB D-P3-006.

P3 14 Attachment download và public asset isolation

Kỳ vọng: Owner ticket/admin tải được cùng bytes; anonymous 401, foreign 404; private file không đọc qua /assets.

Thực hiện: Download attachment A với anonymous/A/B/C. A download attachment do C viết trong ticket A và thử attachment B. Gọi /assets bằng assetId private dưới bốn actor.

Kết quả: Anonymous download 401, A/C 200 cùng hash nội dung, B 404. A được tải file admin trong ticket A vì quyền theo parent ticket. Attachment B: A 404, B 200. Bốn lần dùng public /assets để đọc private TICKET asset đều 404.

Bằng chứng: E-P3-163 đến E-P3-173 (11 records).

P3 15 Avatar upload tự gán owner và ảnh public

Kỳ vọng: Multipart userId B không đổi uploadedBy của A; avatar theo thiết kế public được đọc anonymous.

Thực hiện: A upload avatar hợp lệ nhưng thêm field multipart userId=B; kiểm tra FileAsset trong DB; đọc ảnh không đăng nhập.

Kết quả: Upload 200, uploadedBy vẫn A và kind AVATAR (D-P3-007). Anonymous GET ảnh 200 đúng thiết kế public avatar. Chưa kiểm thử việc ghi đè avatar người khác bằng mọi biến thể input.

Bằng chứng: E-P3-174, E-P3-175; DB D-P3-007.

Kết quả P3 16 đến P3 18

P3 16 Spoof identity header và URL không bypass admin

Kỳ vọng: Headers role/user/id hoặc method override không thay bearer identity; URL encoded admin vẫn bị chặn.

Thực hiện: Thêm X-User-Id/X-Role/X-Admin khi A đọc order B hoặc admin user; gọi admin/%75sers; gửi POST kèm X-HTTP-Method-Override: PATCH.

Kết quả: Order B vẫn 404; ba request admin đều 403. Những header/biến thể URL này không thay quyền bearer trong môi trường Vite/Express đang chạy. Chưa kiểm tra các proxy hoặc rewrite rule production.

Bằng chứng: E-P3-176, E-P3-177, E-P3-178, E-P3-179.

P3 17 Unknown và foreign resource cùng lỗi

Kỳ vọng: Foreign và ID không tồn tại trả cùng status/error cho orders, tickets, cart item, attachments.

Thực hiện: Kiểm tra ID 2147483000 không tồn tại trong DB. Ghép cặp request vào resource foreign thật với resource không tồn tại cho order, ticket, cart item và attachment.

Kết quả: Bốn cặp đều trả 404 và error object giống nhau. So sánh không gồm requestId, thời gian hay toàn bộ headers. Không đủ để kết luận không có timing side channel.

Bằng chứng: E-P3-180, E-P3-181, E-P3-182, E-P3-183, E-P3-184, E-P3-185, E-P3-186, E-P3-187.

P3 18 Đổi role và disable thu hồi phiên

Kỳ vọng: Admin C chỉ đổi B synthetic; token trước promotion/demotion/disable hết hiệu lực; quyền mới chỉ dùng với phiên mới. Quyền ADMIN của C được giữ nguyên.

Thực hiện: C thử tự hạ role, rồi nâng B thành ADMIN, hạ về USER, disable và enable B. Sau mỗi đổi quyền, thử token cũ và login mới.

Kết quả: Self-change trả 400 và C giữ ADMIN. Token B trước promotion/demotion/disable bị 401. Phiên mới B ADMIN đọc dashboard 200; phiên mới B USER bị 403. Enable lại rồi login/me 200. Chỉ tác động B synthetic; chưa thử xóa/hạ admin cuối cùng vì không thay quyền admin thật.

Bằng chứng: E-P3-188 đến E-P3-201 (14 records).

Kết quả P3 19 đến P3 20

P3 19 Minh chứng browser đối chiếu owner foreign admin

Kỳ vọng: A đọc được order A nhưng order B hiện Not found; B đọc được chính order B; UI chặn A vào admin.

Thực hiện: Dùng hai browser context riêng đăng nhập A/B. Chụp A xem order A, A xem order B, B xem order B và A mở /admin.

Kết quả: Browser: A own order 14 → 200, A foreign order 15 → 404, B own order 15 → 200. A mở /admin bị chuyển về /. Ba status API có request ID trong screenshot metadata; browser traffic nền không được đếm trong 212 HTTP record riêng. UI redirect chỉ là bằng chứng bổ sung.

Bằng chứng: Screenshot metadata trong results.json.

P3 20 Admin mutation controls và close ticket hợp lệ

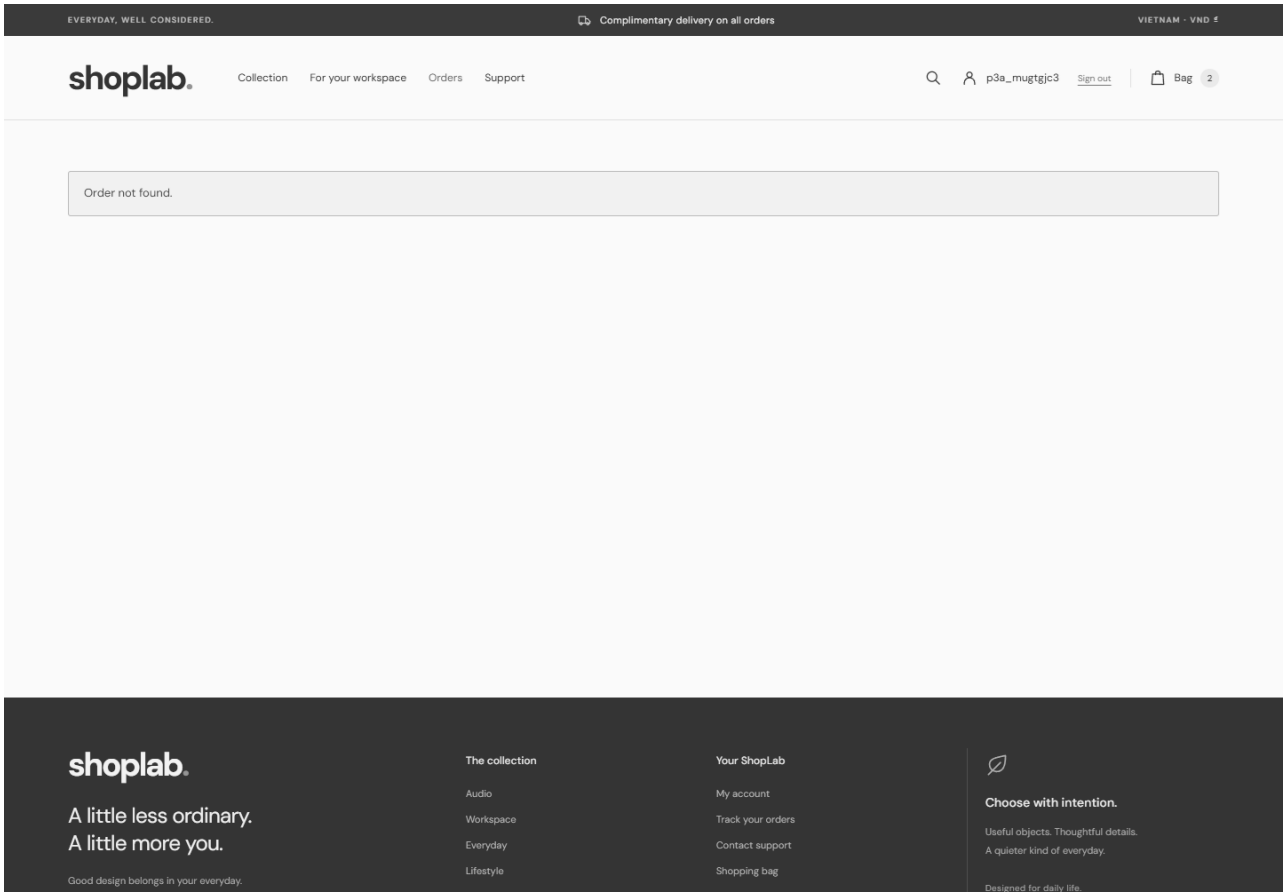
Kỳ vọng: C tạo/sửa/archive product và coupon synthetic; owner/admin đóng ticket đúng route. Không thử SSRF hay parser file.

Thực hiện: C tạo/sửa/archive một product và coupon synthetic, tạo ticket admin, đóng ticket B; A đóng ticket A. C upload product image fixture rồi đọc ảnh public.

Kết quả: 11 request đều trả status mong đợi 200/201. Các positive control này xác nhận một số admin/owner action thực sự hoạt động. Không fetch URL import, không fuzz upload và không đánh giá quy tắc giá/coupon ở đây.

Bằng chứng: E-P3-202 đến E-P3-212 (11 records).

Minh chứng A không được đọc order B

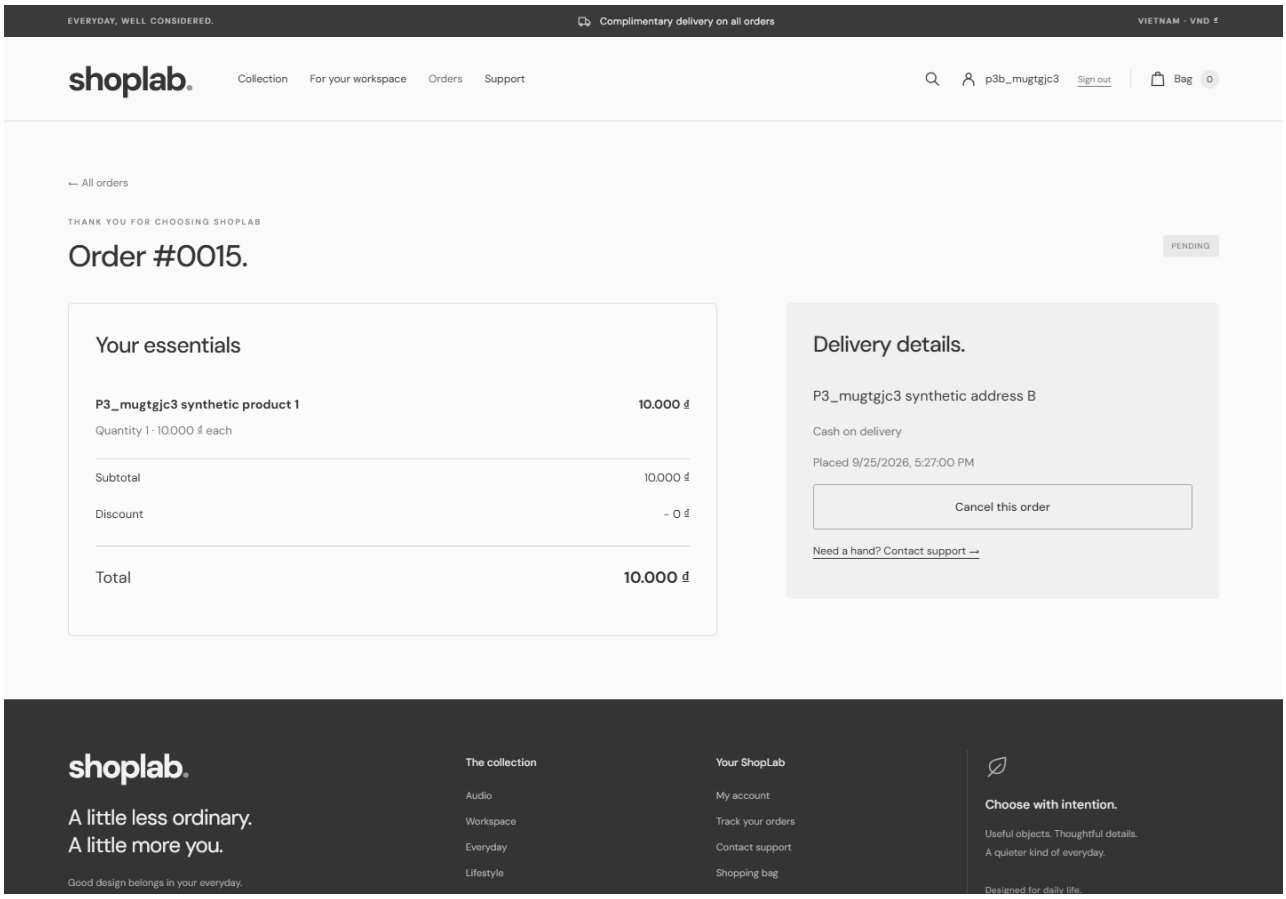


E-P3-02 • Actor A đăng nhập hợp lệ, mở /orders/15. API trả 404 và UI chỉ hiện Order not found.

Request ID: e98771b9-b518-45f0-a9a7-322438eccdd5. Header vẫn hiện username của A, chứng minh browser đã đăng nhập. Không có chi tiết địa chỉ hay hàng hóa của B trong trang lỗi.

Control owner cho đúng order này nằm ở trang tiếp theo. HTTP client cũng có đối chứng riêng ở P3-06 và P3-17; ảnh không phải bằng chứng duy nhất. Sau cleanup, order fixture đã xóa nên muốn tái lập phải tạo cặp order A/B mới.

Minh chứng owner B đọc được cùng order



E-P3-04 • Actor B mở /orders/15, API trả 200 và hiển thị thông tin fixture B.

Request ID: 2771d461-89ff-4535-827f-865ece4b2726. Chỉ thay actor từ A sang B, resource ID giữ nguyên. Địa chỉ và sản phẩm trong ảnh là dữ liệu synthetic được tạo cho đợt này.

Hai ảnh bổ sung: E-P3-01-owner-A.png cho thấy A đọc order mình thành công; E-P3-03-admin-guard.png cho thấy A bị chuyển từ /admin về /. Việc bảo vệ admin được kết luận chủ yếu từ 46 HTTP denial 403 trong P3-03, không dựa riêng vào frontend redirect.

Bảo toàn dữ liệu và giới hạn kiểm thử

Kết quả bảo toàn dữ liệu

Đã dọn user fixture IDs 18, 19, 20 cùng session, refresh/reset token, cart/item, order/item, ticket/message/attachment, review, product, coupon, audit thuộc fixture. Đã xóa đúng 5 file PNG theo tên storage trong thư mục .local/uploads sau khi kiểm tra đường dẫn nằm trong workspace.

Đối chiếu toàn bộ bản ghi của 18 model: không có original row bị thay đổi/mất và không có new row còn sót trong thời điểm kiểm tra. Đây là so sánh dữ liệu các bảng, không phải rollback database; sequence ID đã tăng và log runtime vẫn có các request của đợt test. Snapshot source trước/sau trùng nhau, không chứng minh process đang chạy được build từ một commit đã đóng băng.

Giới hạn cần giữ trong kết luận

Chưa thử mọi HTTP method, mọi biến thể ID, toàn bộ pagination/state hoặc race với thay đổi quyền. Chưa thử last-admin removal để tránh tác động admin có sẵn. URL image-import chỉ có negative authorization checks, chưa positive fetch hoặc SSRF; nội dung file/parser thuộc Phần 6. Logic tiền, coupon, tồn kho, idempotency và concurrent checkout thuộc Phần 4.

Các đối chiếu lỗi foreign/unknown chỉ so status và error object, không xác nhận chống timing enumeration. Không đánh giá Nginx/TLS hoặc deployment nhiều replica. Browser traffic nền không được lưu toàn bộ; 212 là số bản ghi HTTP client đã capture, không phải tổng mọi request mạng trong phiên.

Hồ sơ bàn giao

results.json: nhóm kiểm tra, checks, fixture, ảnh và cleanup. http.json: 212 request/response đã che token/password. db-checks.json: 7 cặp dữ liệu kiểm chứng. CASE_LOG.md: expected, thực hiện, actual và request ID từng bước. AUTHORIZATION_MATRIX.md: ma trận đối chiếu. evidence-manifest.json: SHA-256 để kiểm tra các file bằng chứng.

Mã tái lập: pentest/run-part3.cjs. Script từ chối ghi đè khi results.json đã có. Đổi run folder và tạo fixture mới trước lần retest; không dùng lại IDs đã dọn. Backup private trong .local không được đưa vào gói báo cáo. Finding F-P2-001 vẫn Open; Phần 3 không retest finding đó.

Tài liệu đối chiếu

OWASP WSTG v4.2 IDOR: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References/

OWASP WSTG v4.2 Authorization Bypass: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/05-Authorization_Testing/02-Testing_for_Bypassing_Authorization_Schema/

Tài liệu về IDOR và kiểm soát phân quyền được đối chiếu ngày 25/09/2026.

PHẦN 4 Logic nghiệp vụ

Phần 4 hoàn tất trong phạm vi các phép thử đã thực hiện. Xác nhận một lỗi mức Low: checkout trả 500 khi tổng giỏ vượt giới hạn lưu trữ tiền. Lỗi cần danh mục có sản phẩm giá rất cao do admin cấu hình; chưa thấy mất tiền, đơn ghi dở hoặc ảnh hưởng toàn hệ thống.

Thông tin	Kết quả
Đợt / phiên bản	SL-PT-20260925 / Phần 4 / 1.0 / Internal
Thời gian	26/09/2026 01:25:08 – 26/09/2026 01:25:17 UTC+07
Mục tiêu	http://localhost:5173; API qua Vite proxy
Khối lượng	19 nhóm: 17 PASS, 2 REVIEW cùng một finding
Bằng chứng	152 bản ghi HTTP client; 1 checkout browser riêng; 24 đối chiếu DB; 3 ảnh
Công cụ	Node v24.19.0; Playwright 1.63.0; Chrome 153.0.8010.53
Trạng thái	F-P4-001 Low, Open; chưa sửa hoặc retest
Bảo toàn dữ liệu	Dọn 3 user fixture và dữ liệu liên quan; 18 bảng khớp bản ghi trước test

Kết luận chính

Các lượt checkout/cancel cạnh tranh đã chạy chưa cho thấy trùng đơn, vượt tồn kho, vượt quota coupon hoặc hoàn tồn kho hai lần. PASS chỉ áp dụng tiêu chí và số lượt đã ghi, không chứng nhận mọi lịch thực thi đồng thời đều an toàn.

F-P2-001 vẫn Open và chưa được kiểm tra lại. Mã nguồn ứng dụng được giữ nguyên trong Phần 4.

Phạm vi và phương pháp

Đây là gray-box tự đánh giá ứng dụng thuộc chủ dự án. Kiểm thử giỏ hàng, tính giá, coupon, checkout, chuyển trạng thái, hủy, idempotency và race. Không thử DoS, hệ thống ngoài localhost hoặc payment gateway thật.

Tạo riêng hai user A/B và admin C qua DB, sau đó login thật bằng HTTP. Dữ liệu product/coupon và các lần reset stock, active, thời gian coupon dùng fixture cô lập, ghi trong fixtureResets. Hai product giá lớn dùng cho finding được tạo qua admin API để xác nhận giá được schema thực sự chấp nhận. Tất cả order của phần này được tạo bằng checkout HTTP.

Mỗi tình huống ghi expected, status/body thực tế, request ID và DB trước/sau nếu có. Concurrency giới hạn 2–4 request; last-unit, last-coupon, cancel và cancel-vs-confirm lặp ba

lượt. Đây là kiểm thử chức năng cạnh tranh có giới hạn, không phải benchmark hoặc chứng minh tính đúng với mọi interleaving.

Ảnh giao diện được chụp bằng trình duyệt kiểm thử tự động. Bộ bằng chứng có 152 bản ghi HTTP client; một POST checkout trên giao diện được lưu riêng trong browserCheckout. Traffic nền của trình duyệt không được ghi toàn bộ.

Backup trước test nằm trong .local/pentest-backups, chứa dữ liệu riêng và không đưa vào bộ báo cáo chia sẻ. Snapshot 18 model không thay cho backup toàn cluster; chưa thử restore. Evidence HTTP đã che token/password; chỉ dùng tài khoản và địa chỉ synthetic trong ảnh.

Cách đọc hồ sơ

CASE_LOG.md chứa 19 nhóm, toàn bộ checks và danh sách request ID. http.json chứa request/response; db-checks.json chứa 24 đối chiếu. results.json chứa metadata, fixture resets, browserCheckout, cleanup và source hashes. evidence-manifest.json lưu SHA-256 của các file evidence.

F P4 001 Checkout vượt giới hạn tiền

Thuộc tính	Giá trị
Mức / trạng thái	Low (lỗi xử lý biên nghiệp vụ) / Confirmed, Open
Endpoint	POST /api/orders
Tiền điều kiện	Admin cấu hình hai product giá 999999999999, đủ stock; user đăng nhập
Evidence	P4-18/19; E-P4-144–152; D-P4-023/024; ảnh E-P4-01/02
Tác động đã thấy	Giỏ tổng lớn không checkout được, API/UI trả 500; không có ghi DB một phần

Các bước tái hiện

1. Admin tạo hai sản phẩm active, mỗi sản phẩm giá 999999999999 và stock 200. API chấp nhận với 201. 2. User thêm quantity 50 cho mỗi sản phẩm: tổng 99999999999900; checkout với shippingAddress hợp lệ và Idempotency-Key mới thành công (order 40).

3. User thêm quantity 99 mỗi sản phẩm vào giỏ mới: cart trả tổng 197999999999802. 4. POST /api/orders với địa chỉ hợp lệ và key mới: HTTP 500, error.code INTERNAL_ERROR, message An unexpected error occurred. 5. Thử cùng giỏ trên UI: cùng lỗi 500. Đối chiếu DB ở cả hai lần giữ nguyên stock/cart/order/redemption.

Nguyên nhân và phạm vi kết luận

Source cho phép giá tối đa 12 chữ số và quantity mỗi item tới 99. Order subtotal/discount/total dùng Decimal(14,0) trong backend/prisma/schema.prisma; số lớn nhất dương tương ứng là 99999999999999. Tổng hai dòng vượt giới hạn này. Liên hệ

nguyên nhân được suy ra từ source, trị số biên và control thành công; không trình bày đây là stack trace trực tiếp từ server.

Không có dấu hiệu số bị wrap, giá âm, mua hàng miễn phí hoặc DoS toàn dịch vụ. User không được tự gửi giá vào cart/checkout. Vì cần giá admin cấu hình rất cao và rollback vẫn đúng, đánh giá Low; không gán CVSS giả định tác động chưa kiểm chứng.

Khắc phục và điều kiện retest

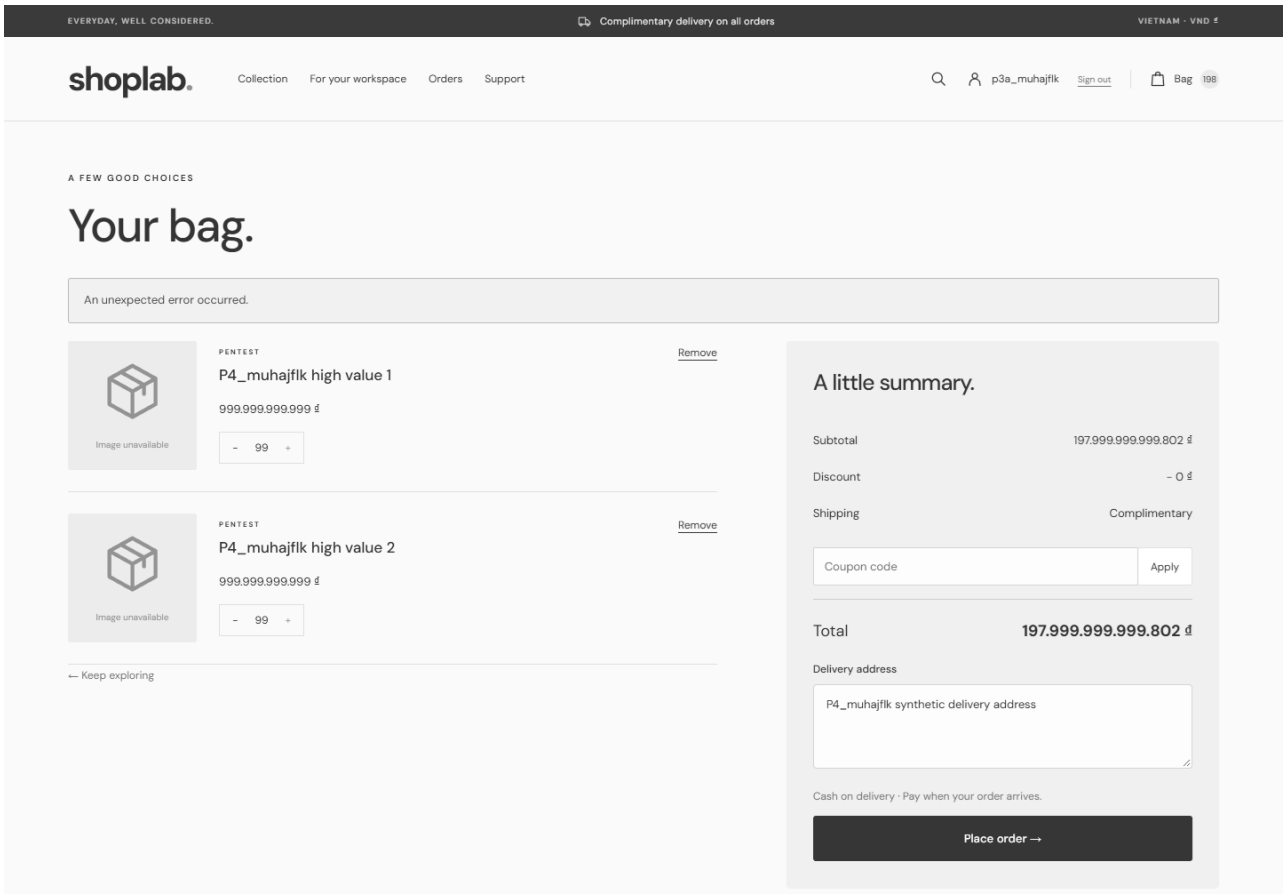
Đặt một giới hạn tổng đơn thống nhất theo nghiệp vụ, kiểm tra bằng phép tính chính xác ở server trước khi ghi order hoặc trừ stock. Trả 4xx với mã có ý nghĩa, ví dụ ORDER_TOTAL_LIMIT. Validation trên giao diện chỉ bổ sung trải nghiệm, không thay thế kiểm tra server.

Nếu nghiệp vụ thực sự cần tổng tiền lớn hơn, mở rộng nhất quán các cột tiền và migration tương ứng; đối chiếu giới hạn ở API, schema và UI. Giữ transaction atomic và không chuyển mọi lỗi 500 thành thành công.

Retest sau bản sửa chưa thực hiện

Kiểm tra tổng đúng giới hạn và lớn hơn một đơn vị; thử cả API và UI; trường hợp bị từ chối phải trả lỗi nghiệp vụ và không đổi stock/cart/order/redemption. Kiểm tra lại đơn bình thường, coupon 100%, retry cùng key và checkout cạnh tranh. Chỉ đổi trạng thái Fixed khi có bằng chứng sau sửa.

Minh chứng lỗi trên giao diện



E-P4-02 • Giỏ tổng 197999999999802; checkout báo lỗi chung. Ảnh chụp thực tế, dữ liệu synthetic.

Request ID UI: 84bb5f0a-cccc-474e-9502-4c681233a45c. Request/body/status được lưu riêng trong results.json; không có header Idempotency-Key trong metadata UI đã lưu.

Kết quả P4-01 đến P4-03

P4-01 Baseline và actor riêng

Kỳ vọng: Health và login A/B/C hoạt động; fixture tách khỏi dữ liệu có sẵn.

Thực hiện và quan sát: Health và ba login A/B/C trả 200. Hai USER và một ADMIN được cấp sẵn qua DB chỉ để tạo tiền điều kiện, không phải bằng chứng leo thang quyền.

Bằng chứng: E-P4-001, E-P4-002, E-P4-003, E-P4-004; DB: không có cặp riêng. Kết quả nhóm: PASS.

P4-02 Biên quantity và giá do client gửi

Kỳ vọng: Quantity ngoài integer 1..99 và field giá thêm bị 400; cộng quá 99 bị 409 không đổi cart.

Thực hiện và quan sát: POST quantity -1, 0, 1.5, 100, chuỗi "1", 1000000000 và field giá thêm bị 400. Quantity 99 được chấp nhận; cộng thêm vượt 99 bị 409. PATCH quantity không hợp lệ bị 400; cart không đổi trong đối chiếu DB.

Bằng chứng: E-P4-005 đến E-P4-018; DB: D-P4-001. Kết quả nhóm: PASS.

P4-03 Coupon validation normalization thay thế và bỏ mã

Kỳ vọng: Unknown/inactive/expired/future bị 400; mã được trim uppercase; một coupon thay thế coupon khác, không cộng dồn.

Thực hiện và quan sát: Coupon inactive, hết hạn, chưa tới thời gian và không tồn tại bị 400. Trim và chữ thường được chuẩn hóa. Subtotal 60007, coupon 25% giảm 15001, total 45006; thay bằng 10% giảm 6000; bỏ mã trả discount 0.

Bằng chứng: E-P4-019 đến E-P4-027; DB: không có cặp riêng. Kết quả nhóm: PASS.

Kết quả P4-04 đến P4-06

P4-04 Checkout dùng tổng tiền server và snapshot order

Kỳ vọng: Client total/discount/price/status bị từ chối; valid checkout lưu đúng tổng, trừ stock, xóa cart, tạo một redemption.

Thực hiện và quan sát: Chèn total, discount, price hoặc status vào checkout bị 400. Checkout hợp lệ tạo order 17: subtotal 60007, discount 15001, total 45006. Stock giảm đúng 3 và 2; cart được xóa; một redemption được ghi.

Bằng chứng: E-P4-028, E-P4-029, E-P4-030, E-P4-031, E-P4-032, E-P4-033; DB: D-P4-002. Kết quả nhóm: PASS.

P4-05 Stock và active đổi sau add cùng rollback nhiều item

Kỳ vọng: Checkout kiểm tra lại stock/active; lỗi item cuối không để trừ stock item trước hoặc tạo order.

Thực hiện và quan sát: Sau add cart, đặt stock một item về 0 trong fixture: checkout 409 và toàn bộ trạng thái kinh doanh được đối chiếu giữ nguyên. Khôi phục stock rồi tắt active cũng trả 409, không ghi đơn dở.

Bằng chứng: E-P4-034, E-P4-035, E-P4-036, E-P4-037; DB: D-P4-003, D-P4-004. Kết quả nhóm: PASS.

P4-06 Giá thay đổi trước và sau checkout

Kỳ vọng: Order lấy giá hiện tại từ server tại checkout; đổi giá sau mua không sửa order đã lưu.

Thực hiện và quan sát: Add 2 sản phẩm giá 10001; admin đổi giá 20001 trước checkout thì order tính 40002. Admin đổi tiếp 30001 sau checkout không làm thay đổi unitPrice và tổng đã lưu trong order.

Bằng chứng: E-P4-038, E-P4-039, E-P4-040, E-P4-041, E-P4-042; DB: không có cặp riêng. Kết quả nhóm: PASS.

Kết quả P4-07 đến P4-09

P4-07 Coupon bị tắt hoặc hết hạn sau khi áp dụng

Kỳ vọng: Checkout kiểm tra lại coupon; từ chối không đổi stock/cart/order/redemption.

Thực hiện và quan sát: Coupon đã áp dụng bị tắt hoặc hết hạn trước checkout trả 400. Hai cặp snapshot xác nhận stock, order và cart không bị cập nhật một phần.

Bằng chứng: E-P4-043, E-P4-044, E-P4-045, E-P4-046; DB: D-P4-005, D-P4-006. Kết quả nhóm: PASS.

P4-08 Idempotency sequential và scope theo user

Kỳ vọng: Cùng key/address trả cùng order; đổi address bị 409; retry key cũ không tiêu thụ cart mới; B dùng cùng key có order riêng.

Thực hiện và quan sát: Cùng key và địa chỉ trả lại cùng order; đổi địa chỉ trả 409 KEY_REUSED. Tạo cart mới rồi gửi key cũ vẫn trả order cũ và giữ cart mới. User B dùng cùng key tạo order riêng. Tổng cộng hai order, stock giảm ba đơn vị.

Bằng chứng: E-P4-047 đến E-P4-054; DB: D-P4-007. Kết quả nhóm: PASS.

P4-09 Bốn checkout đồng thời cùng key

Kỳ vọng: Một order và một lần trừ stock; các response thành công trỏ cùng ID.

Thực hiện và quan sát: Bốn checkout cùng key đồng thời đều trả 201 cùng một order ID. Chỉ có một order; stock từ 20 xuống 18. Một lượt thử với bốn request, không phải stress test.

Bằng chứng: E-P4-055, E-P4-056, E-P4-057, E-P4-058, E-P4-059; DB: D-P4-008. Kết quả nhóm: PASS.

Kết quả P4-10 đến P4-12

P4-10 Hai checkout khác key trên cùng cart

Kỳ vọng: Chỉ một request tạo order; request còn lại bị từ chối, không double debit.

Thực hiện và quan sát: Hai checkout khác key trên cùng cart: một trả 201, một trả 400 EMPTY_CART. Chỉ một order được tạo và stock từ 20 xuống 18.

Bằng chứng: E-P4-060, E-P4-061, E-P4-062; DB: D-P4-009. Kết quả nhóm: PASS.

P4-11 Hai user tranh sản phẩm còn một đơn vị

Kỳ vọng: Ba vòng độc lập, mỗi vòng hai request; chỉ một order, stock=0 không âm.

Thực hiện và quan sát: Hai user tranh một đơn vị cuối, lặp ba lượt với fixture reset: mỗi lượt một 201, một 409; stock về 0 và chỉ một order mới. Chưa quan sát oversell trong các lượt này.

Bằng chứng: E-P4-063 đến E-P4-074; DB: D-P4-010, D-P4-011, D-P4-012. Kết quả nhóm: PASS.

P4-12 Hai user tranh coupon còn một lượt toàn cục

Kỳ vọng: Ba vòng: cả hai đã apply được, nhưng chỉ một redemption và order tại checkout.

Thực hiện và quan sát: Hai user đều áp dụng được coupon còn một lượt; checkout cạnh tranh ba lượt: mỗi lượt một 201, một 400 COUPON_LIMIT. Mỗi lượt chỉ một redemption và một order; stock từ 10 xuống 9.

Bằng chứng: E-P4-075 đến E-P4-092; DB: D-P4-013, D-P4-014, D-P4-015. Kết quả nhóm: PASS.

Kết quả P4-13 đến P4-15

P4-13 Coupon giới hạn mỗi user và hành vi sau hủy

Kỳ vọng: A dùng một lần không apply lại; B vẫn được dùng. Ghi nhận chính sách không hoàn lượt sau cancel, không mặc định là lỗi.

Thực hiện và quan sát: User A dùng coupon giới hạn một lần: không áp dụng lại được; hủy order vẫn không được dùng lại. B vẫn dùng được một lần. Đây là chính sách quota không hoàn khi hủy, chưa được coi là lỗi nếu chưa có yêu cầu nghiệp vụ ngược lại.

Bằng chứng: E-P4-093 đến E-P4-102; DB: D-P4-016. Kết quả nhóm: PASS.

P4-14 Cancel đồng thời không hoàn stock hai lần

Kỳ vọng: Ba vòng, hai cancel cùng order: một 200 và một 409; tồn kho quay đúng ban đầu.

Thực hiện và quan sát: Hai cancel đồng thời, lặp ba lượt: mỗi lượt một 200, một 409. Stock trở về 10 đúng một lần; không thấy hoàn tồn kho hai lần.

Bằng chứng: E-P4-103 đến E-P4-114; DB: D-P4-017, D-P4-018, D-P4-019. Kết quả nhóm: PASS.

P4-15 Không bỏ bước trạng thái hoặc hủy order đã hoàn tất

Kỳ vọng: PENDING không nhảy SHIPPED/COMPLETED; CONFIRMED không cancel theo policy; đi đúng chuỗi và không rollback trạng thái.

Thực hiện và quan sát: Bỏ bước trạng thái bị 409. PENDING → CONFIRMED → SHIPPED → COMPLETED được 200. Hủy sau CONFIRMED bị 409 cho owner và admin; quay trạng thái hoặc hủy COMPLETED bị 409. Stock giữ ở 9.

Bằng chứng: E-P4-115 đến E-P4-125; DB: không có cặp riêng. Kết quả nhóm: PASS.

Kết quả P4-16 đến P4-18

P4-16 Cancel và confirm cạnh tranh cùng order

Kỳ vọng: Ba vòng: một thao tác thắng, trạng thái cuối tương ứng đúng stock, không trạng thái lai.

Thực hiện và quan sát: Cancel và admin confirm cạnh tranh, ba lượt: mỗi lượt một 200 và một 409. Trạng thái cuối CANCELLED đi với stock 10, hoặc CONFIRMED đi với stock 8; chưa thấy cặp trạng thái/tồn kho mâu thuẫn.

Bằng chứng: E-P4-126 đến E-P4-137; DB: D-P4-020, D-P4-021, D-P4-022. Kết quả nhóm: PASS.

P4-17 Discount 100 phần trăm và làm tròn VND

Kỳ vọng: Coupon được cấu hình 100% có total 0 hợp lệ; 33% của 101 làm tròn xuống discount 33, total 68.

Thực hiện và quan sát: Giá 101 với giảm 33% cho discount 33 và total 68, làm tròn xuống theo đơn vị VND. Coupon 100% cho total 0 là hành vi được hỗ trợ; không phải bằng chứng tự ý mua miễn phí.

Bằng chứng: E-P4-138, E-P4-139, E-P4-140, E-P4-141, E-P4-142, E-P4-143; DB: không có cặp riêng. Kết quả nhóm: PASS.

P4-18 Biên tổng tiền Decimal và rollback

Kỳ vọng: Giá/quantity hợp lệ nhưng tổng vượt sức chứa DB phải được xử lý có kiểm soát, không HTTP 500 và không ghi dở.

Thực hiện và quan sát: Hai product giá 999999999999 được tạo qua admin API (201). Quantity 50 mỗi product cho tổng 99999999999900 và checkout thành công. Quantity 99 mỗi product cho tổng 197999999999802; cart chấp nhận nhưng checkout 500 INTERNAL_ERROR. Snapshot D-P4-023 giữ nguyên: rollback đầy đủ.

Bằng chứng: E-P4-144 đến E-P4-152; DB: D-P4-023. Kết quả nhóm: REVIEW.

Kết quả P4-19 đến P4-19

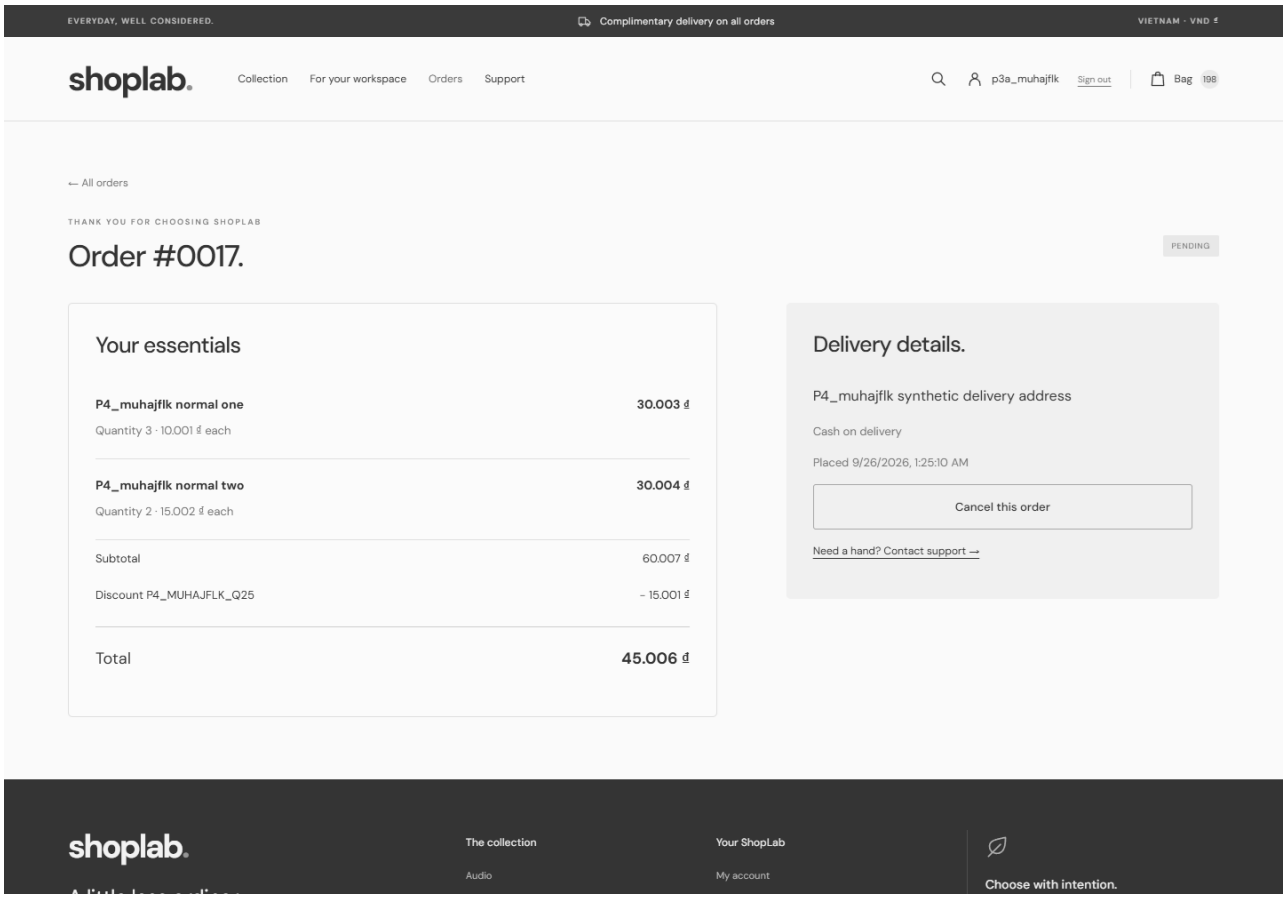
P4-19 Minh chứng browser lỗi biên và order bình thường

Kỳ vọng: Tái hiện UI biên tiền một lần; ghi response thật và xác nhận dữ liệu không đổi, đối chiếu order bình thường.

Thực hiện và quan sát: Browser mở cart tổng lớn và checkout cũng trả 500, hiện An unexpected error occurred. D-P4-024 giữ nguyên. Browser sau đó hiển thị order bình thường số 17 với total 45006. Hai nhóm REVIEW cùng chỉ về F-P4-001, không phải hai finding.

Bằng chứng: browserCheckout trong results.json và ảnh E-P4-01/02/03; DB: D-P4-024. Kết quả nhóm: REVIEW.

Minh chứng đơn hợp lệ và cleanup



E-P4-03 • Order 17: subtotal 60007, giảm 15001, total 45006; trạng thái Pending.

Ảnh E-P4-01-high-total-cart.png lưu riêng cho bước trước checkout lỗi. Cả ba ảnh gốc nằm trong thư mục screenshots của Phần 4.

Đã xóa user synthetic 21, 22, 23 và dữ liệu liên quan. Không có file upload tạo trong phần này. Đối chiếu 18 bảng: không có bản ghi gốc mất/thay đổi hoặc bản ghi mới còn sót tại thời điểm kết thúc. Sequence ID đã tăng và log runtime vẫn tồn tại; không gọi đây là rollback toàn database.

Snapshot source trước/sau trùng nhau. Sau cleanup, các ID fixture không còn tồn tại: tái lập cần fixture mới. Runner pentest/run-part4.cjs từ chối ghi đè results.json cũ; không chạy lại vào thư mục evidence này.

Giới hạn và tài liệu đối chiếu

Chỉ đánh giá môi trường local đang chạy và các tình huống được ghi. Không thử mọi giá trị tiền, số dòng giỏ, lịch concurrent hoặc triển khai nhiều replica. Không thực hiện load test, kiểm tra payment gateway, refund ngoài app hoặc các luật thuế/phí chưa có trong scope.

Việc coupon không hoàn lượt sau hủy được ghi là quan sát nghiệp vụ, cần chủ dự án quyết định chính sách. Coupon 100% được hỗ trợ không tự động là lỗ hổng. Hai nhóm REVIEW về lỗi tổng tiền chỉ được tính là một finding.

Phần 4 tập trung vào logic nghiệp vụ; kết quả injection, XSS, CSRF, tệp và cấu hình triển khai được trình bày ở các chương tương ứng. F-P2-001 vẫn Open.

OWASP WSTG — Business Logic: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/10-Business_Logic_Testing/00-Introduction_to_Business_Logic/

OWASP — Function Use Limits: https://owasp.github.io/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/10-Business_Logic_Testing/05-Test_Number_of_Times_a_Function_Can_Be_Used_Limits

OWASP — Workflow Circumvention: https://owasp.github.io/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/10-Business_Logic_Testing/06-Testing_for_the_Circumvention_of_Work_Flows

PostgreSQL — Numeric Types: https://www.postgresql.org/docs/18/datatype-numeric.html

Tài liệu được dùng để xây dựng tiêu chí và đối chiếu kết quả. Phần kiểm thử này được hoàn thiện ngày 26/09/2026.

PHẦN 5 Input output XSS và CSRF

Phần 5 kiểm tra đầu vào, dấu hiệu injection, XSS, lưu trữ phiên và CSRF của ShopLab local. Xác nhận một lỗi Low về xử lý ID vượt giới hạn số nguyên. Chưa xác nhận SQL injection, XSS hoặc CSRF trong các tình huống đã thực hiện. Một tín hiệu đổi tài khoản do công cụ can thiệp preflight đã được loại bằng kiểm tra đối chứng không interception.

Thông tin	Giá trị
Đợt / phiên bản	SL-PT-20260925 / Phần 5 / 1.0 / Internal
Người nhận / phương pháp	Chủ dự án ShopLab / kiểm thử gray-box
Lượt chính	26/09/2026 01:40:24 – 26/09/2026 01:40:46 UTC+07
Đối chứng	26/09/2026 01:43:03 – 26/09/2026 01:43:11 UTC+07
Target	http://localhost:5173, API qua Vite; attacker fixture chỉ loopback
Khối lượng	19 nhóm chính + 4 nhóm đối chứng; 92 HTTP client; 7 đối chiếu DB; 8 ảnh
Browser evidence	24 CDP records có phân loại; không phải 24 response thật từ app
Finding mới	F-P5-001 Low, Open; chưa sửa hoặc retest sau sửa
Dọn dữ liệu	6 user synthetic qua hai lượt đã xóa; 18 bảng khớp dữ liệu gốc

Lượt chính có 16 PASS và 3 REVIEW. P5-05 dẫn tới finding; P5-16/P5-18 là tín hiệu phải hiệu chỉnh phương pháp. Bốn nhóm đối chứng PASS theo tiêu chí riêng, trong đó có một nhóm tái hiện lỗi 500. Không cộng các PASS thành tỷ lệ an toàn tổng thể.

Phương pháp và phạm vi bằng chứng

Công cụ: Node v24.19.0, Playwright 1.63.0, Chrome 153.0.8010.53. Source backend và frontend được đọc để chọn payload, sau đó kiểm chứng qua HTTP live. Không sửa source hoặc cấu hình app. Snapshot source trước/sau trùng nhau; không thay thế một deployment đóng băng theo commit.

Tài khoản và role ADMIN được cấp trước qua DB. Product, review, ticket/message, profile và order dùng cho payload được tạo/sửa qua API. Chỉ dữ liệu synthetic bị ghi. Sau mỗi lượt, xóa fixture và so toàn bộ original rows của 18 model. Backup riêng trong .local không đưa vào báo cáo chia sẻ, chưa thử restore.

Payload XSS chỉ ghi marker vào window.__p5Xss, không lấy cookie/token, gửi dữ liệu ra ngoài hoặc tải script từ Internet. Detector kiểm tra dương tính ở document trống riêng. Tiêu chí âm gồm thấy đúng text/value, không tạo DOM handler payload và không xuất hiện marker; không dựa riêng vào việc không có popup.

Hai origin thử CSRF là localhost khác port (same-site nhưng cross-origin) và 127.0.0.1 khác port (cross-site). Server fixture bind loopback và đã đóng. Origin/request credentials do browser tạo thật. Chỉ dùng Network CDP quan sát trong lượt đối chứng, không dùng route/interception.

Phần 5 không bao gồm scanner toàn diện, SQL injection dựa trên độ trễ, kiểm thử tải cao, thực thi lệnh, đọc tệp hệ điều hành hoặc external callback. Kết quả upload và URL import được trình bày ở Phần 6; rà soát cấu hình triển khai được trình bày ở Phần 7.

F P5 001 ID vượt giới hạn gây lỗi máy chủ

Thuộc tính	Kết luận
Mức / trạng thái	Low — lỗi validation/robustness; Confirmed / Open
Endpoints đã thấy	GET /api/products/:id, /api/orders/:id, /api/tickets/:id
Quyền	Product không cần login; order/ticket dùng user đăng nhập
Evidence	E-P5-035–040; E-P5C-005/006/007; ảnh E-P5C-03
Tác động đã chứng minh	Request ID ngoài biên trả 500; UI hiện lỗi chung. Không chứng minh DoS, đọc DB hoặc vượt quyền.

Tái hiện và đối chứng

Gửi GET /api/products/2147483647: 404 Product not found. Chỉ tăng ID một đơn vị: GET /api/products/2147483648 trả 500 INTERNAL_ERROR, An unexpected error occurred. ID 9007199254740991 cũng trả 500. Với bearer hợp lệ, order và ticket có ID 2147483648 đều gặp 500.

Lượt đối chứng lặp cặp product ID max/max+1 và chụp UI /products/2147483648. Health vẫn trả 200 sau các request. Không dùng payload tạo tải; không suy diễn lỗi response đơn lẻ thành mất sẵn sàng toàn hệ thống. Page rất lớn được thử trả 200 nên không thuộc finding này.

Nguyên nhân suy ra từ source

backend/src/shared/http.js kiểm tra id bằng number/int/positive nhưng không giới hạn Int32. Model ID dùng Prisma Int trong backend/prisma/schema.prisma. Số 2147483648 vượt giá trị dương tối đa 2147483647 của kiểu này và đi tới tầng truy vấn. Kết luận nguyên nhân dựa trên source và cặp giá trị biên; không có stack trace DB trực tiếp trong response.

Khắc phục và retest dự kiến

Chuẩn hóa parser ID theo miền thật của schema, giới hạn 1..2147483647 và kiểu số an toàn trước truy vấn. Trả 400 rõ ràng cho ID ngoài miền; giữ 404 cho ID hợp lệ không tồn tại. Áp dụng nhất quán các route. Sau sửa kiểm tra max/max+1, âm, lẻ, chữ, số quá lớn và ID thật trên product/order/ticket; chưa thực hiện retest sau sửa, không gán CVSS với tác động giả định.

Kết luận CSRF sau đối chứng

Điểm cần phân biệt: JavaScript không đọc được response do CORS không có nghĩa request chưa tới server. Trong lượt đầu, POST login đã đến server và thay cookie. Nhưng preflight lúc đó do Playwright tự trả credentials=true vì bật interception; đó không phải hành vi CORS nguyên bản của ShopLab.

Quan sát	Lượt đầu có route	Đối chứng không route
Credentialed JSON login	Preflight tooling 204 + ACAC true; POST 200; cookie đổi B	Preflight server 204 thiếu ACAC; POST bị chặn; session/cookie giữ nguyên
Login credentials omit	Không dùng làm control	200 bằng credentials B đã biết; không thay cookie A
Refresh/logout khác origin	403 trên request đơn giản	403 cả same-site và cross-site
Profile sau reload	B do ảnh hưởng lượt login ban đầu	Vẫn A, ảnh trước/sau cùng username

Không ghi nhận finding CSRF hoặc chiếm phiên từ tín hiệu này. Giữ raw evidence và METHODOLOGY_NOTE.md để giải thích REVIEW thay vì sửa lại log gốc thành PASS. Source công cụ local có nhánh isInterceptedOptionsPreflight; đường dẫn, hash và đoạn mã liên quan nằm trong tooling-preflight-note.json.

Khuyến nghị bổ sung: cân nhắc Origin allowlist cho login/register như refresh/logout và cấu hình CORS rõ theo luồng client. Đây là tăng phòng vệ, không phải khẳng định login đang bị khai thác trong cấu hình đã kiểm chứng. Không xác nhận browser khác hoặc production.

Chi tiết nhóm P5 01 đến P5 03

P5 01 Baseline và dữ liệu cô lập

Kỳ vọng: Health/login hoạt động; tạo product riêng qua admin API.

Thực hiện và kết quả: Health và ba login trả 200. Admin C tạo product fixture qua API trả 201. Tài khoản A/B/C được provision riêng qua DB để cô lập dữ liệu, không phải phép thử tự tạo quyền admin.

Bằng chứng: E-P5-001, E-P5-002, E-P5-003, E-P5-004, E-P5-005. Verdict gốc: PASS.

P5 02 SQL injection trên tìm kiếm

Kỳ vọng: Payload tìm kiếm không mở rộng kết quả thành catalogue hoặc gây lỗi SQL; control tìm thấy fixture.

Thực hiện và kết quả: Control q theo prefix tìm thấy product fixture. Tám chuỗi gồm dấu nháy, OR true/false, UNION NULL, SELECT 1 và template syntax đều trả 200. Các chuỗi OR/UNION không trả sản phẩm; không thấy mở rộng kết quả do tautology. Không thực hiện extraction, time-based SQLi hoặc destructive query.

Bằng chứng: E-P5-006 đến E-P5-014. Verdict gốc: PASS.

P5 03 Login SQL và object injection

Kỳ vọng: Không vượt xác thực qua email/password dạng SQL hoặc toán tử object.

Thực hiện và kết quả: Năm payload email/password SQL hoặc object/array đều trả 400/401 và không cấp token. Password SQL với email A hợp lệ không vượt xác thực. Chỉ thử các biến thể được ghi, không suy rộng sang mọi auth endpoint.

Bằng chứng: E-P5-015, E-P5-016, E-P5-017, E-P5-018, E-P5-019. Verdict gốc: PASS.

Chi tiết nhóm P5 04 đến P5 06

P5 04 Kiểu query và ID không hợp lệ

Kỳ vọng: Invalid query/id trả 400; ID hợp lệ không tồn tại trả 404.

Thực hiện và kết quả: Query q lặp bị 400; q[x]=a được bỏ qua và trả 200, không bị hiểu thành toán tử DB. q dài 121, category 51, page/limit sai biên và ID âm/0/lẻ/chữ/SQL bị 400. ID 2147483647 không tồn tại trả 404. PASS của script chỉ nói các input xử lý không 500; không mặc định unknown query phải bị reject.

Bằng chứng: E-P5-020 đến E-P5-035. Verdict gốc: PASS.

P5 05 Biên số nguyên ID và pagination

Kỳ vọng: Số ngoài sức chứa DB phải được từ chối có kiểm soát, không 500.

Thực hiện và kết quả: Product ID 2147483648 và 9007199254740991 trả 500. Order/ticket ID 2147483648 khi có bearer cũng trả 500. Page 9007199254740991 với limit 50 trả 200, vì vậy không gộp pagination vào lỗi ID. F-P5-001 được xác nhận lại ở P5C-04.

Bằng chứng: E-P5-036, E-P5-037, E-P5-038, E-P5-039, E-P5-040. Verdict gốc: REVIEW.

P5 06 JSON parser kích thước và prototype keys

Kỳ vọng: Body lỗi/khác kiểu/quá lớn bị từ chối; không thay profile.

Thực hiện và kết quả: JSON lỗi, array/null/number, __proto__ và constructor bị 400. Body khoảng 34 KB vượt giới hạn 32 KB trả 413. text/plain và form-urlencoded PATCH profile trả 400. D-P5-001 xác nhận trạng thái kinh doanh không đổi; đây không phải kiểm tra mọi gadget prototype pollution trong process.

Bằng chứng: E-P5-041 đến E-P5-049; D-P5-001. Verdict gốc: PASS.

Chi tiết nhóm P5 07 đến P5 09

P5 07 Độ dài field và numeric types

Kỳ vọng: Max length chấp nhận; max+1 hoặc sai kiểu bị 400 và không ghi dữ liệu.

Thực hiện và kết quả: firstName 60 ký tự được chấp nhận; 61 ký tự, object firstName và username chứa tag bị 400. Review rating 0/6/chuỗi, content 2001/object; ticket title 121 và message 4001/object đều bị 400. D-P5-002 giữ nguyên. Không phải tất cả field đều có positive control ở đúng max.

Bằng chứng: E-P5-050 đến E-P5-061; D-P5-002. Verdict gốc: PASS.

P5 08 Lưu payload vào các trường văn bản

Kỳ vọng: Lưu payload qua API hợp lệ để đánh giá escaping khi render; nhận chuỗi không tự chứng minh XSS.

Thực hiện và kết quả: Payload SVG onload, IMG onerror, script và biểu thức template được lưu bằng HTTP vào review, ticket/message, tên/mô tả/category product, firstName/lastName và địa chỉ order. DB xác nhận review và địa chỉ giữ đúng chuỗi. Việc API chấp nhận văn bản có tag không tự chứng minh XSS; kết luận phụ thuộc browser render ở các nhóm sau.

Bằng chứng: E-P5-062 đến E-P5-068. Verdict gốc: PASS.

P5 09 Stored XSS product và review ở browser khác

Kỳ vọng: Anonymous và B thấy chuỗi literal; không có payload node hoặc execution marker.

Thực hiện và kết quả: Anonymous và user B đọc product/review do A gửi. Bốn lần inspect cho thấy đúng chuỗi text, không có node với payload onload/onerror, marker execution rỗng. Detector đã được kiểm tra dương tính trong một document trống riêng, không phải khai thác ShopLab. Ảnh E-P5-01 ghi review literal.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF. Verdict gốc: PASS.

Chi tiết nhóm P5 10 đến P5 12

P5 10 Stored XSS ticket user sang admin

Kỳ vọng: User A và admin C đọc ticket/message chứa payload mà không thực thi.

Thực hiện và kết quả: A đọc ticket mình và C đọc cùng ticket qua admin UI: message giữ literal, không tạo handler và marker rỗng. Ảnh E-P5-02 còn thể hiện title do A gửi giữ nguyên chữ, không trở thành SVG.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF. Verdict gốc: PASS.

P5 11 Profile và order rendering

Kỳ vọng: Profile value, shipping address và item name không tạo node thực thi.

Thực hiện và kết quả: First name nằm trong value input; địa chỉ order được A và C đọc vẫn là text. Marker rỗng và không có node chứa handler payload. Tên product được snapshot trong item cũng hiển thị literal ở ảnh admin order E-P5-03; không thử mọi màn hình quản trị.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF. Verdict gốc: PASS.

P5 12 Reflected DOM XSS và template expression

Kỳ vọng: Query/category/hash không tạo script; template expression giữ nguyên.

Thực hiện và kết quả: Query q chứa IMG nằm nguyên trong input. category chứa SVG được ghép vào heading dưới dạng text. URL fragment chứa payload không thực thi; template syntax trong mô tả giữ nguyên. E-P5-04 chụp product/fragment, không phải ảnh trang search dù tên file có chữ search.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF. Verdict gốc: PASS.

Chi tiết nhóm P5 13 đến P5 15

P5 13 Browser storage và cookie

Kỳ vọng: Không có token trong local/session storage hoặc JS-visible cookie; refresh cookie HttpOnly SameSite Strict.

Thực hiện và kết quả: Trong context A mới: localStorage/sessionStorage rỗng; document.cookie rỗng; không có tên IndexedDB/cache. Refresh cookie HttpOnly, SameSite Strict, path /api/auth; Secure=false ở local HTTP. Source giữ access token trong biến module; không kết luận về toàn bộ heap hoặc production HTTPS.

Bằng chứng: storage.json và checks P5-13 trong results.json. Verdict gốc: PASS.

P5 14 Origin guard trực tiếp trên refresh logout

Kỳ vọng: Origin thiếu/null/sai host/port hoặc suffix bị 403 kể cả có cookie hợp lệ.

Thực hiện và kết quả: Refresh/logout nhận cookie thật nhưng Origin thiếu, null, 127.0.0.1, khác port hoặc hostname suffix đều 403: tổng 10 request. Snapshot session B giữ nguyên. Refresh đúng localhost:5173 trả 200 làm control. Đây là API test; browser được kiểm tra riêng.

Bằng chứng: E-P5-069 đến E-P5-079; D-P5-003. Verdict gốc: PASS.

P5 15 Cookie không thay bearer cho thao tác nghiệp vụ

Kỳ vọng: Không bearer: profile/cart/order/ticket không được phép, kể cả cố gửi cookie đúng.

Thực hiện và kết quả: Bốn request profile/cart/cancel/ticket-close không bearer đều 401 dù cố gửi cookie thật. D-P5-004 không có thay đổi dữ liệu kinh doanh. Cookie thực có path /api/auth nên browser thông thường còn không gửi nó tới các route này.

Bằng chứng: E-P5-080, E-P5-081, E-P5-082, E-P5-083; D-P5-004. Verdict gốc: PASS.

Chi tiết nhóm P5 16 đến P5 18

P5 16 Browser cross-origin JSON và CORS

Kỳ vọng: Preflight từ origin khác không cho đọc private API hoặc gửi JSON login/profile.

Thực hiện và kết quả: Lượt đầu bật context.route để giới hạn mạng. Vite trả ACAO cho origin loopback và Playwright tự đáp ứng preflight với credentials=true; POST login bằng B thực sự đến server. CORS chặn đọc response nhưng cookie bị thay. Không dùng kết quả này làm bằng chứng CSRF thực: phương pháp đã can thiệp preflight. D-P5-005 chỉ so business rows, không gồm sessions. Xem P5C-02 và METHODOLOGY_NOTE.md.

Bằng chứng: E-P5-084; D-P5-005. Verdict gốc: REVIEW.

P5 17 Browser same-site form và simple request

Kỳ vọng: Cookie có thể đi cùng request same-site khác port; Origin chặn refresh/logout; nghiệp vụ cần bearer.

Thực hiện và kết quả: Simple request cùng site khác port trả 403 cho refresh/logout, cookie có trong request; ticket-close 401. Form login application/x-www-form-urlencoded trả 400. Session A không bị revoke. Tuy nhiên context này đã bị thay cookie ở P5-16; dùng confirmation không interception để kết luận cuối về phiên.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF; D-P5-006. Verdict gốc: PASS.

P5 18 Browser cross-site simple request và session control

Kỳ vọng: Khác site bị Origin/auth chặn; không đổi ticket/session; user A vẫn đăng nhập.

Thực hiện và kết quả: Simple request khác site 127.0.0.1 không mang cookie: refresh/logout 403, ticket-close 401, ticket vẫn OPEN. Reload hiển thị B là ảnh hưởng kéo dài từ P5-16, không phải bằng chứng cross-site request ở nhóm này đổi tài khoản. REVIEW được giải thích bằng P5C-01/02/03, không tính thành finding.

Bằng chứng: browser-evidence.json và ảnh; browser-http.json cho CSRF. Verdict gốc: REVIEW.

Chi tiết nhóm P5 19 đến P5 19

P5 19 Error response và health sau thử

Kỳ vọng: Lỗi không tiết lộ stack/SQL/secret; endpoint health vẫn hoạt động sau payload biên.

Thực hiện và kết quả: Không thấy pattern stack/Prisma/SQL/secret đã định nghĩa trong các error response; health sau payload vẫn 200. Kiểm tra pattern không chứng minh không có mọi dạng rò rỉ. Không có pageerror trong browser lượt chính.

Bằng chứng: E-P5-085. Verdict gốc: PASS.

Bốn nhóm đối chứng và kết quả cuối

P5C 01 Control sạch không request routing

Tạo bộ A/B/C mới; login API và browser A thành công. Context không dùng route, Fetch interception hoặc response mocking. Chụp profile A trước thử.

Evidence: E-P5C-001, E-P5C-002, E-P5C-003, E-P5C-004. Verdict: PASS.

P5C 02 Login CSRF JSON không interception

Hai credentialed JSON login từ localhost khác port và 127.0.0.1 bị chặn ở preflight thực vì không có ACAC=true. Không thêm session và cookie victim giữ nguyên. Control credentials=omit nhận 200 bằng thông tin B đã biết, nhưng cookie A không bị thay; không suy ra đọc được phiên của A.

Evidence: confirmation/browser-http.json, browser-evidence.json và ảnh; D-P5C-001. Verdict: PASS.

P5C 03 Simple request và profile sau thử

Bốn simple request refresh/logout từ hai origin trả 403; text/plain login trả 400. Reload profile vẫn đúng A, được chụp ảnh. Browser fetch báo CORS TypeError nhưng status server được CDP ghi riêng, không dựa vào TypeError để coi request chưa đến server.

Evidence: confirmation/browser-http.json, browser-evidence.json và ảnh. Verdict: PASS.

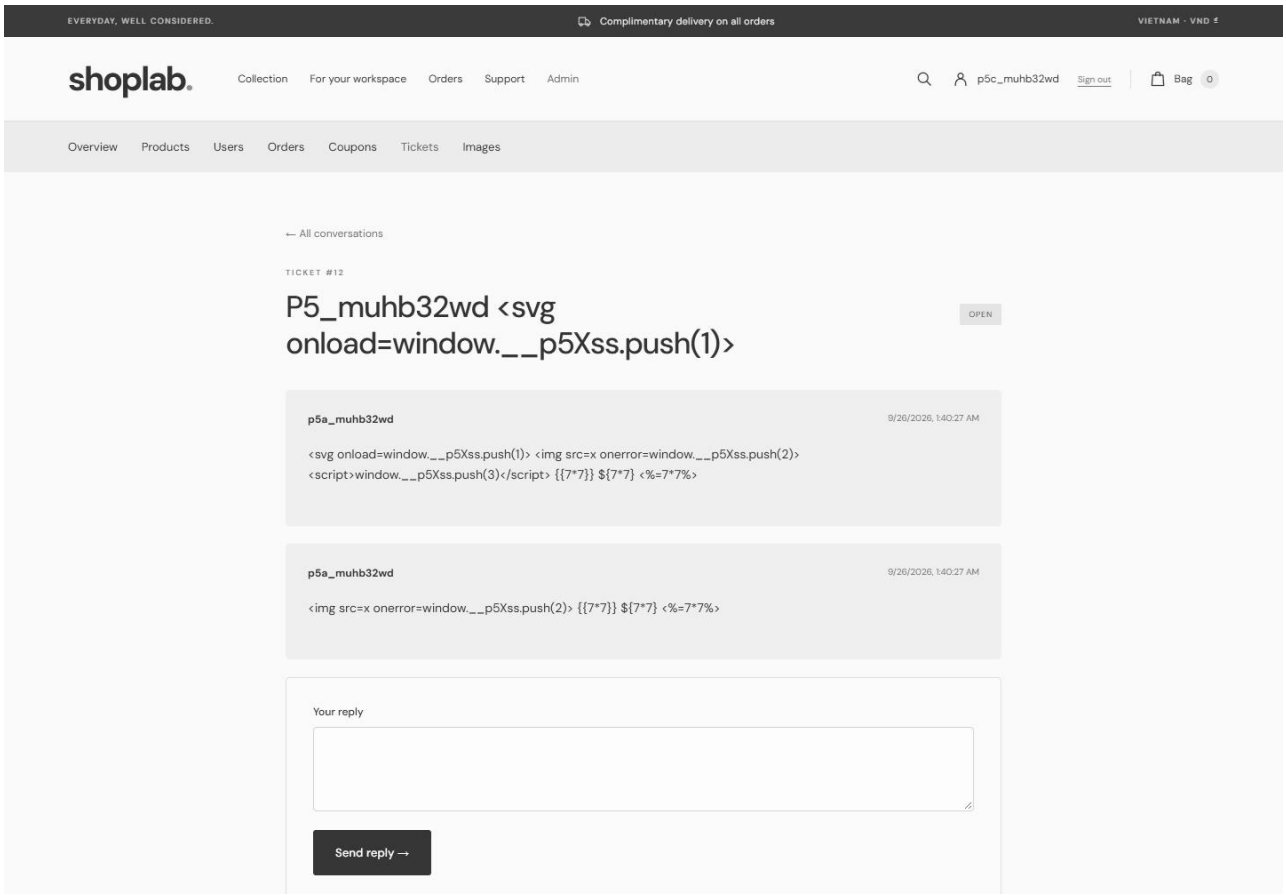
P5C 04 Xác nhận ID biên qua API và UI

Product ID 2147483647 trả 404; 2147483648 trả 500 lần nữa và UI hiển thị lỗi chung. Health 200. PASS của nhóm là tái hiện đúng hiện tượng cần xác nhận, không có nghĩa F-P5-001 đã được sửa.

Evidence: E-P5C-005, E-P5C-006, E-P5C-007. Verdict: PASS.

Các CDP records B-P5C-001/003 đại diện POST bị chặn trước gửi, không có status HTTP. B-P5C-002/004 là preflight thật thiếu ACAC. B-P5C-005 là login credentials=omit 200; B-P5C-007–011 là simple request bị 403/400.

Minh chứng admin đọc ticket chứa payload

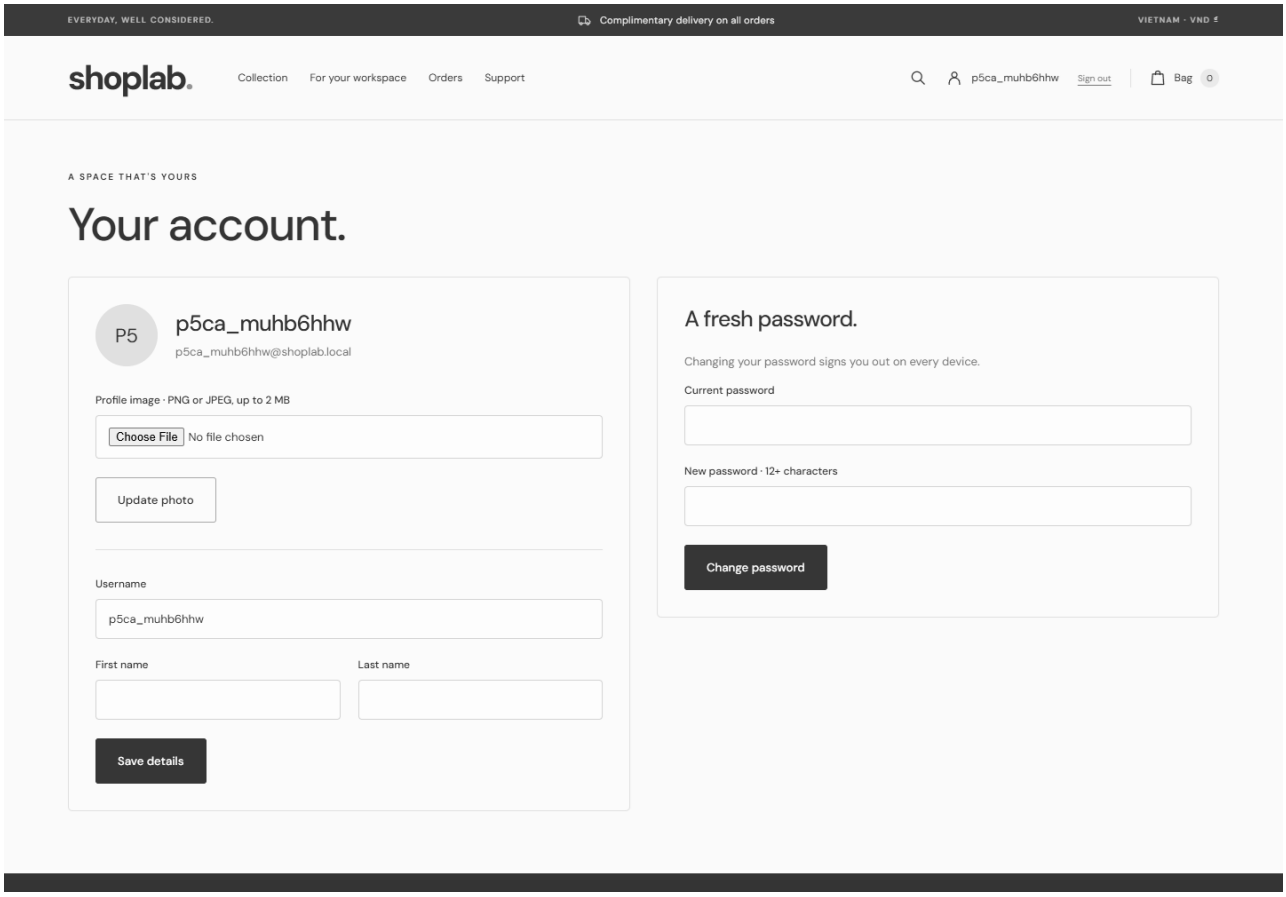


E-P5-02 • Admin C đọc ticket do A gửi; payload trong title/message hiện như văn bản.

Browser inspect xác nhận không có node mang handler __p5Xss và marker rỗng. Các chuỗi template trong message không bị tính thành 49. Ảnh minh họa đi cùng browser-evidence.json; ảnh đơn lẻ không đủ chứng minh không có execution.

Các ảnh bổ sung E-P5-01/03/04 ghi review, order và product. Nội dung đều là synthetic và đã được dọn sau test.

Minh chứng phiên không đổi sau thử CSRF sạch



E-P5C-02 • Sau các phép thử không interception, profile vẫn hiển thị tài khoản A.

Ảnh E-P5C-01 ghi cùng tài khoản trước thử. D-P5C-001 so sessions trước/sau hai JSON login credentialed; cookie cũng được so trực tiếp. Sau control omit và simple request, reload vẫn A. Không dùng ảnh từ context đã chịu ảnh hưởng interception để kết luận bảo vệ CSRF.

Cleanup giới hạn và hồ sơ bàn giao

Lượt chính đã dọn user 24/25/26 và product/review/ticket/order liên quan; đối chứng dọn 27/28/29. Không tạo file upload. Cả hai lượt đối chiếu 18 bảng không có original row đổi/mất hoặc new row còn sót. Sequence ID tăng và log runtime vẫn có request kiểm thử; không phải rollback toàn cluster.

Bằng chứng gồm 92 HTTP client, 24 browser network records được phân loại, 7 DB comparisons và 8 ảnh. Browser traffic nền không được ghi toàn bộ. Token/password/cookie được che; backup riêng không đính kèm. evidence-manifest.json lưu hash tất cả file bằng chứng, gồm thư mục confirmation.

CASE_LOG.md chứa từng check và request ID. COVERAGE.md tóm tắt các nhóm và trạng thái kết luận sau rà soát. findings.json chỉ có một finding mới F-P5-001. F-P2-001 và F-P4-001 vẫn Open, không retest. Mã tái lập run-part5.cjs và run-part5-confirm.cjs phải dùng thư mục/fixture mới khi chạy lại; riêng CSRF phải dùng runner đối chứng không interception.

Chưa thử mọi field, encoding, sink, gadget, browser hay deployment. Không xác nhận chống SQLi time-based hoặc mọi injection backend. Kết quả rỗng trong storage chỉ đúng context/thời điểm đã đo; Secure=false là cấu hình HTTP local.

Tài liệu đối chiếu

OWASP WSTG Stored XSS: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/07-Input_Validation_Testing/02-Testing_for_Stored_Cross_Site_Scripting/

OWASP CSRF Prevention Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

OWASP WSTG Browser Storage: https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/11-Client-side_Testing/12-Testing_Browser_Storage/

Tài liệu XSS, CSRF và lưu trữ trên trình duyệt được đối chiếu ngày 26/09/2026.

PHẦN 6 Upload download và SSRF

Phần 6 kiểm tra upload, download và URL import của ShopLab local. Chưa xác nhận lỗ hổng mới về vượt quyền đọc tệp, ghi ra ngoài thư mục lưu trữ hoặc SSRF trong các trường hợp đã thử. Có một quan sát cần xử lý theo yêu cầu sản phẩm: PDF chỉ được kiểm tra dấu hiệu định dạng ban đầu, chưa kiểm tra đầy đủ cấu trúc hoặc quét nội dung.

Thông tin	Kết quả
Đợt / phiên bản	SL-PT-20260925 / Phần 6 / 1.0 / Internal
Người nhận / phương pháp	Chủ dự án ShopLab / kiểm thử gray-box
Thời gian	26/09/2026 19:03:18 – 26/09/2026 19:03:30 UTC+07
Target	http://localhost:5173 và API qua Vite
Khối lượng	20 nhóm; 79 HTTP client live; 7 component checks; 11 đối chiếu DB/files; 3 ảnh
Kết quả	20 nhóm đạt tiêu chí đã ghi; 0 finding mới; O-P6-001 về PDF validation
Công cụ	Node v24.19.0; Playwright 1.63.0; Chrome 153.0.8010.53
Cleanup	3 user và 23 file synthetic đã xóa; 18 bảng và 2 file gốc giữ nguyên

Kết quả chỉ áp dụng cho các mẫu tệp, URL và tiêu chí đã thử. Phép thử PDF xác minh chính sách tiếp nhận và tải xuống; chưa đánh giá khả năng phát hiện malware.

Mã nguồn và cấu hình ứng dụng được giữ nguyên. F-P2-001, F-P4-001 và F-P5-001 vẫn Open, chưa được kiểm tra lại sau sửa.

Phạm vi môi trường và phương pháp

Môi trường đã dừng khi bắt đầu: kết nối database thất bại trước khi tạo actor, không có HTTP test hay dữ liệu mới. Nhật ký giữ riêng trong part6-preflight-unavailable. Sau đó khởi động lại PostgreSQL hiện có, API, Vite và hai fixture 4101/4102; không chạy migration hoặc seed. SMTP inbox không được khởi động vì không thuộc Phần 6.

Dùng A/B USER và C ADMIN synthetic. Chuỗi ảnh/PDF và tên tệp bất thường đều do runner tạo; không dùng file cá nhân, malware thật hoặc system file làm đích. File tải xuống được so SHA-256; file rejection được đối chiếu cả FileAsset/Attachment và danh sách/hash thư mục uploads, không chỉ dựa vào status HTTP.

Ảnh được chụp bằng Chrome tự động; lượt browser không sử dụng request interception. Bộ bằng chứng có 79 bản ghi HTTP client, chưa bao gồm toàn bộ traffic nền của trình duyệt. Kết quả tải xuống gồm metadata và bytes của tệp.

Live URL import dùng nguồn cấu hình http://127.0.0.1:4101. Canary là server loopback khác port do runner mở, ghi mọi request nhận được. Không dò mạng nội bộ hoặc metadata cloud. Tên .invalid chỉ dùng trong URL bị allowlist từ chối; không coi đây là external callback.

P6-19 gọi trực tiếp fetchImage từ source backend không sửa. IMPORT_ALLOWED_ORIGINS chỉ thay trong process runner để trỏ vào fixture đo redirect/size/timeout, không thay môi trường API đang chạy. Component checks được báo cáo riêng; kết quả không thay cho test toàn stack production.

Backup 18 model trước ghi dữ liệu nằm trong .local, không đính kèm bộ chia sẻ. File gốc được hash trước/sau. Snapshot không phải backup cluster hoặc kiểm thử restore; source hashes không đồng nghĩa deployment đóng băng theo commit.

Ma trận định dạng và giới hạn

Bề mặt	Input đã thử	Kết quả
Avatar/product image	PNG và JPEG hợp lệ	200; tái mã hóa PNG, resize/rotate; JPEG EXIF bị loại
Avatar	HTML/SVG, MIME/extension/signature lệch	400; không thêm file trong nhóm đã thử
Ảnh đầu vào	2 MiB / 2 MiB + 1	200 / 413
Pixel ảnh	4001 × 4000	400; trên giới hạn 16 triệu pixel
Ticket PDF	5 MiB / 5 MiB + 1	201 / 413
Tệp mỗi tin nhắn	3 file / file thứ 4	201 / 400; không orphan
Slot cuối đồng thời	2 upload khi đã có 2 file	1 × 201 và 1 × 400; tổng 3
Ticket đã đóng	Upload PNG hợp lệ	409; không orphan
Private PDF download	Anonymous / A owner / B / C admin	401 / 200 / 404 / 200
Live image import	Origin được phép / redirect / origin khác	200 / 400 / 400

Các control ảnh và PDF chỉ dùng mẫu nhỏ/có padding hoặc một ảnh màu đơn. MiB = 1.048.576 byte. Không áp dụng ma trận này cho mọi MIME, decoder hoặc trường hợp encoding chưa thử.

O P6 001 Giới hạn xác thực PDF

Quan sát và cách tái hiện

Gửi multipart vào message của ticket mình, filename synthetic-invalid.pdf, MIME application/pdf, body 62 byte bắt đầu bằng %PDF-1.4 rồi là văn bản synthetic không có catalog/page/xref hợp lệ. Server trả 201 và tạo attachment (E-P6-037). Dữ liệu này được dọn sau test.

Source storeFile chỉ yêu cầu đuôi .pdf, MIME application/pdf và năm byte đầu %PDF-. Khác với PNG/JPEG, PDF không qua giải mã/tái tạo. Do đó PASS ở P6-09 có nghĩa quan sát được ghi đúng và response có kiểm soát, không có nghĩa nội dung PDF đã được xác thực.

Đánh giá tác động và giới hạn

Phân loại Observation / Informational, không tính vào confirmed vulnerabilities. Chưa chứng minh tệp chạy JavaScript, thực thi mã, gây lỗi PDF reader hoặc có malware. Download fixture hợp lệ có attachment disposition, nosniff và CSP sandbox; quyền private chặn B. Các header này không chứng minh an toàn khi người nhận tự mở một tệp trong ứng dụng ngoài browser.

Góp ý cải thiện

Nếu yêu cầu sản phẩm chỉ nhận PDF thực, bổ sung parser kiểm tra cấu trúc trong môi trường có giới hạn tài nguyên. Nếu triển khai nhận tệp không tin cậy, cân nhắc malware scanning/CDR phù hợp và quy trình xử lý file bị từ chối. Giữ authorization, dung lượng và download attachment hiện có; không coi đuôi/MIME/magic là bảo đảm nội dung sạch.

Chưa sửa hoặc retest theo yêu cầu chính sách mới. Kiểm thử sau thay đổi nên có PDF hợp lệ, PDF lỗi cấu trúc, PDF mã hóa và giới hạn tài nguyên parser; trạng thái chỉ được xác nhận sau khi thống nhất tiêu chí tiếp nhận PDF và có bằng chứng kiểm tra lại.

Chi tiết P6 01 đến P6 03

P6 01 Baseline và fixture

Kỳ vọng: Health/login hoạt động; tạo product và ticket riêng.

Thực hiện và kết quả: Health và login A/B/C 200. C tạo product qua admin API, A tạo ticket và đọc message ID thật. Actor được provision qua DB; dữ liệu dùng kiểm thử file được tạo qua API. Lượt test chỉ tác động fixture riêng.

Bằng chứng: E-P6-001 đến E-P6-007.

P6 02 Ảnh hợp lệ và tái mã hóa

Kỳ vọng: PNG/JPEG hợp lệ thành PNG; metadata và bytes nối thêm không được giữ.

Thực hiện và kết quả: PNG nối chuỗi script marker được nhận, tái mã hóa thành PNG không còn marker. JPEG 40×24 có orientation 6 thành PNG 24×40, không còn EXIF/orientation. Avatar public GET 200 làm control. Đây là kiểm tra tái mã hóa, không phải chứng minh chống mọi polyglot hoặc lỗi decoder.

Bằng chứng: E-P6-008, E-P6-009, E-P6-010.

P6 03 MIME extension và chữ ký không khớp

Kỳ vọng: Các tổ hợp giả định dạng bị 400 và không tạo asset/file.

Thực hiện và kết quả: Bảy trường hợp HTML giả PNG, SVG, PNG khai JPEG, PNG khai text/html, đuôi .png.html, PDF giả PNG và chuỗi MZ giả executable đều bị 400 ở avatar. D-P6-001 xác nhận không thêm asset/file. Không upload malware thật.

Bằng chứng: E-P6-011 đến E-P6-017; D-P6-001.

Chi tiết P6 04 đến P6 06

P6 04 Giải mã ảnh và giới hạn pixel

Kỳ vọng: Signature đúng nhưng nội dung hỏng hoặc hơn 16 triệu pixel bị từ chối.

Thực hiện và kết quả: PNG chỉ còn 16 byte và ảnh màu đơn 4001×4000 (16.004.000 pixel) đều bị 400. Ảnh lớn chỉ được tạo/gửi một lần, ngay trên giới hạn 16 triệu pixel; không thử gây cạn bộ nhớ. D-P6-002 không có file mới.

Bằng chứng: E-P6-018, E-P6-019; D-P6-002.

P6 05 Biên dung lượng ảnh

Kỳ vọng: Ảnh input 2 MiB được nhận; 2 MiB + 1 bị 413.

Thực hiện và kết quả: PNG được padding tới đúng 2 MiB nhận 200 và được tái mã hóa. Thêm một byte nhận 413; D-P6-003 giữ nguyên. Giới hạn đo theo byte input, không theo kích thước PNG đầu ra.

Bằng chứng: E-P6-020, E-P6-021; D-P6-003.

P6 06 Multipart thiếu file nhiều file và fields

Kỳ vọng: Missing/wrong field/two files/six fields bị từ chối có kiểm soát.

Thực hiện và kết quả: Không gửi file, field other, hai file trong một multipart và sáu field kèm file đều nhận 400. D-P6-004 không có asset/file mới. Chưa thử mọi multipart malformed hoặc parser differential.

Bằng chứng: E-P6-022, E-P6-023, E-P6-024, E-P6-025; D-P6-004.

Chi tiết P6 07 đến P6 09

P6 07 Tên tệp traversal và trùng tên

Kỳ vọng: Tên storage là UUID; tên đường dẫn không quyết định chỗ ghi và không overwrite file cũ.

Thực hiện và kết quả: Năm upload gồm ../../p6-proof.png, đường dẫn backslash, double.svg.png và hai lần repeat.png đều 200 vì nội dung PNG hợp lệ. Stored name đều UUID.png và khác nhau; originalName được basename. Không kết luận double extension luôn phải bị từ chối: đuôi cuối .png khớp nội dung đã tái mã hóa.

Bằng chứng: E-P6-026, E-P6-027, E-P6-028, E-P6-029, E-P6-030.

P6 08 PDF ticket và giới hạn 5 MiB

Kỳ vọng: PDF được nhận riêng cho ticket; cùng PDF avatar bị 400; file quá 5 MiB bị 413.

Thực hiện và kết quả: PDF fixture được ticket nhận 201, cùng PDF tại avatar bị 400. PDF padding đúng 5 MiB nhận 201; 5 MiB + 1 bị 413. D-P6-005 không có file mồ côi. Hash bản PDF tải về được kiểm chứng ở nhóm quyền và browser.

Bằng chứng: E-P6-031, E-P6-032, E-P6-033, E-P6-034, E-P6-035; D-P6-005.

P6 09 Mức kiểm tra nội dung PDF

Kỳ vọng: Ghi nhận magic-byte check không tương đương xác thực PDF hay malware scan.

Thực hiện và kết quả: Tệp 62 byte có %PDF-1.4 nhưng không có cấu trúc PDF hợp lệ được nhận 201 (E-P6-037). Đây là O-P6-001 về giới hạn validation, chưa phải finding thực thi mã. Một PDF với tên chứa SVG/onload cũng được nhận để kiểm tra render tên file trên UI.

Bằng chứng: E-P6-036, E-P6-037, E-P6-038.

Chi tiết P6 10 đến P6 12

P6 10 Quota ba attachment và cleanup

Kỳ vọng: Attachment thứ tư bị từ chối; không sót asset/file khi rollback.

Thực hiện và kết quả: Ba attachment vào cùng message nhận 201; attachment thứ tư bị 400. D-P6-006 so DB và danh sách/hash file trước/sau: không thêm asset/file sau lần bị từ chối, dù storeFile có thể chạy trước kiểm tra quota.

Bằng chứng: E-P6-039, E-P6-040, E-P6-041, E-P6-042; D-P6-006.

P6 11 Upload đồng thời tranh slot cuối

Kỳ vọng: Hai upload đồng thời khi có hai attachment: chỉ một thắng và tổng ba.

Thực hiện và kết quả: Message mới có sẵn hai attachment; gửi hai upload đồng thời một lượt. Một 201, một 400; chỉ thêm một asset/file và tổng attachment bằng ba (D-P6-007). Chưa chạy nhiều vòng hoặc kiểm thử tải lớn.

Bằng chứng: E-P6-043, E-P6-044, E-P6-045, E-P6-046, E-P6-047; D-P6-007.

P6 12 Quyền upload và download private

Kỳ vọng: Owner/admin tải được cùng bytes; anonymous 401, B 404; public assets không mở file ticket.

Thực hiện và kết quả: B upload vào message A bị 404; A upload product image qua admin route bị 403; DB/files giữ nguyên D-P6-008. Tải PDF: anonymous 401, A 200, B 404, C ADMIN 200. Hai response 200 cùng hash fixture và có Content-Disposition attachment, nosniff, CSP sandbox. Public /assets với assetId TICKET trả 404.

Bằng chứng: E-P6-048 đến E-P6-054; D-P6-008.

Chi tiết P6 13 đến P6 15

P6 13 Đường dẫn storage không được dùng làm download

Kỳ vọng: ID/path giả không đọc được fixture qua đường khác; không dùng file host thật làm đích.

Thực hiện và kết quả: Thử dùng stored filename thay asset ID, encoded ../ và đường /uploads của chính fixture. Không response nào có hash PDF; không có 500. /uploads có thể trả HTML fallback của Vite với 200, không được tính là tải được PDF. Không yêu cầu đọc file hệ điều hành thật.

Bằng chứng: E-P6-055, E-P6-056, E-P6-057, E-P6-058.

P6 14 Browser tên file và tải xuống

Kỳ vọng: Tên chứa tag render literal; browser tải PDF thành attachment có hash đúng.

Thực hiện và kết quả: Browser A mở ticket, tên file chứa tag hiển thị là button text; không có handler node hoặc execution marker. Bấm p6-proof.pdf tạo download thực, suggested filename đúng và SHA-256 trùng bytes fixture. downloaded-proof.pdf chỉ là bằng chứng synthetic, không phải báo cáo PDF.

Bằng chứng: results.json browserDownload; downloaded-proof.pdf; E-P6-01.

P6 15 Ticket đóng không nhận file

Kỳ vọng: Sau close, upload trả 409 và không để file/asset mồ côi.

Thực hiện và kết quả: Owner đóng ticket thành công; upload tiếp vào message chưa đủ quota trả 409. D-P6-009 không thêm file/asset. Browser hiển thị trạng thái CLOSED và không còn form upload; ảnh E-P6-02 ghi phần đầu ticket, kiểm tra text thông báo đóng được thực hiện bằng locator.

Bằng chứng: E-P6-059, E-P6-060; D-P6-009.

Chi tiết P6 16 đến P6 18

P6 16 Live import nguồn được phép

Kỳ vọng: Admin import PNG từ fixture 127.0.0.1:4101 thành công; user thường không có quyền.

Thực hiện và kết quả: User A import qua admin route bị 403. Admin C import http://127.0.0.1:4101/sample.png thành công 200, asset giải mã thành PNG và public GET 200. Browser mở product hiển thị ảnh; ảnh fixture là một mảng màu, không phải ảnh tải lỗi.

Bằng chứng: E-P6-061, E-P6-062, E-P6-063.

P6 17 Live SSRF allowlist và origin confusion

Kỳ vọng: URL ngoài origin chính xác bị reject, canary không được truy cập.

Thực hiện và kết quả: Mười URL không hợp lệ/ngoài allowlist bị 400: canary khác port, localhost thay 127.0.0.1, port 4102, userinfo, suffix hostname .invalid, file/data/ftp scheme và chuỗi sai URL. Canary loopback do runner kiểm soát không có hit. D-P6-010 không đổi asset/file. Không nhắm cloud metadata hoặc dịch vụ nội bộ thật.

Bằng chứng: E-P6-064 đến E-P6-073; D-P6-010.

P6 18 Live chuẩn hóa URL và redirect

Kỳ vọng: Canonical loopback dạng số vẫn cùng origin; redirect bị từ chối không tạo asset.

Thực hiện và kết quả: Decimal host 2130706433, hex 0x7f000001, path /folder/../sample.png và fragment đều chuẩn hóa về cùng origin cho phép rồi import 200. Đây không phải bypass sang máy khác. Live /redirect trả 400 và D-P6-011 không thêm asset/file. Chứng cứ không theo redirect có server đếm request nằm ở component test, không suy ra chỉ từ 400 live.

Bằng chứng: E-P6-074, E-P6-075, E-P6-076, E-P6-077, E-P6-078; D-P6-011.

Chi tiết P6 19 đến P6 20

P6 19 Component fetchImage có server đo request

Kỳ vọng: Cùng source fetchImage, allowlist riêng trong process kiểm thử; redirect không theo, byte/time limits có hiệu lực.

Thực hiện và kết quả: Import trực tiếp hàm fetchImage từ source không sửa, trong process runner có allowlist riêng trỏ tới server local đo request. /ok đúng hash; redirect 302 ra canary và 307 cùng origin đều bị từ chối, không có hit đích tiếp theo. Body >2 MiB, Content-Type HTML, 404 và timeout đều bị từ chối. Đây là component test, không phải bảy HTTP request vào ShopLab live.

Bằng chứng: C-P6-001 đến C-P6-007; component-checks.json; canary-log.json.

P6 20 Bảo toàn file có sẵn và health

Kỳ vọng: Hash mọi file gốc không thay đổi; health vẫn 200 sau kiểm thử.

Thực hiện và kết quả: Health cuối trả 200; hai file gốc còn nguyên hash. Sau finally cleanup: xóa ba user 30/31/32, dữ liệu liên quan và 23 file synthetic. DB 18 model và toàn bộ danh sách/hash thư mục uploads trở về bản ghi/file gốc; sequence và runtime logs không được rollback.

Bằng chứng: E-P6-079.

Kết quả đo URL import ở component

Case	Đích fixture	Kết quả / thời gian
C-P6-001	/ok	Chấp nhận đúng hash / 14 ms
C-P6-002	/redirect-out	Image source must respond with HTTP 200; redirects are not followed. / 2 ms
C-P6-003	/redirect-in	Image source must respond with HTTP 200; redirects are not followed. / 1 ms
C-P6-004	/large	Imported image exceeds 2 MB. / 10 ms

Case	Đích fixture	Kết quả / thời gian
C-P6-005	/html	Image source did not return PNG or JPEG. / 10 ms
C-P6-006	/404	Image source must respond with HTTP 200; redirects are not followed. / 1 ms
C-P6-007	/slow	Image request timed out. / 5010 ms

Canary không có hit. /ok chỉ nhận một request control; redirect-in không tạo request /ok lần hai. Hai điều kiện này là bằng chứng không theo redirect ở hàm được gọi. Deadline /slow là 5010 ms, phù hợp cấu hình 5 giây trong lượt đo, không phải số liệu hiệu năng production.

P6-19 không kiểm thử DNS rebinding thực hoặc thay địa chỉ giữa hai lần lookup. Source pin kết quả DNS lookup vào request được rà soát nhưng chưa chứng minh mọi tình huống IPv6, proxy hoặc hạ tầng DNS. Bảy phép kiểm tra component được thống kê riêng với request HTTP vào ứng dụng đang chạy.

Minh chứng tên tệp trên giao diện

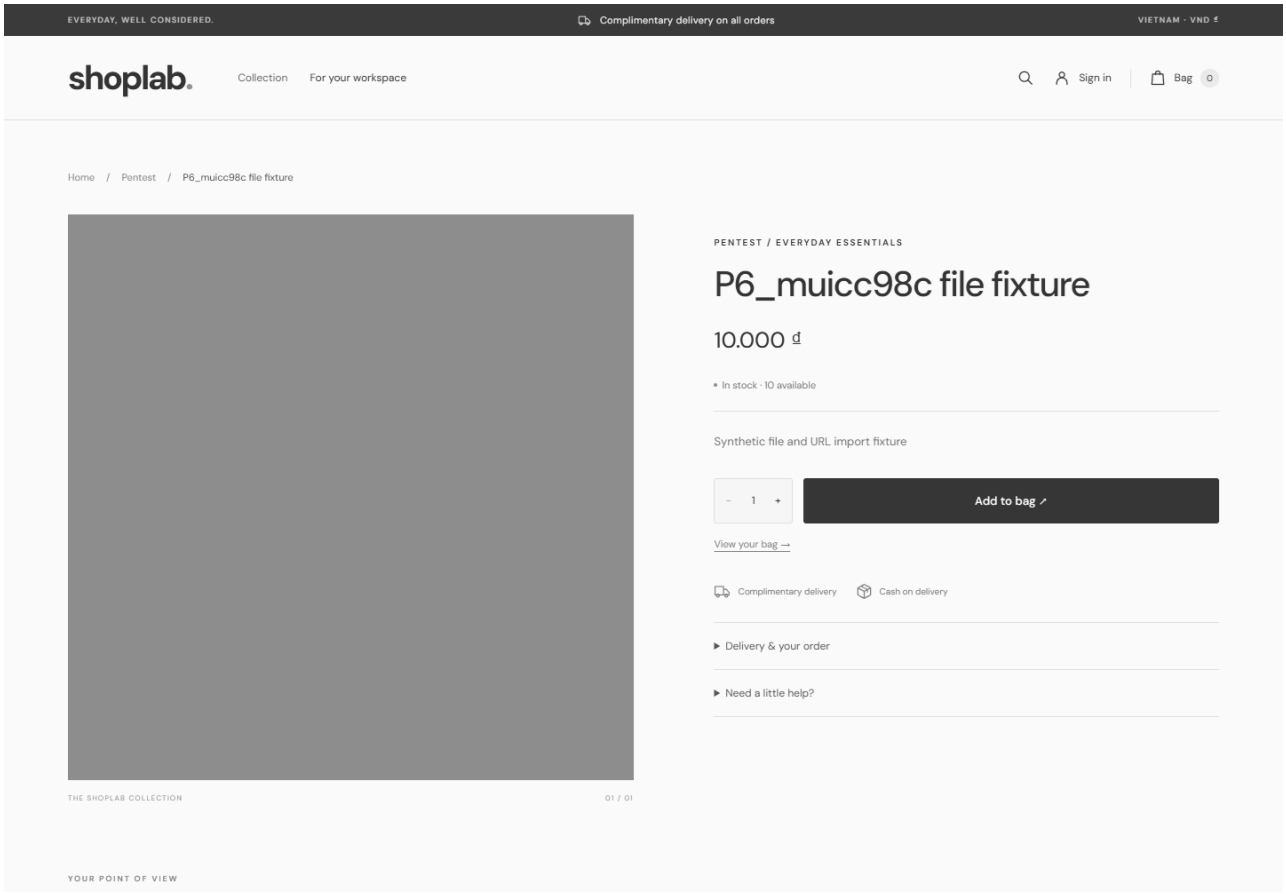


E-P6-01 • Tên có SVG/onload hiện như chữ trên nút attachment; không tạo DOM handler.

Browser A thấy cả PDF control và synthetic-invalid.pdf. Điều này minh họa quan sát PDF validation, không chứng minh file độc hại được thực thi. Việc không có marker được kiểm tra bằng DOM; không chỉ dựa vào hình chụp.

Download thật p6-proof.pdf có SHA-256 6a65fbfcfc685ddc3036c6e57de449ee9a9652d97a04865a8ba33d4c14dcd43e. Hash trùng fixture đầu vào. File bằng chứng được giữ trong thư mục run, tách khỏi uploads của ứng dụng.

Minh chứng ảnh import và bảo toàn dữ liệu



E-P6-03 • Ảnh từ nguồn local cho phép đã hiển thị trên product synthetic; mảng màu là nội dung fixture.

E-P6-02 ghi ticket CLOSED; HTTP 409 và so file trước/sau mới là bằng chứng chính của từ chối upload khi đóng. Đã dọn user 30/31/32, product/ticket và 23 file synthetic. Hai file uploads gốc khớp hash, 18 model không có bản ghi gốc đổi/mất hoặc bản ghi mới còn sót.

File directory snapshot và source hashes khớp sau cleanup. Sequence IDs và runtime logs vẫn tăng; đây là đối chiếu bảo toàn dữ liệu, không phải khôi phục toàn database. Dịch vụ ShopLab local được để chạy sau kiểm thử, còn canary và component fixture tạm đã đóng.

Hồ sơ bàn giao và giới hạn kết luận

CASE_LOG.md: expected/actual, checks và request ID từng bước. http.json: 79 HTTP client record, token/cookie/password đã che. db-checks.json: 11 đối chiếu DB/files. component-checks.json và canary-log.json: bảy phép thử hàm với log đích. file-checks.json và results.json: metadata tái mã hóa, download, cleanup. evidence-manifest.json: SHA-256 các file bằng chứng.

Mã tái lập: pentest/run-part6.cjs. Script từ chối ghi đè results.json cũ; cần run folder và fixture mới trước retest. Failed preflight khi DB chưa chạy được giữ riêng, không được tính

vào 20 nhóm hoặc 79 HTTP record. Runner runtime đã khởi động database có sẵn, không migration/seed; inbox SMTP chưa chạy.

Không thử malware thật, PDF reader exploitation, mọi kiểu polyglot, archive extraction, DNS rebinding, mọi trường hợp upload đồng thời hoặc exhaustion. P6-11 chỉ có một lượt hai request. Không có rate/aggregate-storage quota assessment trong phần này. Chưa kết luận Nginx/TLS hoặc môi trường public production.

F-P2-001, F-P4-001 và F-P5-001 vẫn Open. O-P6-001 là quan sát về xác thực nội dung PDF và cần tiêu chí sản phẩm cụ thể. Mã nguồn ứng dụng được giữ nguyên trong lượt kiểm thử này.

Tài liệu đối chiếu

OWASP File Upload Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

OWASP SSRF Prevention Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

Hướng dẫn về upload và SSRF được đối chiếu ngày 26/09/2026 để xây dựng tiêu chí kiểm thử.

PHẦN 7 Cấu hình dependency và mã nguồn

Phần 7 xác nhận một điểm yếu mức Low trong môi trường dev: Vite cho phép đọc tệp JSON ngoài frontend, nằm trong .local, qua /@fs/ mà không cần đăng nhập ứng dụng. Minh chứng chỉ chứa dữ liệu giả; không tải secret thật. Audit dependency chưa trả về advisory và build frontend thành công. Cấu hình Docker/Nginx được rà soát bằng source vì cổng 8080 chưa hoạt động.

Thông tin	Kết quả
Đợt và phạm vi	SL-PT-20260925 / Phần 7 / phiên bản 1.0 / Internal
Người nhận / phương pháp	Chủ dự án ShopLab / kiểm thử gray-box
Lượt HTTP và config	26/09/2026 19:16:04 đến 26/09/2026 19:16:07 UTC+07
Báo cáo và audit	Ngày 26/09/2026 UTC+07; audit và build là phép kiểm tra riêng
Khối lượng	18 nhóm; 22 HTTP attempt (21 response, 1 refused); 4 config checks; 2 ảnh
Kết quả	1 finding mới Low; 3 quan sát Informational; 3 finding trước vẫn Open
Dependency	All 594 / prod 188 theo metadata audit; 0 advisory được trả về
Bảo toàn	18 model không đổi; canary đã xóa; 58 file source/config hash không đổi

Phần 7 không thay đổi mã nguồn hoặc phiên bản dependency. Kết luận áp dụng cho môi trường local và các cấu hình đã rà soát; cấu hình triển khai thực tế và kiểm tra lại sau sửa vẫn còn ngoài phạm vi.

F P7 001 Phạm vi file của Vite quá rộng

Điều kiện và cách tái hiện

Mức Low, trạng thái Open, độ tin cậy cao đối với việc đọc canary; ưu tiên xử lý trước khi chia sẻ dev server. Người thử cần truy cập được cổng Vite 5173 và biết/đoán đường dẫn file. Runtime hiện chỉ lắng nghe loopback. Không chấm CVSS số vì chưa có threat model triển khai public để suy rộng tác động.

1. Tạo một JSON vô hại trong .local/p7-canary-<timestamp>.json với marker riêng. 2. Gửi GET http://localhost:5173/@fs/<absolute-path> bằng client không cookie/bearer. 3. Quan sát HTTP 200 và marker đúng. 4. Mở URL đó trong browser sạch; chụp ảnh E-P7-02. 5. Xóa canary sau test. URL và response đầy đủ nằm ở E-P7-019, không cần file còn tồn tại để kiểm chứng record đã lưu.

Nguyên nhân và tác động

frontend/vite.config.js không thu hẹp server.fs.allow/deny. Workspace chứa pnpm-workspace.yaml; phạm vi phục vụ mặc định của Vite có thể bao gồm workspace. Cùng workspace có .local/settings.json và backup theo scripts/runtime.mjs. Việc đọc canary cùng vùng lưu trữ là bằng chứng lỗi phân tách, còn đọc secret/backup thật chỉ là rủi ro suy luận và không được thực hiện.

Backend config source cũng trả 200 qua /@fs/. .gitignore hoặc .dockerignore không điều khiển HTTP file serving. Không gọi đây là lỗ hổng của phiên bản Vite: đây là cách đặt file nhạy cảm và cấu hình dev server của dự án. Audit Vite sạch không loại trừ lỗi cấu hình này.

Giới hạn và khuyến nghị

Không có bằng chứng attacker Internet truy cập được loopback, không chứng minh browser ngoài origin đọc được canary: response cross-origin thử bằng HTTP client không có ACAO. Không đọc .local/settings.json, backup hoặc credential thật; không giả JWT. Không áp dụng finding này cho Nginx chưa chạy.

Thu hẹp fs.allow vào frontend và phần dependency cần thiết; bổ sung deny rõ cho .local, backup, evidence và backend ngoài nhu cầu build, hoặc đặt secret/backup ngoài workspace phục vụ. Giữ loopback, không tunnel dev server ra Internet. Dùng static build sau Nginx cho triển khai. Retest bằng canary cùng vị trí phải bị 403/404, đồng thời frontend/HMR/build vẫn hoạt động; chưa đánh dấu Fixed.

Các quan sát cần xử lý trước triển khai

O P7 001 Guardrail cho môi trường production

Module config chỉ kiểm tra secret dài ít nhất 32 ký tự; nhận chính placeholder trong .env.example ngay cả NODE_ENV=production. Compose bật demo seed, HTTP origin và cookie không Secure. Không có bằng chứng runtime hiện dùng placeholder: các kiểm tra dùng process riêng và secret giả. Lab đã được SECURITY.md giới hạn local nên ghi Informational, không gán mức Critical cho tài khoản demo theo thiết kế.

Đề xuất tách profile production, từ chối placeholder đã biết, dùng secret ngẫu nhiên từ nơi quản lý phù hợp, bắt buộc HTTPS/Secure khi public, tắt seed demo và xác minh tài khoản demo không tồn tại trong dữ liệu triển khai.

O P7 002 Nhận diện client sau proxy

Limiter dùng IP mặc định; app chưa đặt trust proxy và Nginx chưa ghi X-Forwarded-For. Có nguy cơ nhiều client dùng chung bucket proxy. Đây là suy luận source được tài liệu express-rate-limit hỗ trợ, chưa xác nhận trên deployment thật và không thử làm cạn quota. Cần test hai client qua Nginx, cấu hình trusted hop/address và overwrite forwarded headers ở biên tin cậy.

O P7 003 Chuỗi cung ứng và image runtime

CI chưa chạy dependency audit; actions/base image còn pin theo tag thay vì digest/commit. Backend image không tách stage runtime và công cụ dev. Chưa kiểm tra OS CVE, signature/provenance hoặc thực quyền container. Bổ sung chính sách cập nhật/audit, review

build scripts được phép, giảm runtime packages và xác minh image bằng công cụ phù hợp trước khi public.

Các quan sát không được cộng thành ba lỗ hổng khai thác đã xác nhận. Source review còn ghi nhu cầu vòng đời/quota file cũ và audit sự kiện; chưa thử tải, malware, DB restore hoặc chain chiếm quyền.

Dependency và sản phẩm build

Package	Phiên bản cài	Nhóm
@playwright/test	1.63.0	Dev
@prisma/client	6.19.3	Runtime
express	5.2.1	Runtime
express-rate-limit	8.7.0	Runtime
helmet	8.3.0	Runtime
jsonwebtoken	9.0.3	Runtime
multer	2.4.0	Runtime
nodemailer	9.1.1	Runtime
sharp	0.35.4	Runtime
zod	4.6.5	Runtime
axios	1.20.0	Runtime
react	19.3.0	Runtime
react-router-dom	7.18.4	Runtime
vite	7.3.6	Dev

Bảng chọn 14 package quan trọng; đủ 25 dependency trực tiếp nằm trong direct-dependencies.json. Node chạy kiểm thử v24.19.0. Lockfile và source được hash; phiên bản cài có thể khác giá trị tối thiểu trong package.json.

Audit toàn cây trả totalDependencies=594, production trả 188; cả hai có advisories rỗng. Không cộng các trường metadata chồng lấn và không diễn giải 0 advisory thành 0 rủi ro. Registry chỉ cung cấp dữ liệu đã biết tại thời điểm truy vấn; không bao phủ OS container, runtime OS, package độc hại chưa phát hiện hoặc cách ứng dụng sử dụng thư viện.

Vite build tạo 28 file, không có .map. Exact-match scan không tìm thấy secret/password runtime hiện tại hoặc placeholder JWT. Không ghi các giá trị đó vào evidence. Chưa kiểm

tra secret lịch sử Git, không thực hiện full entropy scan, chưa chạy frontend build sau CSP Nginx.

Chi tiết P7 01 đến P7 03

P7 01 Môi trường thực tế

Trạng thái: PARTIAL. Kỳ vọng: Xác định dịch vụ đang phục vụ và giới hạn triển khai.

GET giao diện 5173 và health qua Vite/API 4000 đều 200. TCP 8080 từ chối kết nối. netstat ghi API, Vite, PostgreSQL và hai fixture đều LISTENING trên 127.0.0.1; không thấy listener SMTP/inbox trong danh sách cổng ShopLab. Docker không có trong PATH của phiên kiểm tra. Chưa chạy compose, Nginx hay TLS, vì vậy chỉ rà soát source của các lớp này.

Bằng chứng: E-P7-001–004; listeners.txt.

P7 02 Header và cache

Trạng thái: PASS. Kỳ vọng: API trả header bảo vệ và không cache dữ liệu; phân biệt HTML dev.

Health trực tiếp và qua proxy có nosniff, CSP, no-store, request ID, không có X-Powered-By. HTML gốc Vite dùng no-cache và thiếu CSP/X-Frame-Options. Không gán header của API cho toàn website. HSTS xuất hiện trên response HTTP không có nghĩa phiên HTTP đã được mã hóa hoặc được HSTS bảo vệ.

Bằng chứng: E-P7-001–003; backend/src/app.js:20–26.

P7 03 Lỗi giao thức và giới hạn body

Trạng thái: PASS. Kỳ vọng: Request lỗi trả status có kiểm soát, không lộ stack.

Endpoint không tồn tại 404; hai route cần đăng nhập 401. TRACE health 404. JSON dang dở nhận 400; body JSON 32.778 byte nhận 413. Không có stack trace trong các response đã lưu. Error code INTERNAL_ERROR cho 400/413 chưa diễn đạt chính xác nhưng chưa chứng minh rò rỉ dữ liệu. Chỉ một body vượt giới hạn, không thử tải hoặc DoS.

Bằng chứng: E-P7-005–007, 013, 015–016.

Chi tiết P7 04 đến P7 06

P7 04 Host và CORS cơ bản

Trạng thái: PASS. Kỳ vọng: Host ngoài allowlist bị chặn ở Vite; không coi 204 là CORS cho phép.

Host p7.invalid qua Vite bị 403. OPTIONS từ Origin p7.invalid trả 204 nhưng không có Access-Control-Allow-Origin hoặc Allow-Credentials. API trực tiếp nhận health với Host/X-Forwarded-* tự đặt, trả 200 và không redirect. Điều này chưa chứng minh Host-header injection hay bypass limiter. Source reset link dùng config.origin, không dựng link từ Host. Không đánh giá DNS rebinding.

Bằng chứng: E-P7-014, 017–018; auth.service.js forgotPassword.

P7 05 Phạm vi file của dev server

Trạng thái: FINDING. Kỳ vọng: Đối chiếu khả năng đọc file ngoài frontend bằng canary không bí mật.

Tạo đúng một JSON trong .local, chứa marker synthetic. GET /@fs/<đường dẫn tuyệt đối>/...json trả 200 và đúng marker, không cookie/bearer. Browser sạch cũng đọc được. GET kèm Origin ngoài vẫn 200 ở HTTP client nhưng không có ACAO: không phải bằng chứng website ngoài đọc được nội dung bằng JavaScript. Backend config source qua /@fs/ cũng 200. F-P7-001 Low được xác nhận trong môi trường dev loopback.

Bằng chứng: E-P7-019–022; E-P7-02-synthetic-file.png.

P7 06 Kiểm tra cấu hình secret

Trạng thái: REVIEW. Kỳ vọng: Thiếu/short secret bị từ chối; xem khả năng nhận placeholder ở production.

Bốn process riêng import config với NODE_ENV=production. Missing và short bị từ chối. Chuỗi mẫu replace_with_at_least_32_random_characters và secret random synthetic đều được chấp nhận; COOKIE_SECURE=false và HTTP origin cũng được nhận. Đây là kiểm tra module cấu hình, không phải khởi động server production hoặc thử giả JWT. Không thay secret đang dùng. O-P7-001 ghi thiếu guardrail khi chuyển sang production.

Bằng chứng: C-P7-001–004; config-checks.json; config/env.js:3–10.

Chi tiết P7 07 đến P7 09

P7 07 Compose và dữ liệu demo

Trạng thái: REVIEW. Kỳ vọng: Rà soát ranh giới mạng, seed, TLS và tài khoản lab.

Compose publish Nginx/inbox trên 127.0.0.1 và dùng network internal; PostgreSQL không publish port. Backend bật SEED_DEMO=true và COOKIE_SECURE=false. container-start chạy migration rồi seed khi được bật; seed có mật khẩu demo cố định và upsert không thay tài khoản cũ. Phù hợp mục tiêu lab đã ghi trong SECURITY.md; cần cấu hình riêng trước public deployment. Không thử đăng nhập tài khoản thật/có sẵn trong Phần 7.

Bằng chứng: compose.yml; scripts/container-start.mjs; backend/prisma/seed.js:5–8; O-P7-001.

P7 08 Proxy và rate limit

Trạng thái: REVIEW. Kỳ vọng: Đối chiếu IP dùng làm khóa giới hạn khi đi qua reverse proxy.

Auth dùng một limiter 30 request/15 phút cho register/login/forgot/reset. App không đặt trust proxy; Nginx không chủ động ghi X-Forwarded-For. Suy luận từ source: nhiều client qua cùng proxy có thể dùng chung bucket của proxy. O-P7-002 cần kiểm chứng với hai client khi Nginx hoạt động. Không gửi đủ request để khóa người dùng, không tuyên bố đã gây từ chối dịch vụ. Khi sửa phải ràng buộc proxy tin cậy, không bật trust proxy=true tùy tiện.

Bằng chứng: auth.routes.js:15; app.js; infra/nginx/nginx.conf; tài liệu express-rate-limit.

P7 09 Image container và chuỗi build

Trạng thái: REVIEW. Kỳ vọng: Kiểm tra user, dependency trong runtime và khả năng tái lập.

Backend dùng USER node; Nginx dùng image unprivileged; fixture mount read-only. Backend chỉ có một stage thực tế, không tách runtime và không install --prod, nên cần rà soát việc giữ công cụ dev/migration trong image. Tag base image chưa pin digest; CI actions dùng tag @v4. Chưa build/scanner image, chưa kiểm thử quyền volume/capabilities/read-only filesystem. Đây là O-P7-003 về hardening và chuỗi cung ứng, không phải container escape.

Bằng chứng: backend/Dockerfile; infra/nginx/Dockerfile; compose.yml; .github/workflows/ci.yml.

Chi tiết P7 10 đến P7 12

P7 10 Audit toàn bộ dependency

Trạng thái: PASS. Kỳ vọng: Truy vấn advisory thành công, phân biệt lỗi mạng với kết quả sạch.

pnpm audit --json chạy thành công. Metadata totalDependencies=594 và tất cả mức severity bằng 0; advisories rỗng. Không cộng các nhóm dependencies/dev/optional vì có phần chồng lấn. Kết quả là snapshot registry tại thời điểm chạy, không loại trừ zero-day, mã độc package hoặc lỗi dùng thư viện. Không chạy audit --fix, install hay update.

Bằng chứng: dependency-audit-all.json; pnpm-lock.yaml hash.

P7 11 Audit production và inventory

Trạng thái: PASS. Kỳ vọng: Tách dependency production, ghi phiên bản thực thay vì khoảng semver.

pnpm audit --prod --json thành công: totalDependencies=188, devDependencies=0, advisories rỗng. Inventory có 25 dependency trực tiếp trên ba workspace, gồm Vite 7.3.6, Express 5.2.1, React 19.3.0, Axios 1.20.0. Không suy ra installed version từ ^version trong package.json. Chưa kiểm tra CVE của OS/base image bằng container scanner.

Bằng chứng: dependency-audit-prod.json; dependency-inventory.json; direct-dependencies.json.

P7 12 Build frontend và dữ liệu trong bundle

Trạng thái: PASS. Kỳ vọng: Build thành công, không đóng gói secret đã biết hay source map ngoài ý muốn.

Build Vite tạo 28 file tại .local/part7-build, không thay frontend/dist đang dùng. Không có .map; kiểm tra exact-match không tìm thấy secret JWT hiện tại, password DB hiện tại hoặc placeholder JWT trong các file build. Không thấy chuỗi backend/src hoặc .local/settings.json. Giá trị secret chỉ so trong bộ nhớ, không ghi evidence. Đây không phải quét entropy/toàn bộ lịch sử Git. Build không chứng minh CSP Nginx chạy đúng.

Bằng chứng: build-log.txt; build-checks.json; collect-part7.cjs.

Chi tiết P7 13 đến P7 15

P7 13 Source xác thực và phiên

Trạng thái: REVIEW. Kỳ vọng: Theo dấu dữ liệu từ input đến token, DB, cookie và logout.

JWT verify chốt HS256, issuer và audience; middleware tra session hiện tại, hạn dùng, revokedAt và trạng thái user. Password bcrypt cost 12; random token 32 byte, lưu SHA-256 cho refresh/reset. Refresh xoay token trong Serializable transaction, replay thu hồi session. Refresh/logout kiểm tra Origin; cookie HttpOnly/SameSite Strict và secure tùy config. Frontend giữ bearer trong biến module. Đây là rà soát bổ sung, không chạy lại hoặc đánh dấu Fixed các finding Phần 2.

Bằng chứng: auth.routes.js; auth.service.js; middleware/auth.js; frontend/src/api/client.js.

P7 14 Source phân quyền và field cho phép

Trạng thái: REVIEW. Kỳ vọng: Kiểm tra owner/admin được ràng buộc ở backend.

Admin router dùng authenticate rồi requireAdmin. Order/cart/ticket/review gắn userId hoặc parent owner từ req.user; attachment theo ticket và author. Body được parse bởi Zod strict trên các tuyến đã đọc. UI Guard chỉ hỗ trợ UX; server là nơi quyết định quyền. Không phát hiện đường bypass mới từ các luồng đã rà soát, nhưng không khẳng định mọi race, serializer hay tuyến tương lai đều an toàn. Ma trận động Phần 3 được tham chiếu, không tính lại vào Phần 7.

Bằng chứng: modules/admin, orders, cart, tickets, reviews, files; SOURCE_EVIDENCE.md.

P7 15 Query validation và tiền

Trạng thái: REVIEW. Kỳ vọng: Đối chiếu data flow query/transaction với finding đã có.

Product search dùng Prisma contains, không nối SQL. Raw query trong app là tagged SELECT 1 cố định. Id helper chưa chặn biên Int32; pagination page chưa chặn biên phù hợp DB. Money tính bằng BigInt nhưng DB Decimal(14,0) có giới hạn. F-P5-001 và F-P4-001 được giữ Open theo bằng chứng trước; không tạo finding trùng hoặc tuyên bố retest. Checkout kiểm tra tồn và coupon trong Serializable transaction; schema/migration có constraint số lượng và tổng tiền.

Bằng chứng: shared/http.js; shared/money.js; orders.service.js; cart.service.js; schema.prisma; migrations.

Chi tiết P7 16 đến P7 18

P7 16 Source file và URL import

Trạng thái: REVIEW. Kỳ vọng: Theo dấu file path, URL, giới hạn và cleanup.

UUID dùng làm tên lưu, fs write flag wx; file image được decode/re-encode, PDF theo magic bytes. URL import exact origin, pin DNS lookup, không theo redirect, giới hạn bytes và timeout. Attachment cleanup khi transaction thất bại. Avatar/product thay ảnh chỉ đổi pointer, chưa thấy cơ chế xóa file cũ hoặc quota tổng lưu trữ; ghi giới hạn cần thiết kế vòng

đời, chưa thử exhaustion. O-P6-001 được tham chiếu, không tính finding mới. DNS lookup trước timer vẫn cần xem xét nếu mở allowlist rộng.

Bằng chứng: files.service.js; files.routes.js; users.routes.js; admin.routes.js; kết quả Phần 6.

P7 17 Logging CI và secret hygiene

Trạng thái: REVIEW. Kỳ vọng: Kiểm tra dữ liệu log, loại trừ secret và kiểm soát CI.

API log method/path/status/requestId, không log body/cookie/Authorization; Nginx dùng $uri thay vì toàn request query. Một số thay đổi có audit DB; login fail và nhiều action chưa có audit sự kiện riêng. .gitignore loại .env/.local/uploads, .dockerignore loại các thư mục tương ứng; đây không chứng minh lịch sử Git sạch. CI chạy frozen install, generate, unit/integration, build; chưa có bước audit dependency trong workflow. O-P7-003 đề xuất bổ sung bước audit trong CI và chính sách cập nhật dependency.

Bằng chứng: app.js logging và error handler; shared/http.js; infra/nginx/nginx.conf:1; .github/workflows/ci.yml.

P7 18 Bảo toàn và bằng chứng

Trạng thái: PASS. Kỳ vọng: Không đổi dữ liệu ứng dụng hoặc mã nguồn khi đánh giá.

Hash/count toàn bộ bản ghi của 18 model trùng trước/sau; không tạo actor hoặc đăng nhập thành công nên không phải dọn session. File canary duy nhất đã xóa bằng đường dẫn kiểm chứng. 58 file source/config được hash trước/sau và kiểm tra lần cuối sau build vẫn trùng. Có 22 HTTP client attempt gồm 21 response và một connection refused; hai navigation browser chụp ảnh được ghi riêng. App vẫn chạy; bộ build QA nằm trong .local.

Bằng chứng: results.json; final-source-check.json; source-before/after.json; screenshots.

Coverage tổng hợp và giới hạn source review

Phần	Đã thực hiện	Giới hạn còn lại
1 Recon	UI/API inventory, phiên bản, surface	Không đồng nghĩa mọi endpoint đã khai thác
2 Auth session	Register/login/reset/JWT/refresh/logout	F-P2-001 Low còn Open
3 Authorization	Owner A/B, admin, parent child	Ma trận đã thử; không phủ mọi trạng thái
4 Business logic	Cart/coupon/checkout/cancel/race	F-P4-001 Low còn Open; race giới hạn
5 Input browser	Injection/XSS/CSRF và đối chứng	F-P5-001 Low còn Open; không chứng minh SQLi
6 Files SSRF	Upload/download/import và fixture	O-P6-001 PDF; chưa AV/rebinding toàn diện

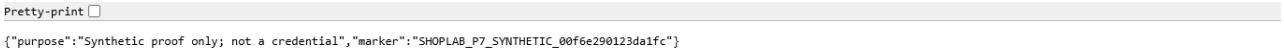
Phần	Đã thực hiện	Giới hạn còn lại
7 Config source	HTTP, build, audit, source data flow	F-P7-001 Low; Nginx/TLS/image chưa chạy
CAPTCHA đăng nhập	Ngưỡng sai, mã thiếu/sai/hết hạn, dùng lại, song song và rate limit	O-CAP-001; chưa đánh giá OCR hoặc tấn công phân tán

Mức bao phủ được thống kê theo các nhóm mục tiêu kiểm thử, chưa thể quy đổi thành tỷ lệ hoàn thành OWASP WSTG/ASVS. Đối chiếu toàn đợt và trạng thái phát hiện được trình bày ở chương kết luận; kiểm tra lại cần thực hiện trên bản ứng dụng đã sửa.

Source review theo luồng: request → schema → authenticate/authorize → Prisma/transaction → response/file/network. SOURCE_EVIDENCE.md lưu 36 file được chọn với số dòng; manifest theo dõi 58 file source/config. Số file được hash không có nghĩa mọi dòng đã được đánh giá thủ công với cùng mức sâu. Các pattern tìm kiếm sink nguy hiểm chỉ là hỗ trợ, không phải SAST hoàn chỉnh.

Không phát hiện chuỗi SQL/command execution mới trong luồng đã đọc. Không dùng absence của eval hoặc raw SQL để tuyên bố không có injection. Các vấn đề Int32/giới hạn tiền đã có bằng chứng ở phần trước được giữ nguyên ID; không tính finding trùng, không tuyên bố đã sửa.

Minh chứng đọc canary trong browser



E-P7-02 • Trích phần đầu giao diện JSON canary chứa marker thử nghiệm.

Ảnh chụp nguyên trạng trang JSON. URL/status của navigation được lưu trong results.json → screenshots; response HTTP độc lập E-P7-019 có cùng nội dung marker. Ảnh không tự chứng minh đường dẫn hoặc trạng thái mạng nếu tách khỏi metadata, vì ảnh page không chứa thanh địa chỉ browser.

File canary đã được xóa sau test. Bản ảnh và HTTP record vẫn là bằng chứng tại thời điểm thực hiện, không phải cam kết URL đó còn hoạt động. E-P7-01-health.png là ảnh bổ sung của health response, được giữ trong thư mục screenshots.

Bàn giao khắc phục và giới hạn cuối

Finding đang Open sau Phần 7: F-P2-001 enumeration đăng ký, F-P4-001 tổng tiền checkout vượt giới hạn, F-P5-001 ID vượt Int32, F-P7-001 phạm vi file dev server. Cả bốn được đánh giá Low trong bối cảnh local và điều kiện đã ghi. O-P6-001 cùng ba observation Phần 7 được theo dõi riêng. Chưa sửa source hoặc retest sau sửa.

Ưu tiên trước chia sẻ môi trường: chặn phục vụ .local/backup qua Vite và tiếp tục chỉ bind loopback. Trước public deployment: tắt demo seed, áp dụng secret/TLS/cookie policy, xác minh proxy identity và limiter, test Nginx headers/CSP, quét image thực và bổ sung audit CI. Sau đó retest từng finding bằng positive/negative control có bảo toàn dữ liệu.

Hồ sơ gồm CASE_LOG.md và cases.json; http.json; config-checks.json; audit all/prod; dependency inventory; build-log/build-checks; SOURCE_EVIDENCE.md; manifests

source; results.json; hai ảnh thật và evidence-manifest.json. 22 HTTP attempt không bao gồm traffic nền browser, audit registry hay build. Không tạo tài khoản hoặc thay đổi DB; hash/count 18 model trước/sau trùng, không phải chứng nhận backup/restore cluster.

Không kiểm thử production thực, TLS/certificate, Docker network runtime, quyền volume/container, OS image CVE, full Git history, external callbacks, DoS, malware, DNS rebinding hoặc mọi tổ hợp race.

Tài liệu đối chiếu chính thức

Vite server filesystem options: https://vite.dev/config/server-options

pnpm audit: https://pnpm.io/cli/audit

express rate limit proxy troubleshooting: https://express-rate-limit.mintlify.app/guides/troubleshooting-proxy-issues

Tài liệu được đối chiếu ngày 26/09/2026 và hỗ trợ phương pháp, khuyến nghị. Kết quả ShopLab được xác định từ bộ bằng chứng của từng phép thử.

BỔ SUNG KIỂM THỬ CAPTCHA ĐĂNG NHẬP

Thực hiện ngày 06/10/2026 trên mã nguồn ShopLab trong thư mục dự án. Phần bổ sung đánh giá cơ chế CAPTCHA được thêm sau đợt kiểm thử ngày 25–26/09/2026. Hai endpoint được kiểm tra là POST /api/auth/login và POST /api/auth/login-captcha.

Kết quả: 2 bài kiểm thử tích hợp và 15 tình huống bổ sung đạt tiêu chí. Bộ tình huống bổ sung ghi 58 request/response HTTP. CAPTCHA được kiểm tra tại backend; gửi đúng mật khẩu trực tiếp đến API khi thiếu mã bắt buộc vẫn bị từ chối. Không ghi nhận khả năng bỏ qua CAPTCHA trong các tình huống đã thực hiện.

Cơ chế xác minh và phạm vi kiểm thử

Email được loại khoảng trắng đầu cuối và chuyển về chữ thường. Bộ đếm lưu theo SHA-256 của email trong bảng LoginAttempt. Sau lần nhập sai thứ ba, API trả HTTP 401 LOGIN_FAILED kèm ảnh CAPTCHA. Từ lần tiếp theo, yêu cầu phải có captchaId và captchaAnswer hợp lệ trước khi backend kiểm tra mật khẩu.

Ảnh CAPTCHA gồm 6 ký tự; ID được tạo từ 24 byte ngẫu nhiên. Đáp án được chuẩn hóa bằng trim và chuyển chữ hoa trước khi đối chiếu hash ràng buộc với email và ID. Mã có thời hạn 2 phút. Trạng thái sai có thời hạn 15 phút, được gia hạn khi phát sinh thêm lần kiểm tra mật khẩu thất bại. Đăng nhập thành công xóa trạng thái của chính email đó.

Giới hạn theo IP là 30 request trong 15 phút và được dùng chung cho register, login, login-captcha, forgot-password và reset-password. Bộ giới hạn chạy trước kiểm tra dữ liệu và CAPTCHA; vì vậy response 429 là chặn theo hạn mức IP, còn 401 CAPTCHA_REQUIRED là thiếu hoặc không đáp ứng mã xác minh của một email.

Phương pháp và dữ liệu thử nghiệm

Các request được gửi bằng Supertest vào cùng Express app của dự án, sử dụng PostgreSQL và cơ sở dữ liệu thử nghiệm riêng. Mỗi nhóm chạy trong một process mới để tách bộ đếm rate limit. Tài khoản thử nghiệm được tạo riêng; không dùng dữ liệu tài khoản đang có trong cơ sở dữ liệu phát triển.

Để đối chiếu trường hợp mã đúng và hết hạn, một số phép thử đặt hash của mã biết trước hoặc timestamp hết hạn trong cơ sở dữ liệu thử nghiệm. Các phép thử này xác minh logic kiểm tra tại backend; không giải ảnh bằng OCR và không đo thời gian chờ thực 2 hoặc 15 phút. Giao diện được rà soát từ AuthPage.jsx và đối chiếu ảnh thực nghiệm ngày 01/10/2026.

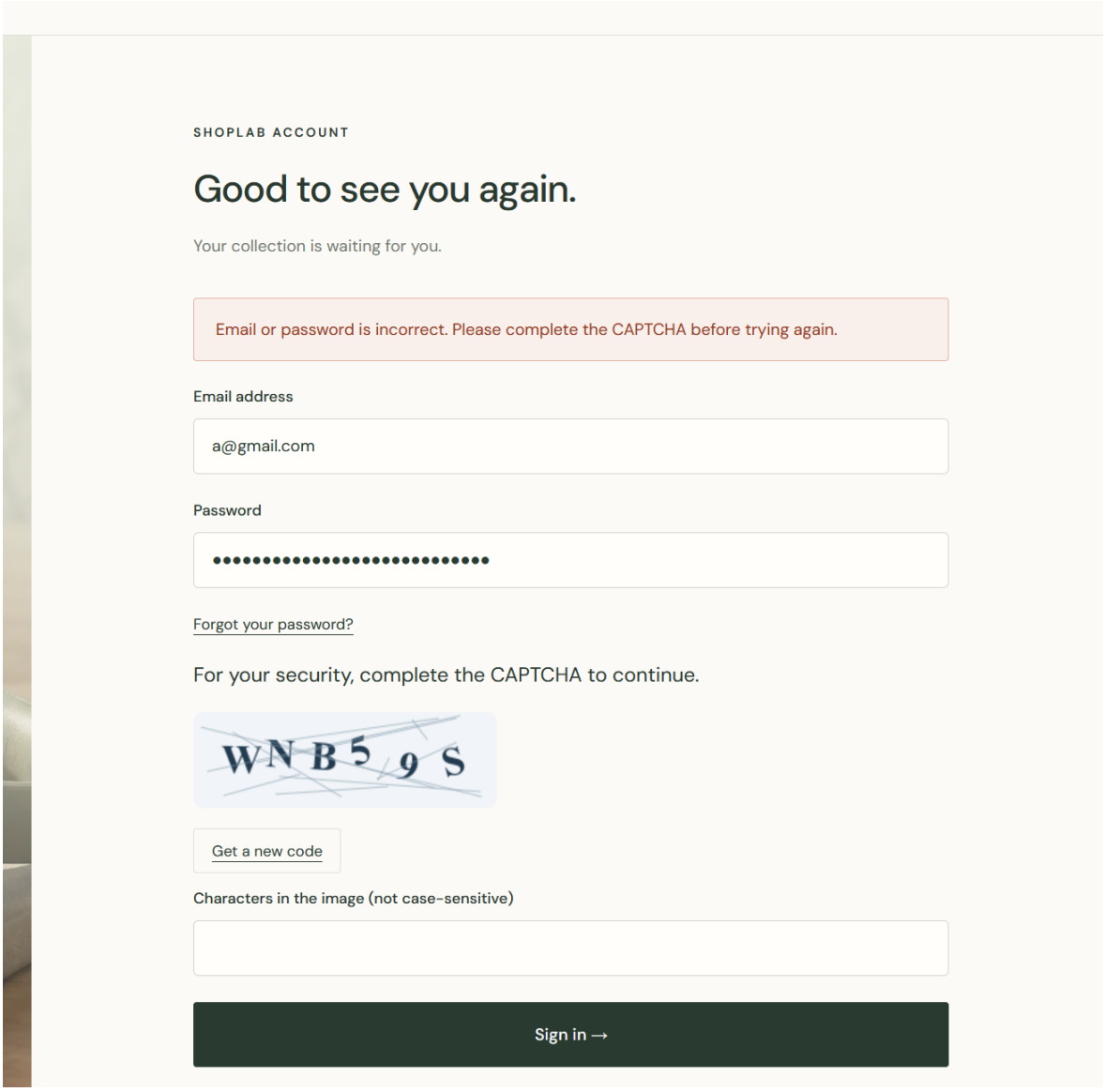
Kết quả chi tiết

Mã	Tình huống	Kết quả ghi nhận
CAP-01	Nhập sai cùng email 3 lần	Lần 1–2: 401 LOGIN_FAILED, chưa có CAPTCHA. Lần 3: 401 kèm ảnh PNG; failures = 3.
CAP-02	Mật khẩu đúng nhưng thiếu CAPTCHA bắt buộc	401 CAPTCHA_REQUIRED; không có accessToken hoặc Set-Cookie.

Mã	Tình huống	Kết quả ghi nhận
CAP-03	Gửi đáp án sai	401 CAPTCHA_REQUIRED; ID ảnh đổi, không cấp cookie phiên.
CAP-04	Mã hết hạn nhưng bộ đếm còn hiệu lực	401 CAPTCHA_REQUIRED. Timestamp hết hạn được đặt trong DB thử nghiệm.
CAP-05	CAPTCHA đúng, mật khẩu sai rồi dùng lại mã	Lần đầu: 401 LOGIN_FAILED và đổi ID. Gửi lại mã cũ với mật khẩu đúng: 401 CAPTCHA_REQUIRED.
CAP-06	Xin mã mới rồi gửi mã trước đó	Đổi mã: 200 và ID mới. Mã cũ bị 401 CAPTCHA_REQUIRED.
CAP-07	Đáp án chữ thường có khoảng trắng và mật khẩu đúng	200, có token và cookie; trạng thái email bị xóa. Lần sai tiếp theo chưa có CAPTCHA.
CAP-08	Đăng nhập B đúng khi A đang bắt buộc CAPTCHA	B nhận 200. A vẫn failures = 3 và bị 401 CAPTCHA_REQUIRED khi thiếu mã.
CAP-09	Dùng mã của A cho email B	401 CAPTCHA_REQUIRED; mã không dùng được giữa hai email.
CAP-10	Đổi email thành chữ hoa và thêm khoảng trắng	Vẫn 401 CAPTCHA_REQUIRED, cùng trạng thái failures = 3.
CAP-11	Ba lần sai gửi đồng thời	Cả ba trả 401; một response kèm ảnh, DB ghi đủ failures = 3.
CAP-12	Trạng thái sai hết hạn, mật khẩu đúng	200 không cần CAPTCHA; trạng thái email bị xóa. Timestamp được đặt trong DB thử nghiệm.
CAP-13	Xin ảnh trước ngưỡng cho email tồn tại và chưa đăng ký	Cả hai trả 200 với captcha = null; riêng phép thử này chưa phân biệt tài khoản bằng trạng thái CAPTCHA.
CAP-14	ID dài, đáp án dài, thêm role hoặc email sai	Bốn request trả 400 VALIDATION_ERROR; không cấp cookie, không tạo LoginAttempt.
CAP-15	Dùng hết quota qua route xin ảnh rồi đăng nhập đúng	30 request đầu: 200. Request 31: 429 RATE_LIMIT. Đăng nhập đúng tiếp theo vẫn 429; có RateLimit và Retry-After.

Bằng chứng HTTP của CAP-01 đến CAP-07 nằm trong lifecycle.json; CAP-08 đến CAP-12 trong isolation.json; CAP-13 và CAP-14 trong validation.json; CAP-15 trong rate.json. Mỗi bản ghi có mã E-CAP, thời điểm, endpoint, status, mã lỗi, trạng thái CAPTCHA và dấu hiệu cấp token/cookie; mật khẩu và đáp án thử nghiệm đã được che.

Minh chứng CAPTCHA trên giao diện



Hình CAP 01 Form đăng nhập hiển thị ảnh CAPTCHA và ô nhập ký tự trong thực nghiệm ngày 01/10/2026

Ảnh giao diện thể hiện yêu cầu hoàn thành CAPTCHA, ảnh 6 ký tự, nút Get a new code và ô nhập ký tự. Log ngày 01/10/2026 ghi lần sai thứ ba của cùng email có CAPTCHA; sau một lần đăng nhập đúng ở tài khoản test, email đó vẫn nhận CAPTCHA_REQUIRED. Kết quả bổ sung ngày 06/10/2026 xác nhận lại tính độc lập của bộ đếm theo email.

Đối chiếu thử đăng nhập bằng Burp Intruder

Danh sách trong thực nghiệm Burp có 300 cặp email và mật khẩu được chuẩn bị. Lượt bị giới hạn theo IP đi đến cặp thứ 28 thì nhận 429; cặp này bị chặn trước kiểm tra mật khẩu. Số 300 là quy mô dữ liệu đầu vào, không phải số cặp đã hoàn tất xác thực. Một ảnh của lượt khác ghi nhận cặp admin hợp lệ trả 200; hai kết quả không thuộc cùng chuỗi request.

Việc đăng nhập thành công bằng cặp thông tin hợp lệ không chứng minh vượt CAPTCHA. Để kết luận bỏ qua cơ chế này, cùng email phải đang ở trạng thái bắt buộc CAPTCHA nhưng vẫn được cấp phiên khi thiếu hoặc sai mã. CAP-02, CAP-03, CAP-05 và CAP-08

đều ghi nhận backend từ chối các trường hợp tương ứng. CAPTCHA đúng cũng không thay thế việc kiểm tra mật khẩu.

Quan sát về việc đổi mã giữa các lượt đăng nhập

O-CAP-001 — Informational: challenge được lưu chung theo email và endpoint xin mã mới không yêu cầu phiên đăng nhập. CAP-06 xác nhận request đổi mã trả 200 và làm mã trước đó mất hiệu lực. Một lượt xin mã khác cho cùng email vì vậy có thể làm người đang nhập phải lấy mã mới. Phép thử chỉ ghi nhận một lần thay mã; chưa đo khả năng gây gián đoạn liên tục hoặc tấn công từ nhiều nguồn IP.

Khi mở rộng triển khai, cần cân nhắc ràng buộc challenge với từng lượt xác thực và giới hạn riêng hành vi xin mã mới. Kiểm tra lại phải bảo đảm mã của một lượt không bị thay bởi lượt khác ngoài thiết kế, đồng thời không cho phép tái sử dụng mã đã hết hạn hoặc đã dùng. Quan sát này được theo dõi riêng với bốn lỗ hổng Low của đợt gốc.

Kết luận và bảo toàn dữ liệu

Các trường hợp đã kiểm tra cho thấy CAPTCHA được thực thi tại API, mã cũ hoặc hết hạn bị từ chối, đăng nhập thành công đặt lại đúng bộ đếm và ba lần sai đồng thời được ghi đầy đủ. Giới hạn IP vẫn có hiệu lực với route xin mã và đăng nhập đúng. Kết quả chưa đánh giá OCR, password spraying phân tán, nhiều replica, proxy production hoặc khả năng tiếp cận của CAPTCHA.

Cơ sở dữ liệu thử nghiệm đã được xóa và cluster thử nghiệm đã dừng sau lượt kiểm tra. Hash SHA-256 của sáu tệp nguồn và kiểm thử được theo dõi khớp trước/sau; mã nguồn ứng dụng không bị thay đổi. Hồ sơ bổ sung lưu tại pentest/runs/captcha-assessment-20261006-r2, gồm results.json, jest-results.json, bốn log HTTP và captcha-api.png. Log ngày 01/10 lưu tại pentest/runs/captcha-demo-20261001/results.json; ảnh Burp và giao diện nằm trong báo cáo demo Brute force CAPTCHA.

Nguồn mã đối chiếu: backend/src/modules/auth/auth.routes.js; backend/src/modules/auth/login-captcha.js; frontend/src/pages/auth/AuthPage.jsx; backend/prisma/schema.prisma; migration 202609300001_login_captcha; backend/tests/integration/login-captcha.test.js.

PHẦN 8 Kết luận toàn đợt và kế hoạch khắc phục

8 1 Chốt kết quả và đối chiếu bằng chứng

Ngày 30/09/2026, đối chiếu 116 mục trong bảy evidence manifest: toàn bộ hash khớp. Việc này xác nhận file hiện lưu trùng manifest đã ghi, không xác nhận tính đúng của mọi diễn giải, không thay thế chữ ký số và không chứng minh ứng dụng hiện tại vẫn có cùng trạng thái.

Bốn phát hiện duy nhất của đợt gốc là F-P2-001, F-P4-001, F-P5-001 và F-P7-001. Các trường hợp tái hiện cùng nguyên nhân được giữ chung một mã phát hiện. Năm quan sát Informational được theo dõi riêng: O-P6-001, O-P7-001/002/003 và O-CAP-001 về việc mã CAPTCHA được thay chung theo email. Phần bổ sung ngày 06/10/2026 không phát sinh lỗ hổng bỏ qua CAPTCHA trong các phép thử đã thực hiện.

Không giữ tín hiệu login CSRF ban đầu như finding: Playwright interception đã tự tạo preflight cho phép credential; lượt browser sạch không interception không tái hiện việc thay tài khoản. PDF giả được nhận là giới hạn validation đã quan sát, không chứng minh malware hoặc thực thi mã. URL chuẩn hóa về cùng origin cho phép không phải SSRF bypass.

8 2 Mức độ rủi ro và điều kiện áp dụng

Mức Low theo bối cảnh lab local, khả năng khai thác và tác động đã chứng minh. Không gán CVSS số khi chưa chốt threat model production. Không có finding mức cao được xác nhận không đồng nghĩa production sẵn sàng: TLS, reverse proxy, image runtime, network deployment và quản lý secret vẫn cần kiểm tra trong môi trường thực.

F P2 001 Phân biệt email đã đăng ký

POST /api/auth/register với email/username mới nhận 200 và session. Giữ email đã có, thay username mới nhận 409 ALREADY_EXISTS; UI cũng xác nhận. Tác động là lộ sự tồn tại email, hỗ trợ chọn mục tiêu; chưa chứng minh mất mật khẩu hay chiếm tài khoản. Evidence E-P2-005–008 và B-P2-004. Cần chính sách đăng ký/xác minh email với phản hồi công khai thống nhất; chỉ sửa câu thông báo không đủ khi status hoặc session vẫn khác.

F P4 001 Checkout vượt giới hạn tiền

Hai sản phẩm do admin cấu hình giá 999999999999: quantity 50 mỗi loại cho tổng 99999999999900 và checkout thành công; quantity 99 mỗi loại cho tổng 197999999999802 và checkout 500. Decimal(14,0) có trần 99999999999999. DB rollback đầy đủ; chưa chứng minh mất tiền hoặc DoS toàn dịch vụ. Evidence E-P4-144–152, D-P4-023/024, ảnh E-P4-02. Kiểm tra trần tổng đơn bằng số chính xác trước khi ghi DB, trả 4xx nghiệp vụ hoặc mở rộng schema nhất quán nếu nghiệp vụ yêu cầu.

F P5 001 ID ngoài Int32 trả lỗi máy chủ

GET /api/products/2147483647 nhận 404 khi không tồn tại; 2147483648 nhận 500. Order/ticket với bearer hợp lệ cũng gặp lỗi tương tự. Nguyên nhân suy ra từ parser không giới hạn Int32 và schema Prisma Int; không có bằng chứng SQLi hay đọc dữ liệu. Evidence

E-P5-036/037/039/040 và E-P5C-006. Chuẩn hóa parser về miền 1..2147483647, từ chối trước query bằng 400, giữ 404 cho ID hợp lệ không tồn tại.

F P7 001 Vite phục vụ vùng file nội bộ

GET không bearer/cookie tới /@fs/<absolute-path> của JSON canary trong .local trả 200 và đúng marker. Không đọc secret thật; cổng chỉ bind loopback; chưa chứng minh đọc cross-origin từ website bên ngoài hoặc khai thác bản Nginx. Evidence E-P7-019/020/022 và ảnh E-P7-02. Thu hẹp fs.allow, deny .local/backup/backend/evidence ngoài nhu cầu frontend, hoặc chuyển dữ liệu nhạy cảm ngoài workspace phục vụ; giữ loopback và dùng static build khi triển khai.

8 3 Thứ tự xử lý đề xuất

Ưu tiên	Hạng mục	Chủ trì dự kiến
1	F-P7-001 trước khi chia sẻ dev server; giữ loopback	Người phụ trách frontend và môi trường
2	F-P5-001 giới hạn ID; F-P4-001 trần tiền và rollback	Người phụ trách backend và DB
3	F-P2-001 chốt chính sách email rồi thay luồng đăng ký	Chủ sản phẩm và backend
Trước public	O-P7-001 secret/demo/TLS; O-P7-002 proxy; O-P7-003 CI/image	Chủ dự án và người phụ trách triển khai
Theo chính sách file	O-P6-001 cấu trúc PDF, scanning/CDR và xử lý tệp lỗi	Chủ sản phẩm và backend
Theo thiết kế đăng nhập	O-CAP-001 tách challenge theo lượt xác thực và giữ giới hạn xin mã	Người phụ trách backend và xác thực

Thứ tự xử lý phản ánh ưu tiên công việc và không thay đổi mức độ nghiêm trọng của phát hiện. Các vai trò chủ trì là đề xuất để lập kế hoạch; thời hạn thực hiện cần được xác định theo kế hoạch dự án.

8 4 Tiêu chí nghiệm thu và retest

F P7 001

Canary mới đặt cùng vùng .local phải bị 403/404 qua đường /@fs/ thường và biến thể có query; các file frontend cần thiết, HMR và production build vẫn hoạt động. Xác minh không dựa riêng vào CORS để bảo vệ file. Không dùng secret thật làm payload kiểm tra.

F P5 001

Kiểm tra ID 0, âm, thập phân, chuỗi, Int32 max/max+1 và số vượt miền an toàn trên product/order/ticket cùng các route dùng parser chung. Invalid trả 400; ID hợp lệ không tồn tại trả 404; ID thật giữ quyền owner/admin đúng. Không có query lỗi 500 do input ngoài miền.

F P4 001

Control tổng dưới/đúng trần theo chính sách phải xử lý đúng; vượt trần một đơn vị trả lỗi nghiệp vụ 4xx. Stock/cart/order/redemption giữ nguyên khi bị từ chối. Kiểm tra coupon 100%, làm tròn, retry idempotency và hai checkout cạnh tranh trên fixture riêng.

F P2 001

Tạo cặp email tồn tại/mới và username mới; đối chiếu status, body, cookie/session, redirect và các khác biệt quan sát được. Kiểm tra luồng xác minh email nếu được triển khai; đánh giá timing có kiểm soát. Chỉ coi Fixed khi tín hiệu tồn tại email không còn theo threat model thống nhất; nếu cố ý chấp nhận thì ghi Accepted risk với người quyết định và lý do.

Observations

Production profile phải tắt seed, từ chối placeholder và dùng HTTPS/Secure đúng thiết kế. Kiểm tra hai client sau Nginx, header giả từ nguồn không tin cậy và audit dependency/image tại ngày kiểm tra lại. Tiêu chí PDF cần bộ mẫu hợp lệ và lỗi cấu trúc; magic bytes không xác nhận tệp sạch malware. Với O-CAP-001, kiểm tra việc tách challenge theo lượt xác thực, giữ bộ đếm sai theo email và từ chối mã hết hạn hoặc đã dùng. Cần đối chiếu hai trình duyệt cùng email để xác minh hành vi đổi mã theo thiết kế.

Kiểm tra lại sau sửa chưa được thực hiện. Hồ sơ mỗi lượt cần ghi phiên bản hoặc hash/image, ngày kiểm tra, dữ liệu thử nghiệm, request/response, ảnh, trạng thái trước/sau và kết quả dọn dữ liệu. Trạng thái gồm Fixed, Partially fixed, Not fixed hoặc Not retested. Phát hiện chỉ được chuyển sang Fixed khi có bằng chứng kiểm tra lại đạt tiêu chí.

8 5 Những phần chưa được kết luận

Chưa chạy kiểm thử Docker/Nginx/TLS thực tế, certificate, network/capabilities/volume của image, OS CVE, mọi cách DNS rebinding, mọi kiểu file độc hại/parser, toàn bộ race interleaving hoặc load test. Không đánh giá payment gateway ngoài ứng dụng, refund thực, hạ tầng Internet, dữ liệu thật hoặc toàn bộ lịch sử Git. Không tuyên bố đạt đầy đủ WSTG hay ASVS.

Kết quả audit dependency thuộc ngày 26/09/2026. Kiểm thử bổ sung CAPTCHA ngày 06/10/2026 không chạy lại audit hoặc kiểm tra lại bốn phát hiện cũ. Các so sánh dữ liệu và source chỉ áp dụng cho từng lượt được ghi trong hồ sơ.

8 6 Bàn giao và khả năng tra cứu

Hồ sơ kỹ thuật đợt gốc gồm CASE_LOG, HTTP JSON, đối chiếu DB/tệp, mã chạy kiểm thử, ảnh gốc và evidence manifest trong pentest/runs/SL-PT-20260925/part1 đến part7. Hồ sơ CAPTCHA bổ sung nằm tại pentest/runs/captcha-assessment-20261006-r2; log đối chứng trước đó tại pentest/runs/captcha-demo-20261001. Thông tin xác thực nguyên văn và backup DB được lưu riêng, không đính kèm báo cáo.

Hồ sơ tổng kết gồm integrity-check.json đối chiếu manifest, merge-provenance.json ghi nguồn các báo cáo, findings-register.json thống kê phát hiện và RETEST_PLAN.md nêu tiêu chí kiểm tra lại sau sửa.